SWE5006 · TEAM 14

Rewind

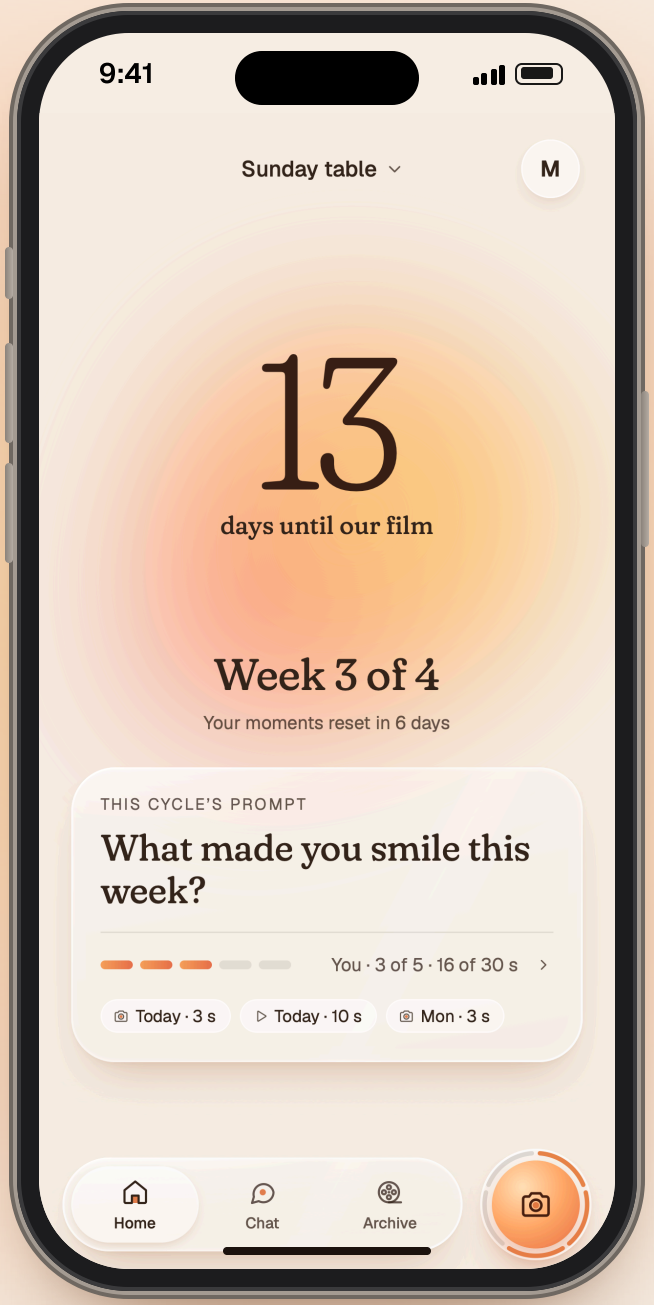
A month of moments. One film.

Small private groups. Sealed moments. A shared reveal.

Contribute → Seal → Compile → Watch

Gopal Guruprasath

27 October 2026



Everyday moments need a shared reason to return

PRODUCT VIEW · PRIVATE-GROUP JOURNEY

01

Contribute

Photo or video
2–10 members

02

Seal

Private until reveal
28-day cycle

03

Watch

One group film
24-hour premiere

5 moments / 30 seconds per member each week

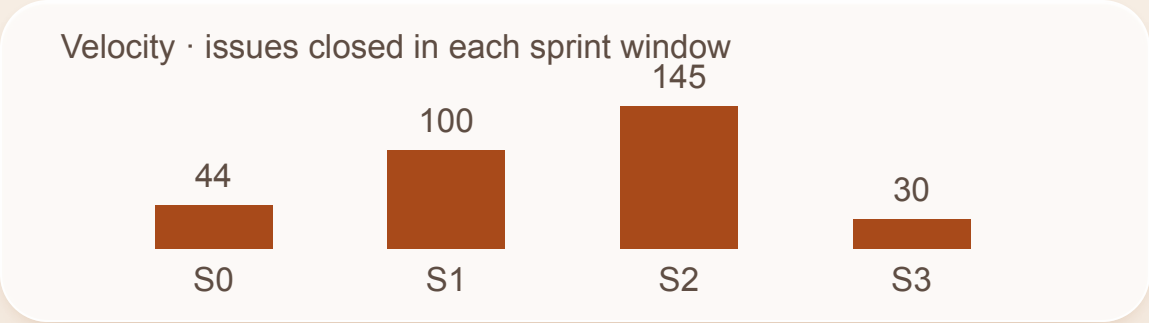
Problem. Photos disappear into busy chats; shared memories become scattered.

Scope. Accounts, invitation, capture, chat, reminders, film and Archive in a web/PWA product.

Value. A bounded contribution habit leads to one shared reveal.

Four sprints delivered the hosted private-group journey

SPRINT	MILESTONE
0 · 1–12 Sep	Runtime foundation
1 · 13–26 Sep	Integrated capture-to-film
2 · 27 Sep–10 Oct	Real accounts · S3 · PostgreSQL · Cognito
3 · 11–24 Oct	Stability · recovery · regression tests



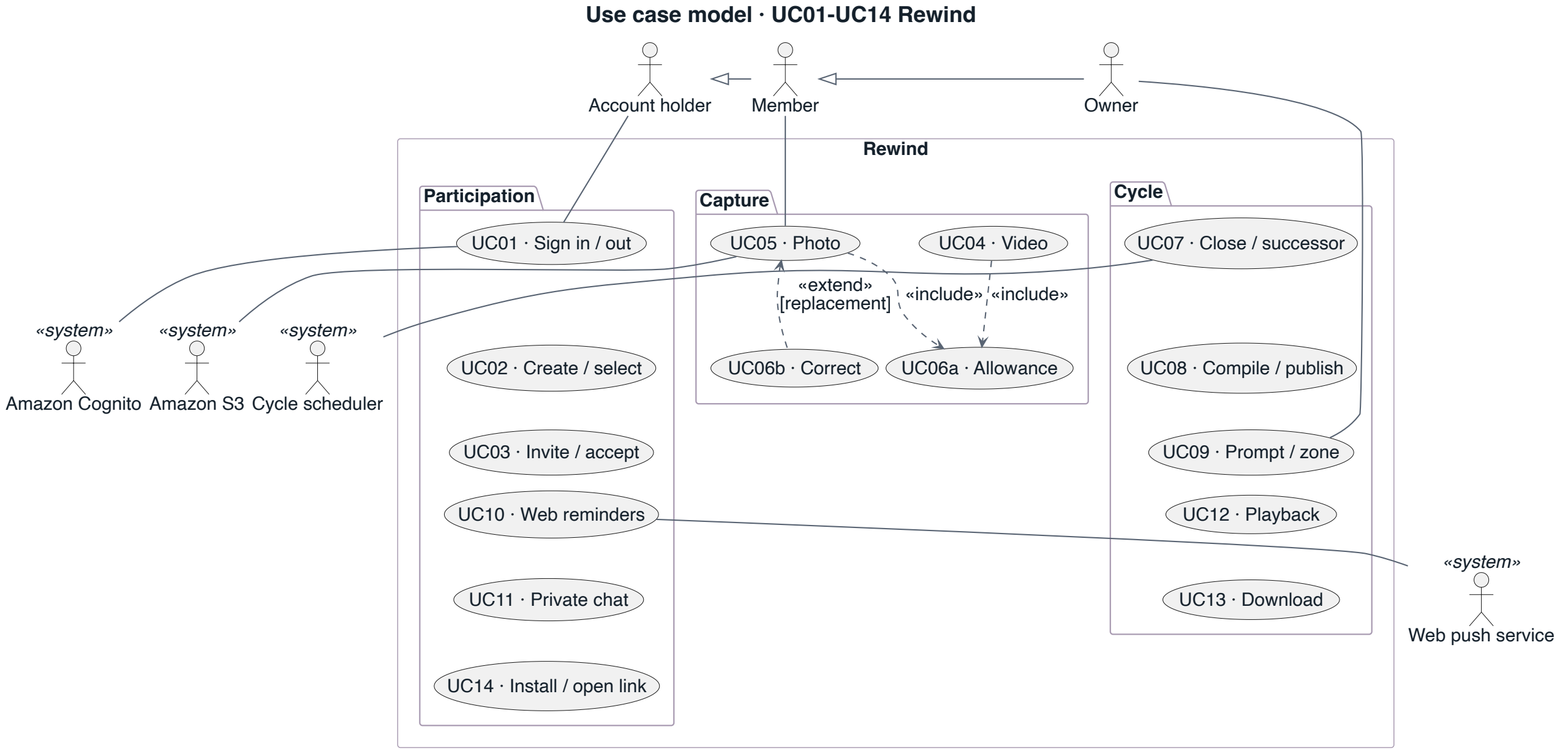
Team · equal effort. Nguyen Kim Long · Gopal Guruprasath · Jiang Jiayu · Phan Mai Tan Loi · Sang Haoxiang.
20% each · 10 person-days each · agreed split.

Done. Outcome checked + fast tests + green Quality + merge to dev. Batch reviews resolve blocking findings.

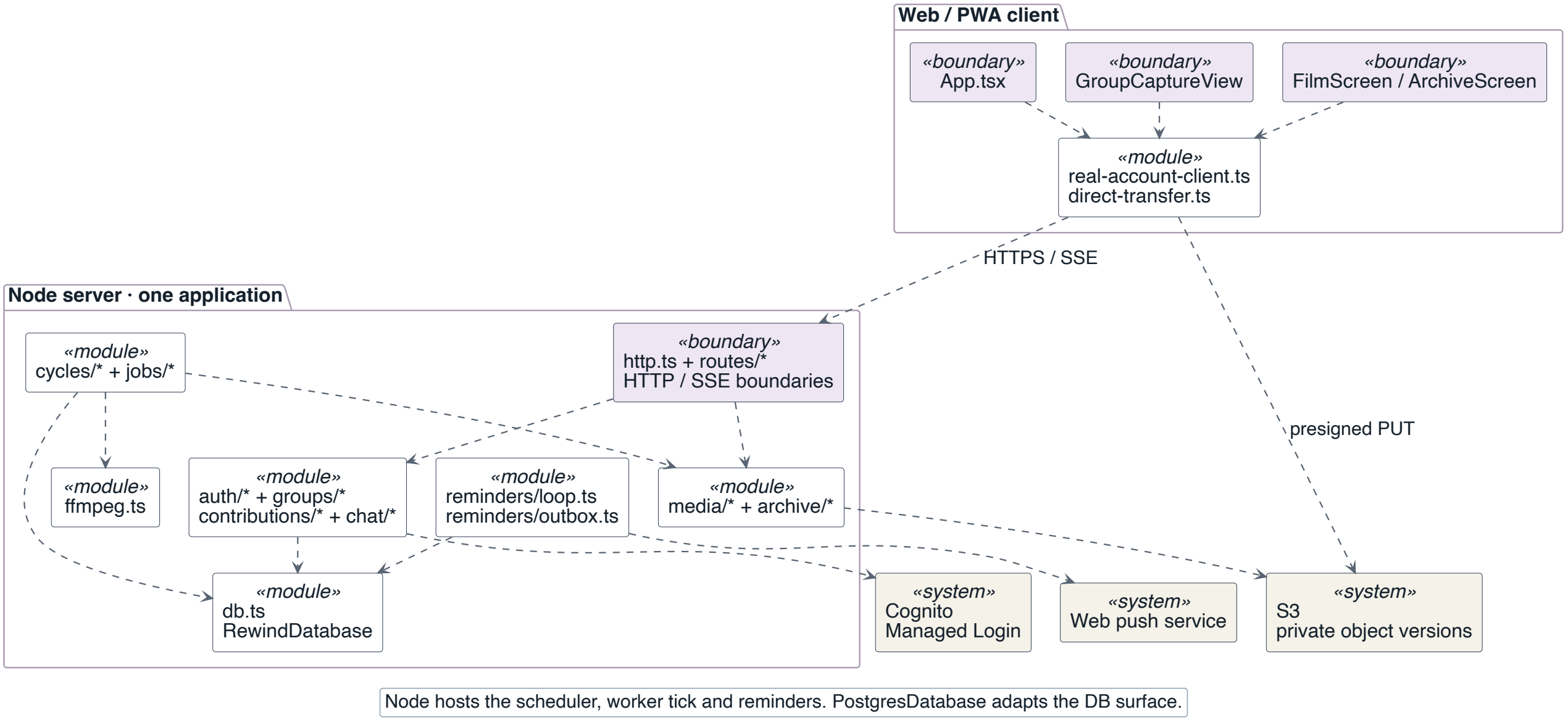
Ceremonies. Project planning; Sprint Planning and Review each sprint. Backlog → stories → sprint plans → review → retro.

Retro → next sprint. Integration gaps in S1 → real adapters in S2; stale state in S2 → interaction tests in S3.

Outstanding #587 focused runner · #588 chat labels · #527 Safari/PWA integration · #362 report assembly

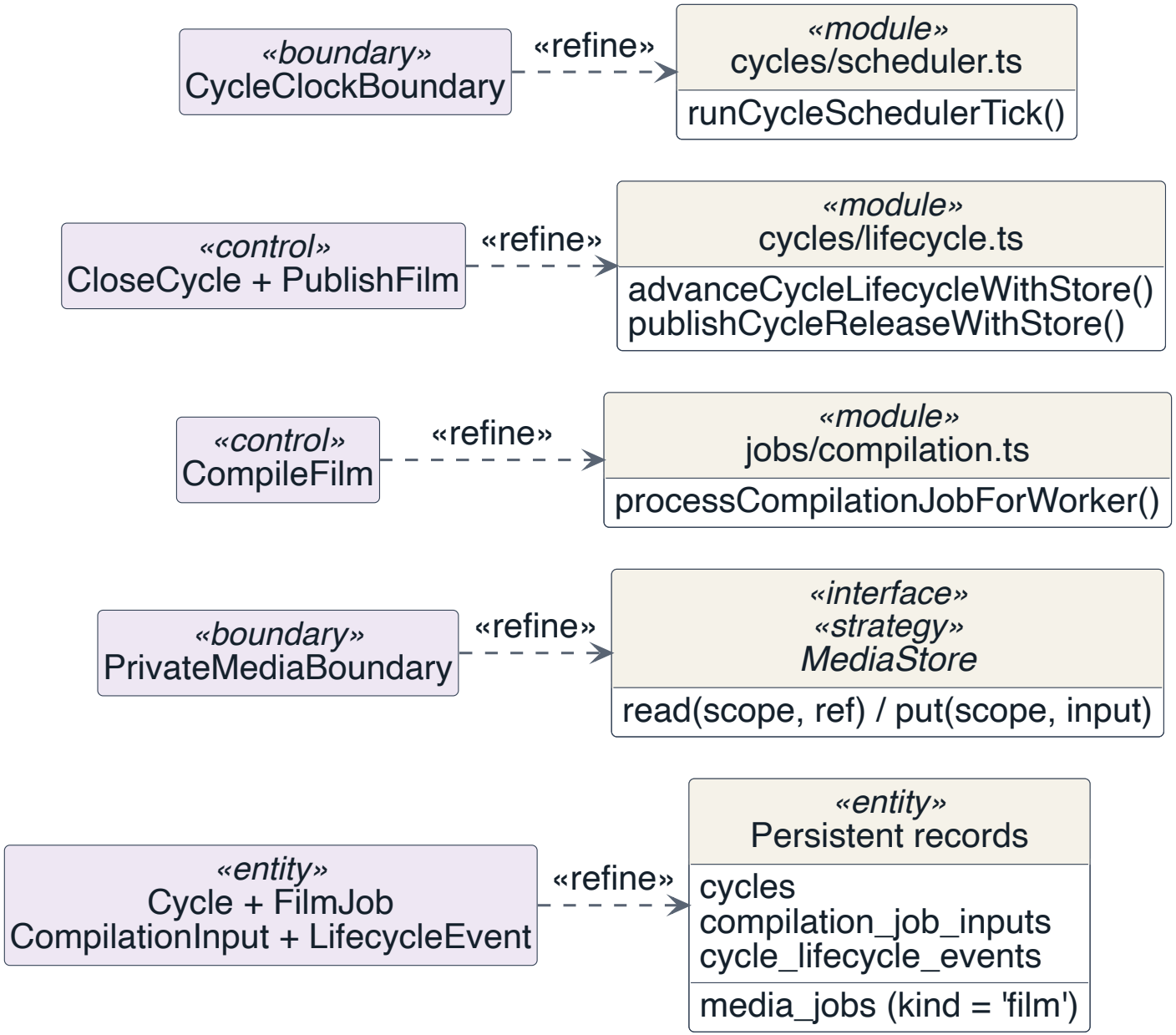

Use case model · UC01-UC14 Rewind
Account holder
Member
Owner
Rewind
Participation
Capture
Cycle
UC01 · Sign in / out
UC05 · Photo
UC04 · Video
UC07 · Close / successor
«extend»
[replacement]
«include»
«include»
«system»
Amazon Cognito
«system»
Amazon S3
«system»
Cycle scheduler
UC02 · Create / select
UC06b · Correct
UC06a · Allowance
UC08 · Compile / publish
UC03 · Invite / accept
UC09 · Prompt / zone
UC10 · Web reminders
UC12 · Playback
UC11 · Private chat
UC13 · Download
UC14 · Install / open link
«system»
Web push service

Logical architecture · UC01-UC14 Rewind

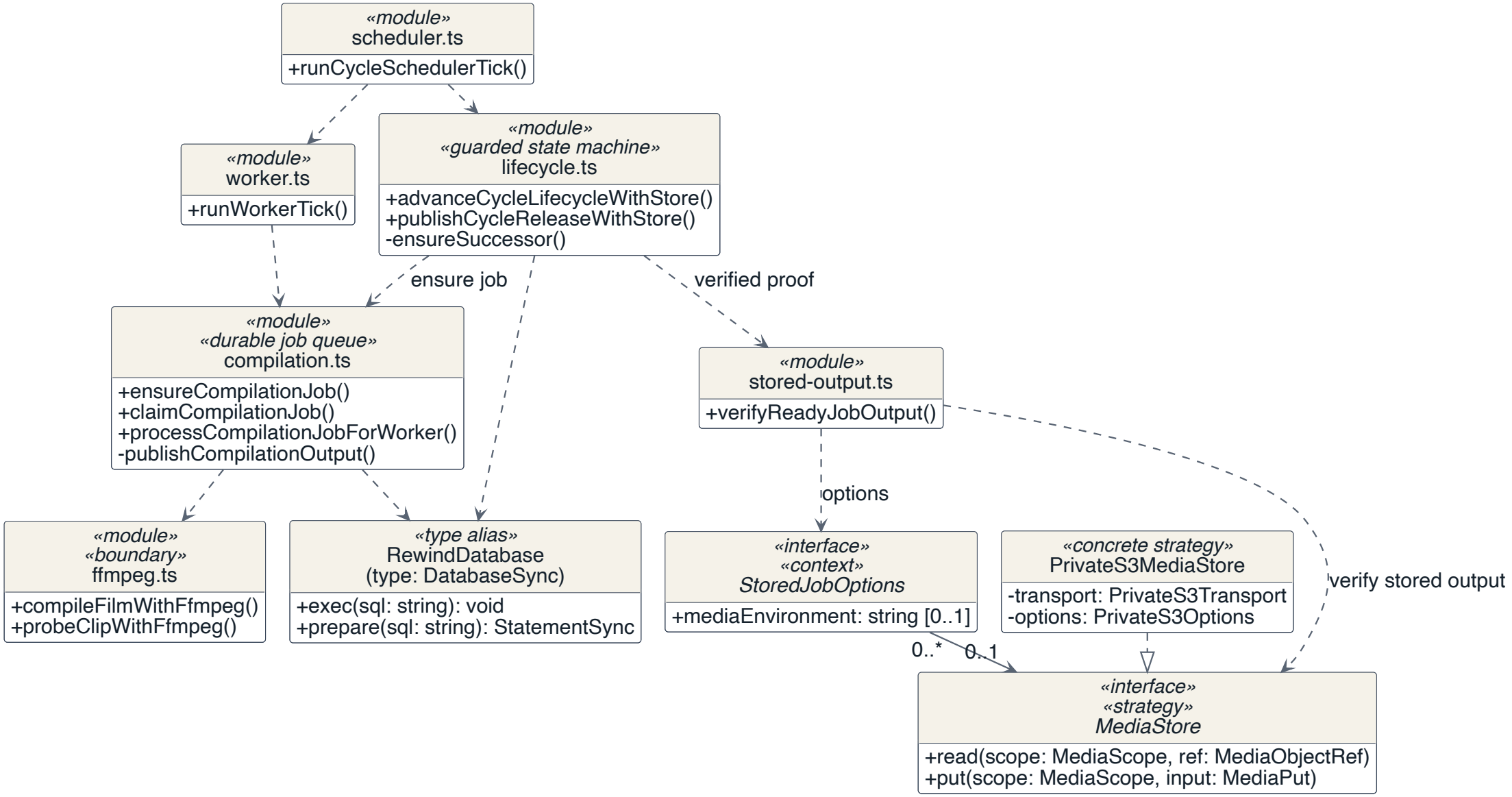


Node hosts the scheduler, worker tick and reminders. PostgresDatabase adapts the DB surface.

Analysis to design · UC07-UC08 Close cycle and release film

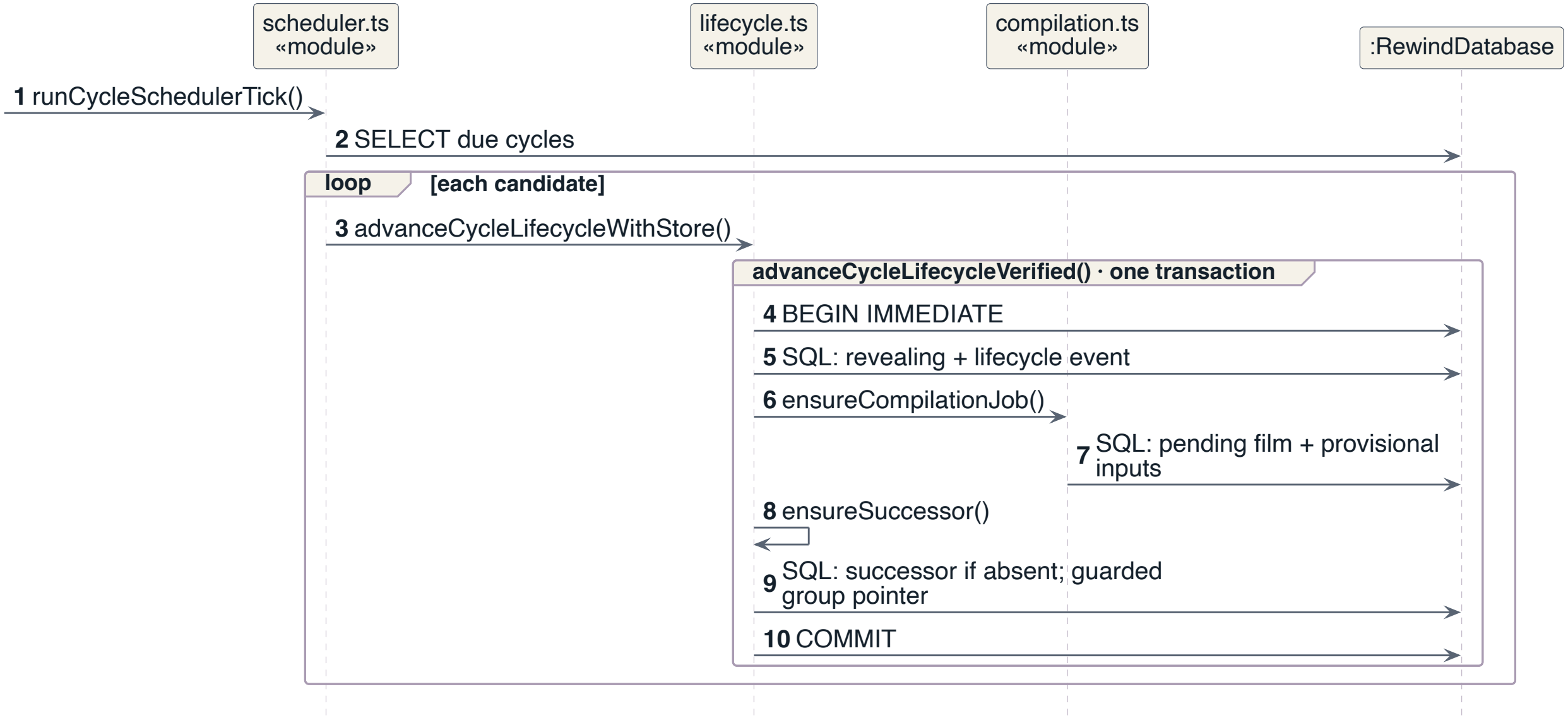


Design classes · UC07-UC08 Close cycle and release film



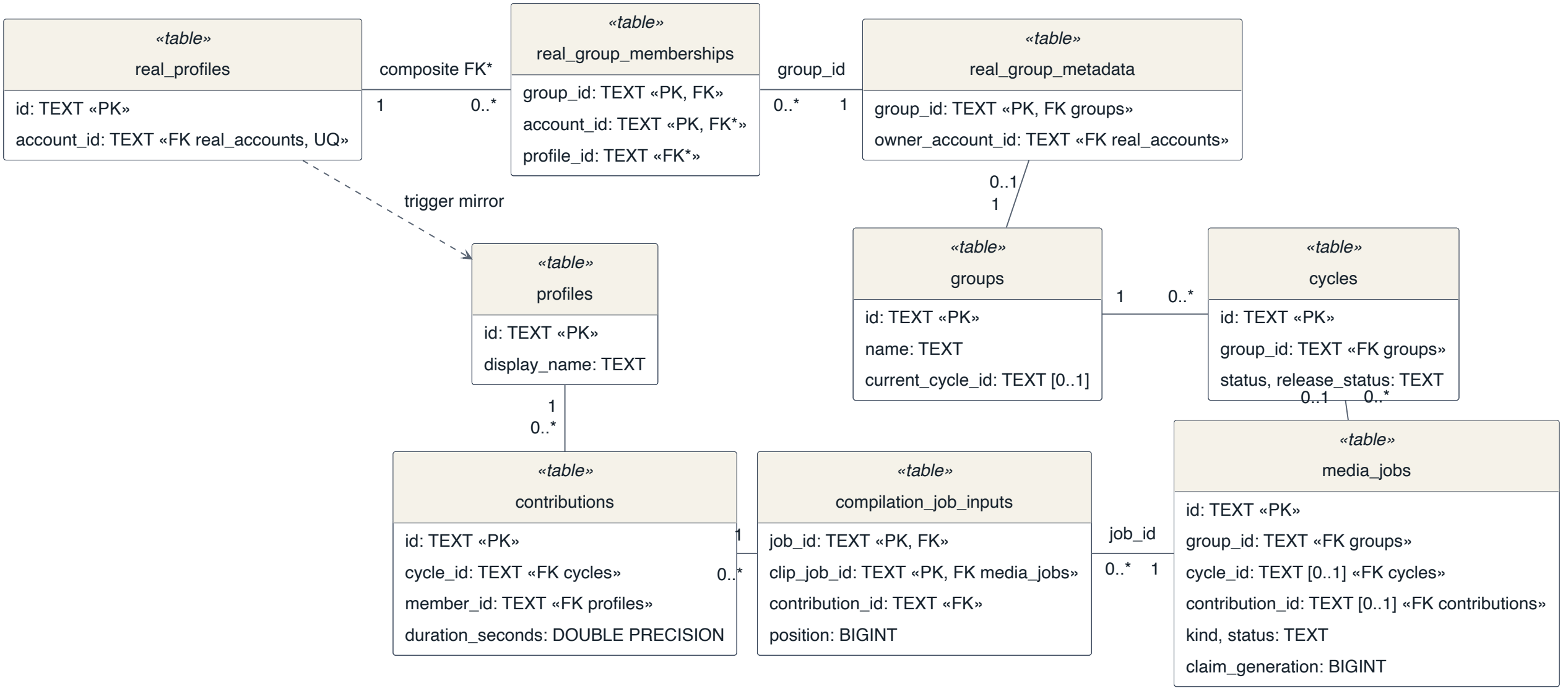
State machine = persisted states + guards. Job queue = records + generation fence.
Functions belong to «module» elements. Storage interface is the Strategy seam.

Design sequence · UC07 Close cycle and open successor



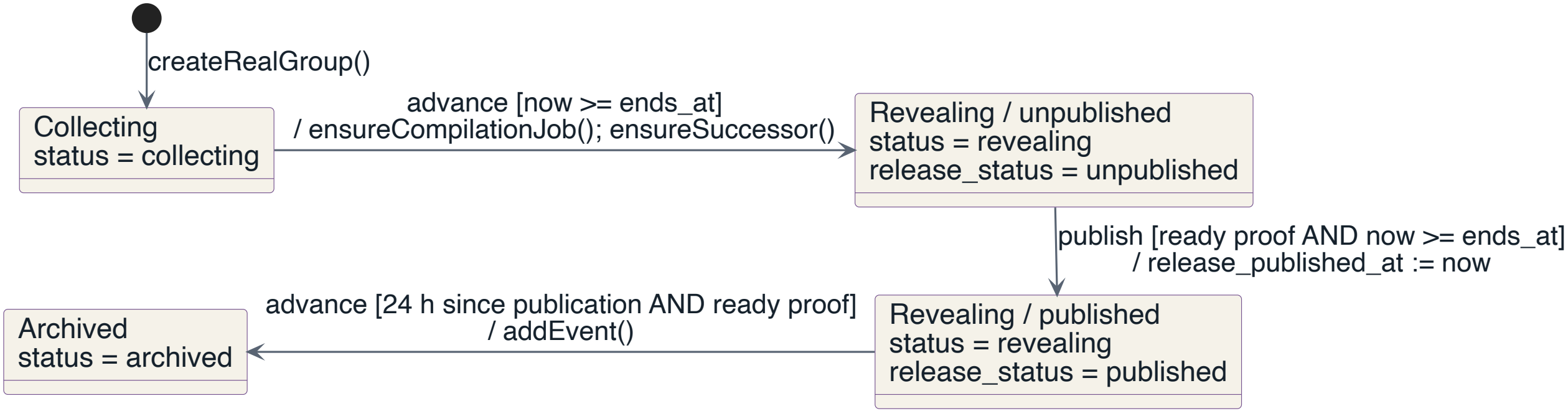
Due collecting-cycle path. Continue with seq-cycle-compile and seq-cycle-release.

Data class view · Real membership, capture and compilation



Selected columns. PK = primary key; FK = database foreign key; UQ = unique; [0..1] = nullable.
FK* = (account_id, profile_id) → real_profiles(account_id, id). real_accounts is the account identity table.
current_cycle_id is an application link. UNIQUE(job_id, contribution_id). Archive reads published cycles + film jobs.

Statechart · UC07-UC08 Close cycle and release film



advance = advanceCycleLifecycleWithStore(); publish = publishCycleReleaseWithStore(). Ready proof = verified film bytes + unchanged ready job. Failed guards retain the state. Intake closes at ends_at via cyclePhase(). The successor collects during release.

Each screen renders one state of the cycle

TESTING

Twelve test types each catch a different failure

TYPE	TOOL	TESTS	WHEN IT RUNS
Static checks	Prettier · ESLint · tsc · layer rule	**4 checks**	Every PR · blocks merge
Frontend unit and component	Jest · Testing Library	**1,674**	Every PR · blocks merge
Server unit and API	node:test · HTTP · SQLite	**1,006**	Every PR · blocks merge
Database	Same suite on PostgreSQL 17	**989**	Every PR · blocks merge
Architecture and repository rules	node:test · Python	**131 + 13**	Every PR · blocks merge
Deployment fixtures	Bash · injected failures	**11 fixtures**	Every PR · blocks merge
Browser end-to-end	Playwright · Chromium	**41**	PRs to main · blocks merge
Web export and PWA	expo export · check-pwa	**10 + 11**	PRs to main · blocks merge
Accessibility	axe-core · keyboard	**6**	PRs to main · blocks merge
Real-account journey	Playwright · Firefox · HTTPS	**1 long flow**	Run on demand
Security	Suites + six pipeline scans	**13 files + scans**	Merge · deploy · report
Performance and load	Node HTTP load runner	**5 stages**	Run on demand

TESTING

Static checks reject style, type and layering errors

4

checks in a parallel matrix

Prettier · ESLint · TypeScript · check-architecture

Every PR · blocks merge

Formatting, lint rules and types are checked before any test runs. The layer rule keeps domain code free of framework imports and keeps device APIs out of routes.

EXAMPLE TEST

`scripts/check-architecture.mjs`

npm run architecture:check · runs in CI and the pre-commit hook

Catches: a domain module that imports React, or a route that imports expo-camera.

TESTING

Component tests check screens and state without a device

1,674

Jest tests in 79 files

Jest (jest-expo) · React Native Testing Library

Every PR · blocks merge

Screens, capture state, stores, the uploader, film playback and the auth client. Coverage is 89.6% of statements against an enforced 70% floor.

EXAMPLE TEST

`tests/real-account-chat.test.tsx`

“loads the selected group, sends replies and never adds session credentials to request URLs”

Catches: a change that leaks the session token into a chat request URL.

TESTING

“Try again” must return to a usable viewfinder

REGRESSION TEST · CU-A PHOTO RETRY

GIVEN

Photo capture fails

WHEN

User taps “Try again”

THEN

Viewfinder returns;
a fresh capture succeeds

Before fix

FAIL

→

After fix

PASS

Fault. Retry called capture from a state where its guard returned at once.

Repair. Return to the viewfinder for a fresh capture.

Test. Fails on the old source; passes with the fix.

`camera-capture.characterisation.test.tsx`

TESTING

API tests call real routes on a running server

1,006

server tests in 66 files

node:test · real HTTP server · SQLite

Every PR · blocks merge

Each test starts the server, signs in and calls the real routes: route contracts, sessions, membership, media integrity, the cycle engine and reminders. Server line coverage is 85.7%.

EXAMPLE TEST

`server/tests/cross-group-access.test.mjs`

“every exposed protected category denies a member of another group without content”

Catches: a missing membership check. Another group’s member must get 403 and no content for contributions, clips and Archive.

TESTING

The server suite runs again on PostgreSQL 17

989

pass on PostgreSQL · 17 SQLite-only tests skip

node:test · postgres:17-alpine service container

Every PR · blocks merge

Local runs use SQLite; hosted dev uses PostgreSQL. Running the same suite on both catches dialect differences. Migration tests check that a fresh schema equals the upgraded one.

EXAMPLE TEST

`server/tests/migration-baseline.test.mjs`

“a fresh database gets exactly the schema of the retired chain”

Catches: schema drift between a new install and an upgraded database.

TESTING

Repository tests stop the architecture and policies drifting

131

root tests · plus 13 Python gate tests

node:test · Python unittest

Every PR · blocks merge

The layer guard, service-worker cache rules, the change-scope classifier, deployment policy and Terraform policy are all tested like code.

EXAMPLE TEST

`tests/architecture.test.mjs`

“architecture guard rejects framework imports in domain and device imports in routes”

Catches: a broken layer guard. The test plants a bad import in each layer and expects both to be reported.

TESTING

Deployment scripts are tested offline with injected failures

11

shell fixtures · no cloud access

Bash fixtures · fake tar, chown and health check

Every PR · blocks merge

Backup, restore, release bundle and host lifecycle run against fake commands. Failures are injected at plan, apply, transfer, restore and health.

EXAMPLE TEST

`tests/deploy/restore-atomic.test.sh`

Cases: corrupt media · checksum · extraction · permissions · readiness

Catches: a restore that half-applies a broken backup. Every case must leave the previous state in place.

TESTING

Playwright drives the exported app in a real browser

41

Playwright tests in 9 specs

Playwright · Chromium · iPhone-size viewports

PRs to main · blocks merge

Real-account journey · on demand

Phone-size layout, capture with an injected camera stream, video fallback, film playback and the chat keyboard. A separate Firefox journey runs owner, invited member and outsider over local HTTPS.

EXAMPLE TEST

`tests/e2e-real-account/real-account.spec.mjs`

“real owner, invited member, outsider, strict local HTTPS, and automatic next cycle”

Catches: an outsider who can open the owner’s group. The journey expects a 404.

TESTING

The PWA build is checked the way it will be installed

10 + 11

routing tests · service-worker rule tests

expo export · check-pwa · Playwright

PRs to main · blocks merge

Service-worker rules · every PR

After export, check-pwa verifies the manifest, service worker, offline page, Apple Home Screen metadata and icons. Routing tests reload deep routes offline and check cache headers.

EXAMPLE TEST

`tests/pwa.test.mjs`

“private API/media, invite query navigations and writes never enter the shell cache”

Catches: a service worker that would cache private media or API answers on a shared phone.

TESTING

Axe and keyboard tests check the main screens for WCAG 2.1 AA

6

tests · 4 Axe scans and 2 keyboard tests

@axe-core/playwright · WCAG 2.0 and 2.1, A and AA

PRs to main · blocks merge

Welcome, sign-in, registration, Home, Settings, Camera, Chat, Archive, the sign-out dialog and the loading state. Any serious or critical violation fails the test.

EXAMPLE TEST

`tests/responsive/accessibility.spec.ts`

“sign-out dialog keeps keyboard focus inside, restores its trigger, and has no serious or critical violations”

Catches: a dialog that lets keyboard focus escape behind it.

TESTING

Security is tested in the suites and scanned in the pipeline

In the test suites

Access and privacy. 13 server files: cross-group reads, media tokens, Cognito callback failures, account safety.

Rate limits. `safety-rate-limits.test.mjs`: thirty chat messages pass, the next is refused.

Patched dependencies. braces and node-forge: the original `node-forge` accepts a forged signature; our fork rejects it.

Scan gates. 13 Python tests prove the IaC and image gates reject expired, wrong or incomplete scans.

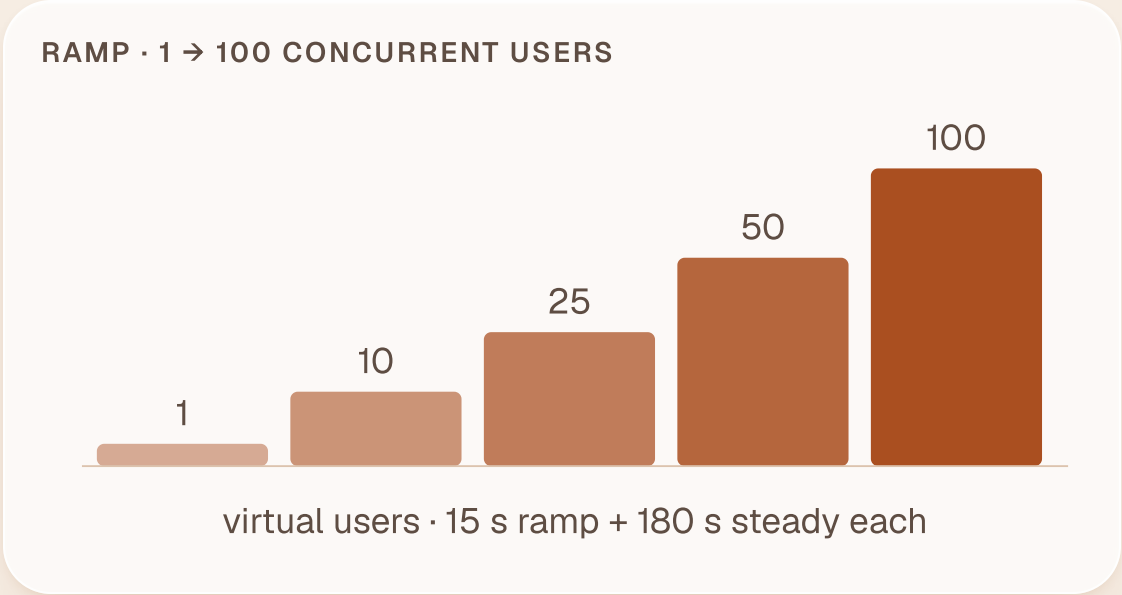
Every PR · blocks merge

In the pipeline · Section 4

SCAN	TOOL	DECISION
SAST	CodeQL	Reports
SCA	npm audit	Blocks merge
Secrets	Gitleaks	Fails its job
IaC	Trivy config	Fails its job
Images	Trivy	Blocks upload
DAST	ZAP baseline	Reports

TESTING

A scripted load test drives the hosted API in five stages



Pass rule: every stage p95 < 2 s and errors < 1%.

Target. Hosted dev: CloudFront → Node API → PostgreSQL.

Runner. Node HTTP closed loop, `scripts/load/hosted.mjs`; manual `performance.yml` workflow.

Users. Each virtual user acts, then waits 3–7 s.

ACTION	SHARE
Read chat	**30%**
Open Home	**20%**
List groups · open Archive	**15% each**
Budget · media links	**10% · 5%**
Send chat	**5%**

TESTING

100 concurrent users stay under the 2-second target, error-free

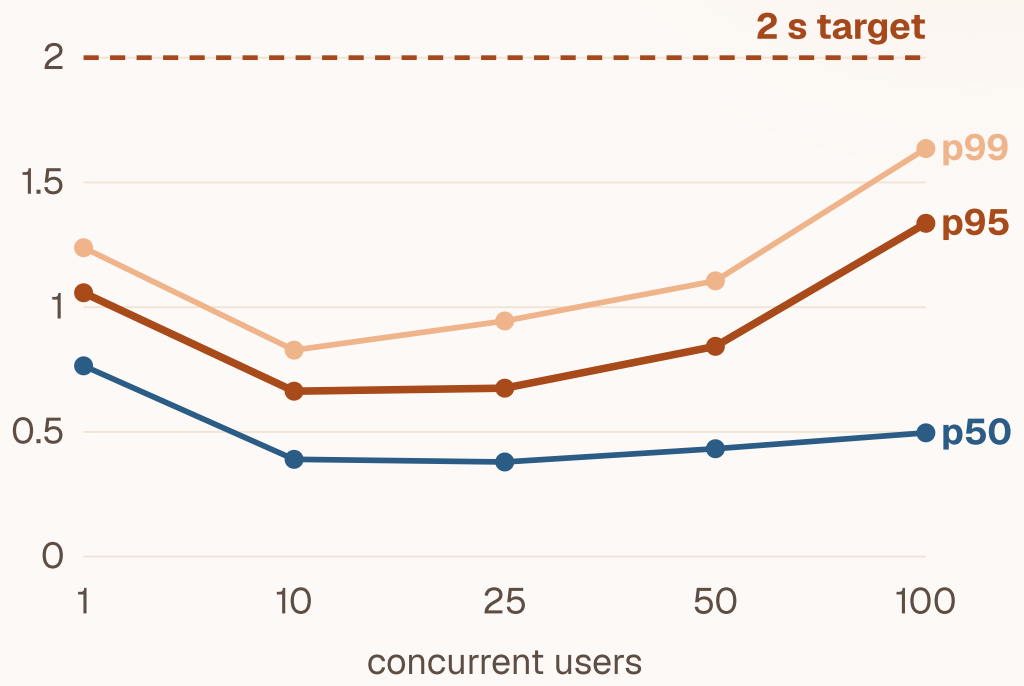
USERS	P95 MS	REQ/S	ERRORS	STAGE
1	1,058	0.21	0%	PASS
10	663	1.83	0%	PASS
25	675	4.59	0%	PASS
50	842	9.06	0%	PASS
100	1,336	17.84	0%	PASS

6,038
steady requests

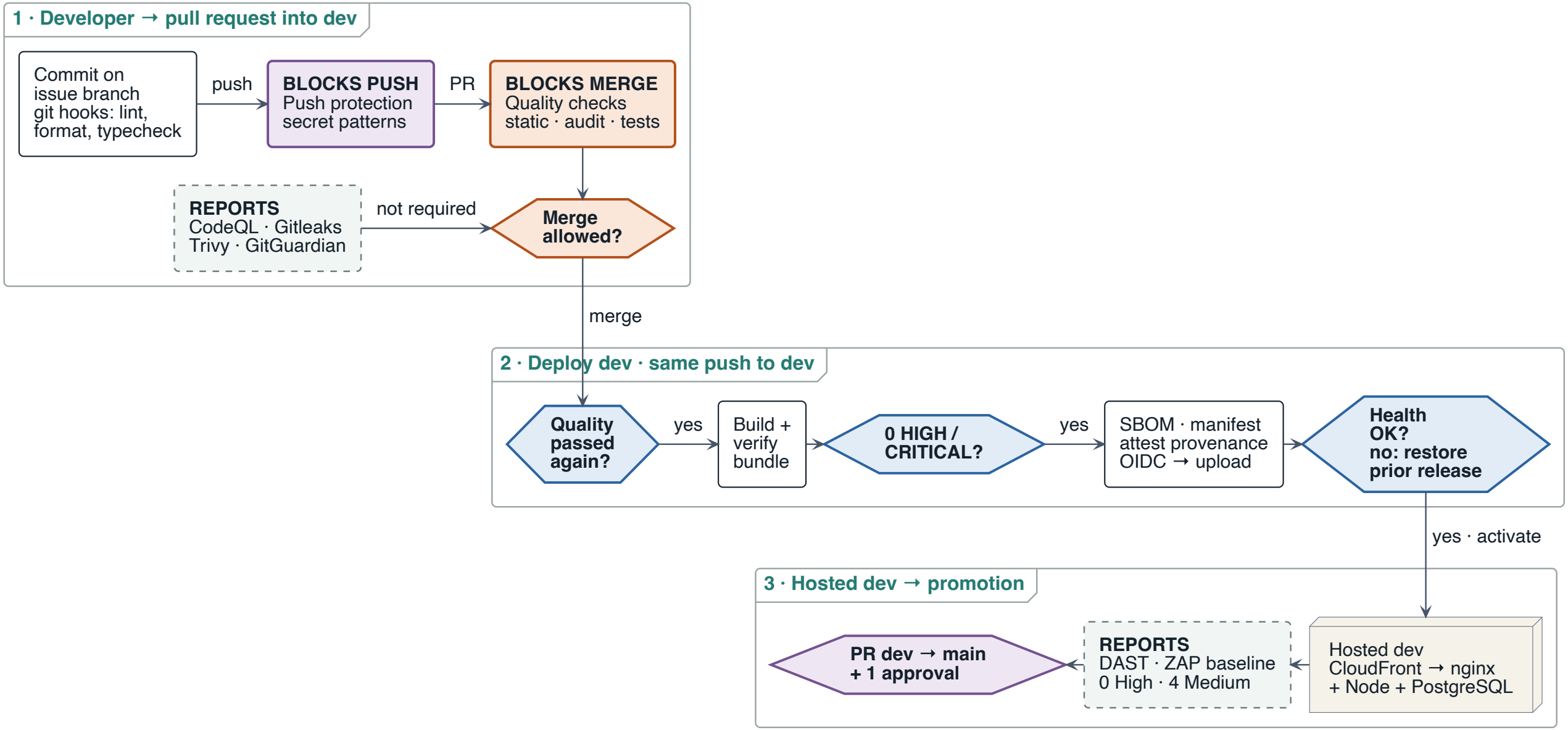
0
errors

1.34 s
p95 at 100 users

LATENCY BY STAGE · SECONDS

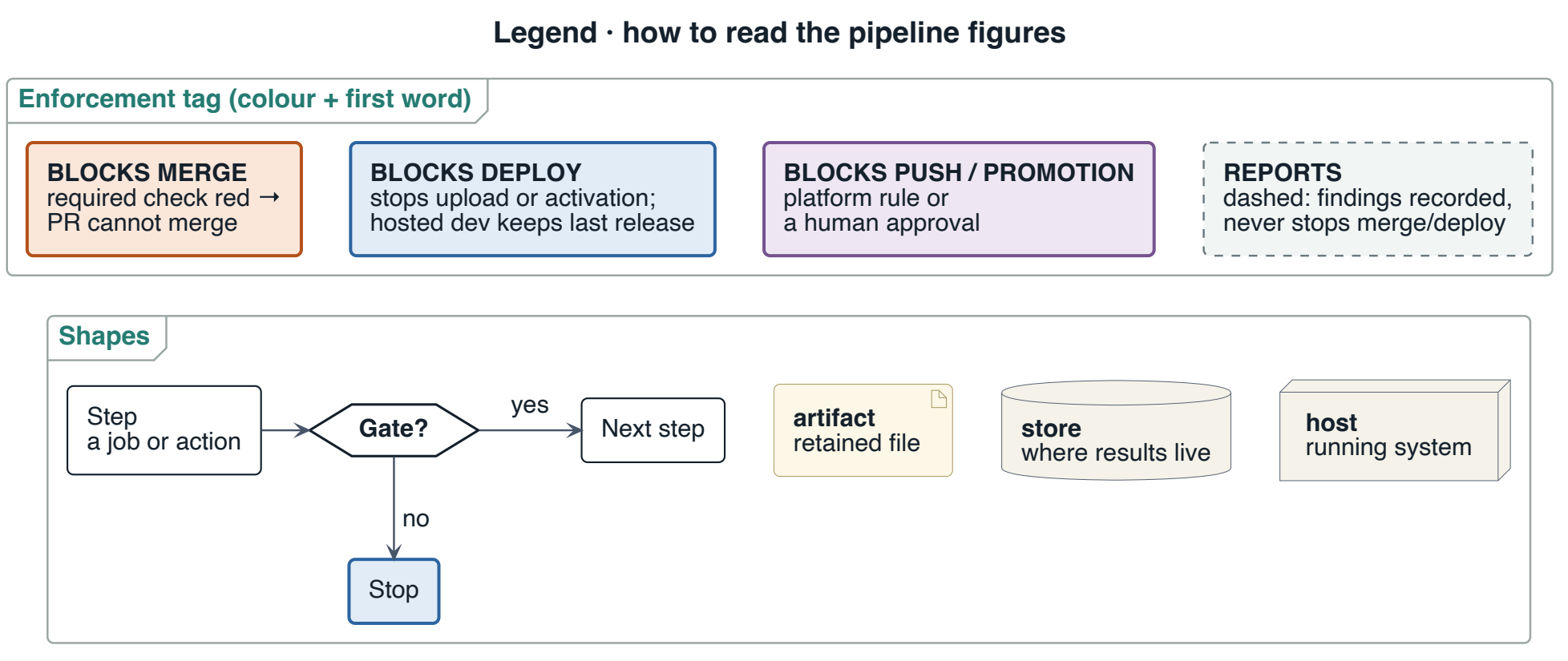


Pipeline view · one change from commit to hosted dev



Colour says what a failure blocks; shape says what the element is

LEGEND · SYMBOLS USED ON EVERY PIPELINE PAGE

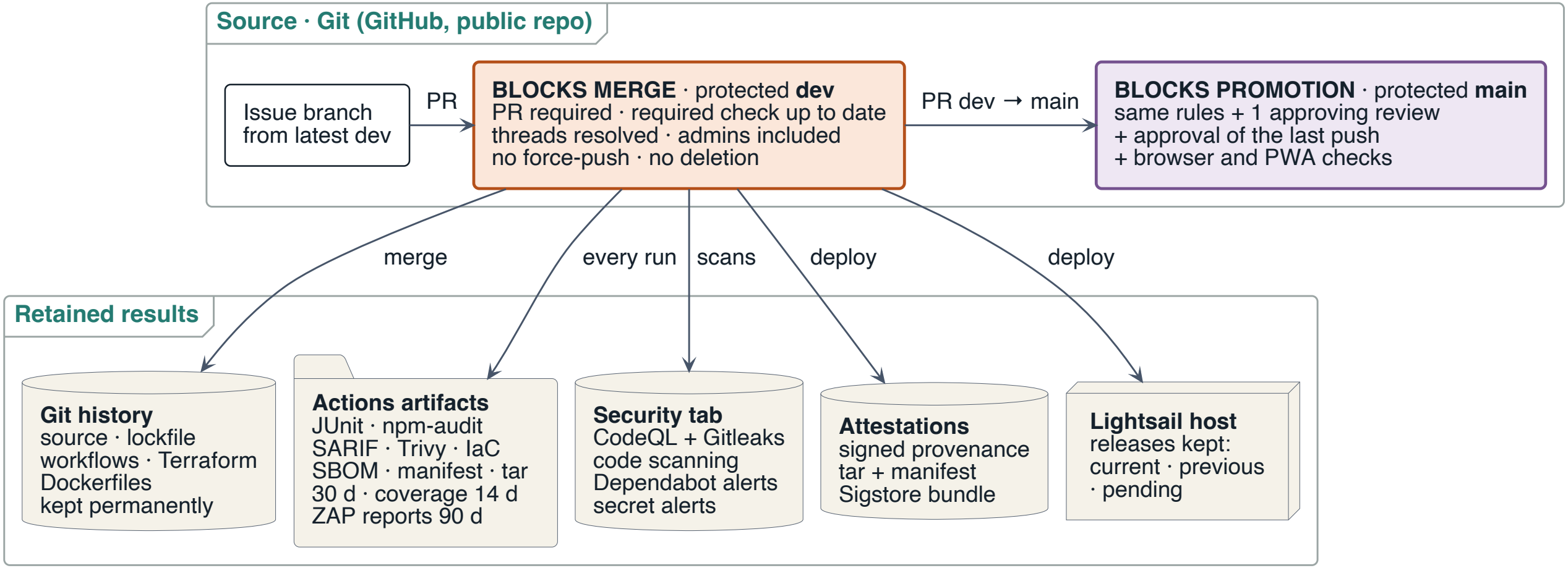


Frame = swimlane: where the work runs (developer, GitHub runner, AWS, Lightsail host).

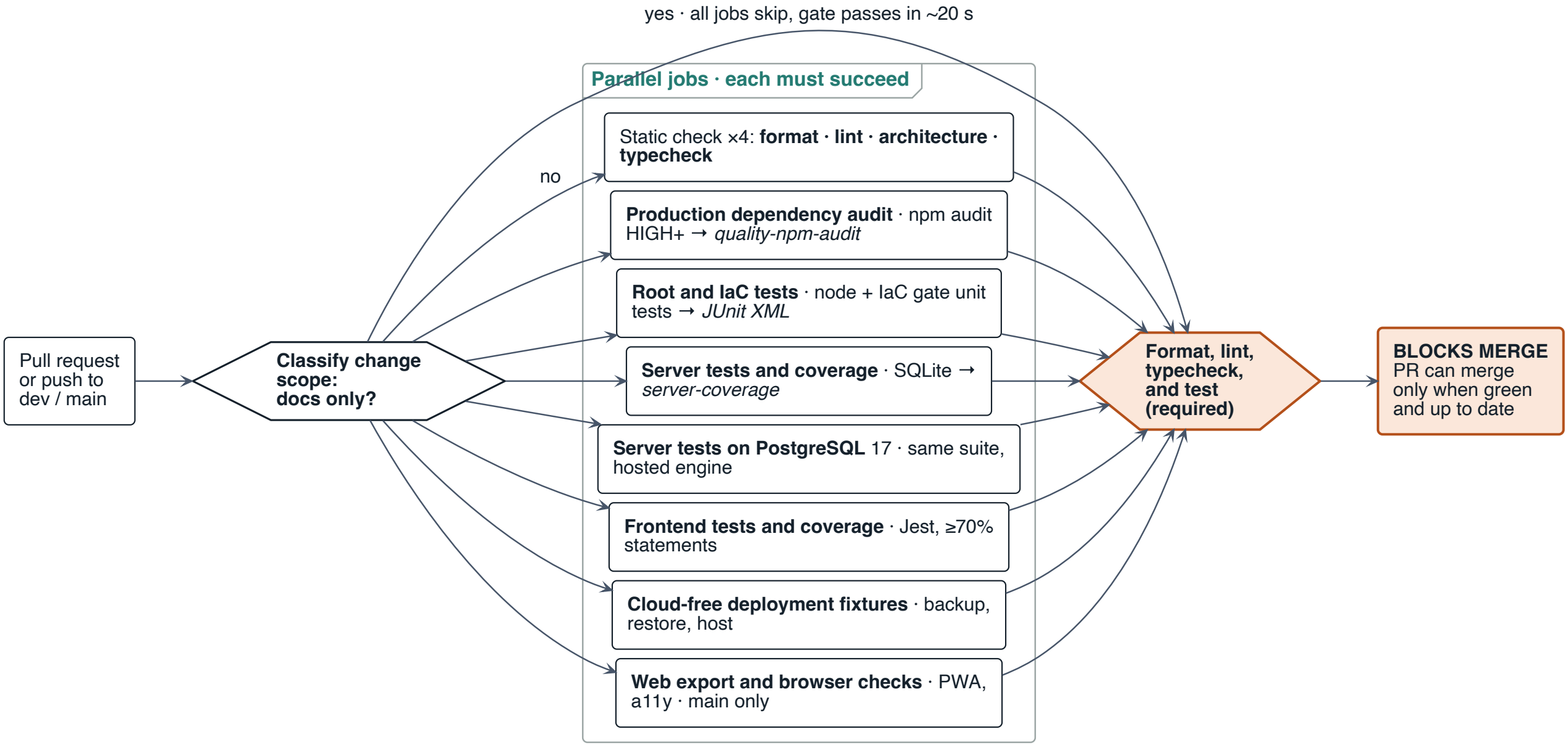
Arrow = control flow; its label is the condition (yes / no) or the trigger.

Hexagon = gate. Its colour names what a “no” blocks: the merge, the deploy, or the promotion.

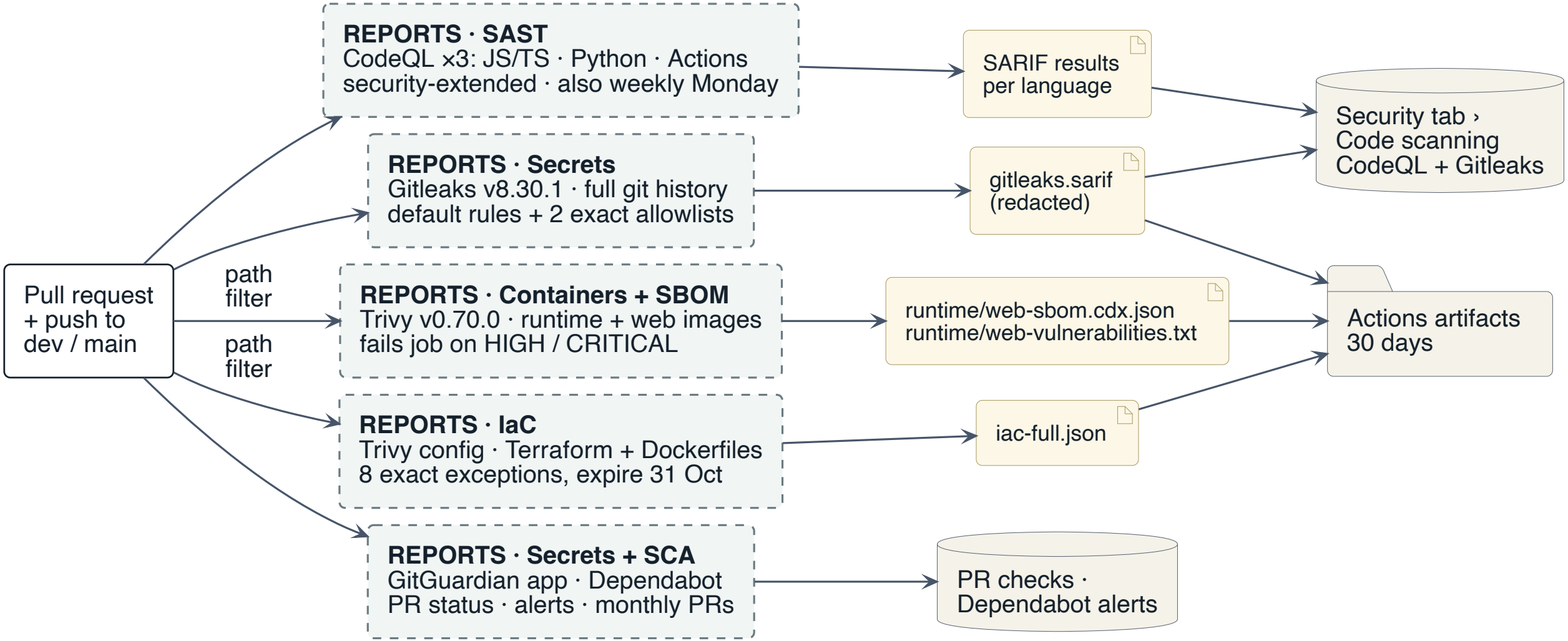
Source and artifact management · where every change and every result is kept



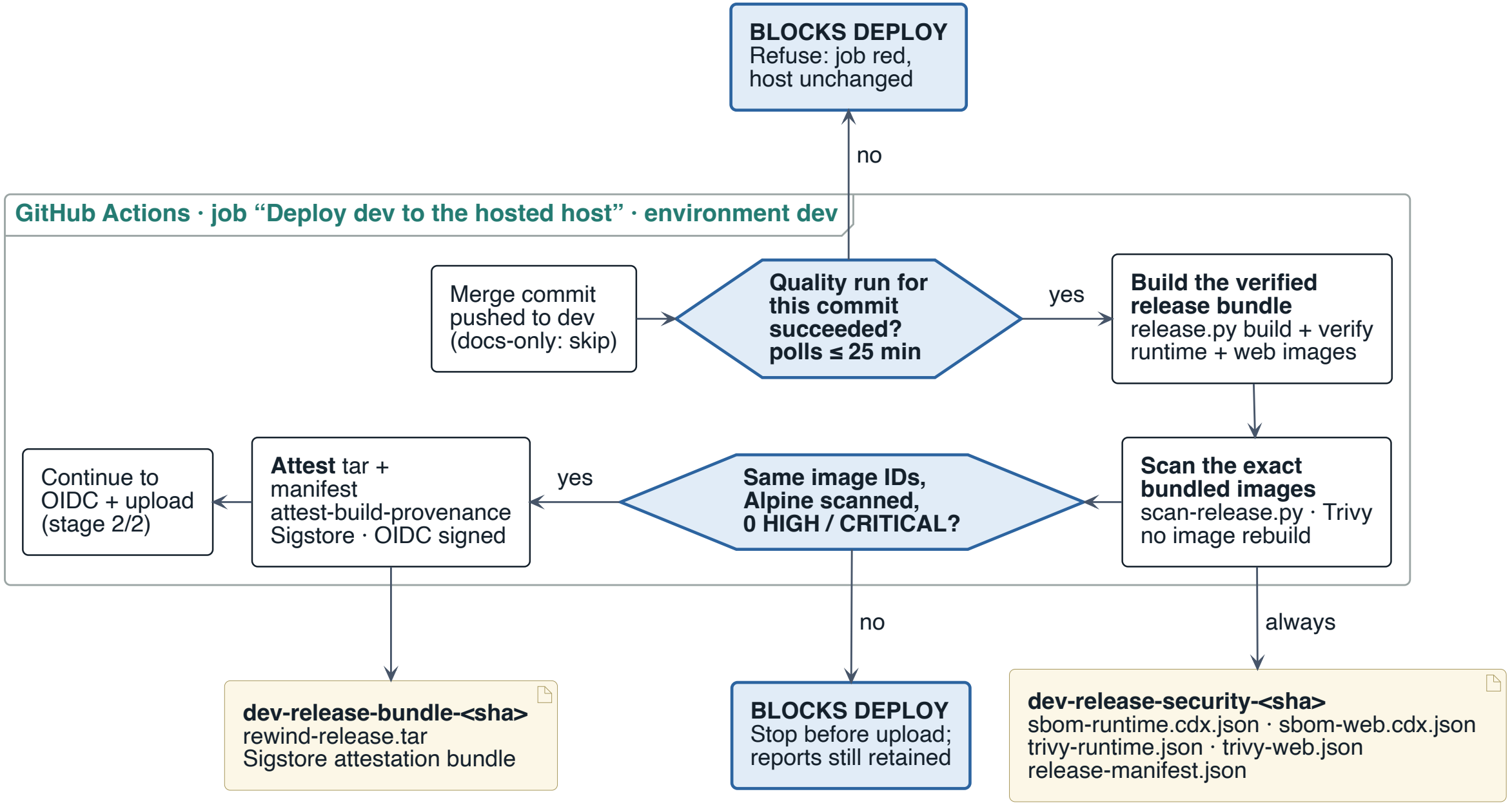
PR stage · Quality checks workflow (quality.yml) decides whether a PR may merge



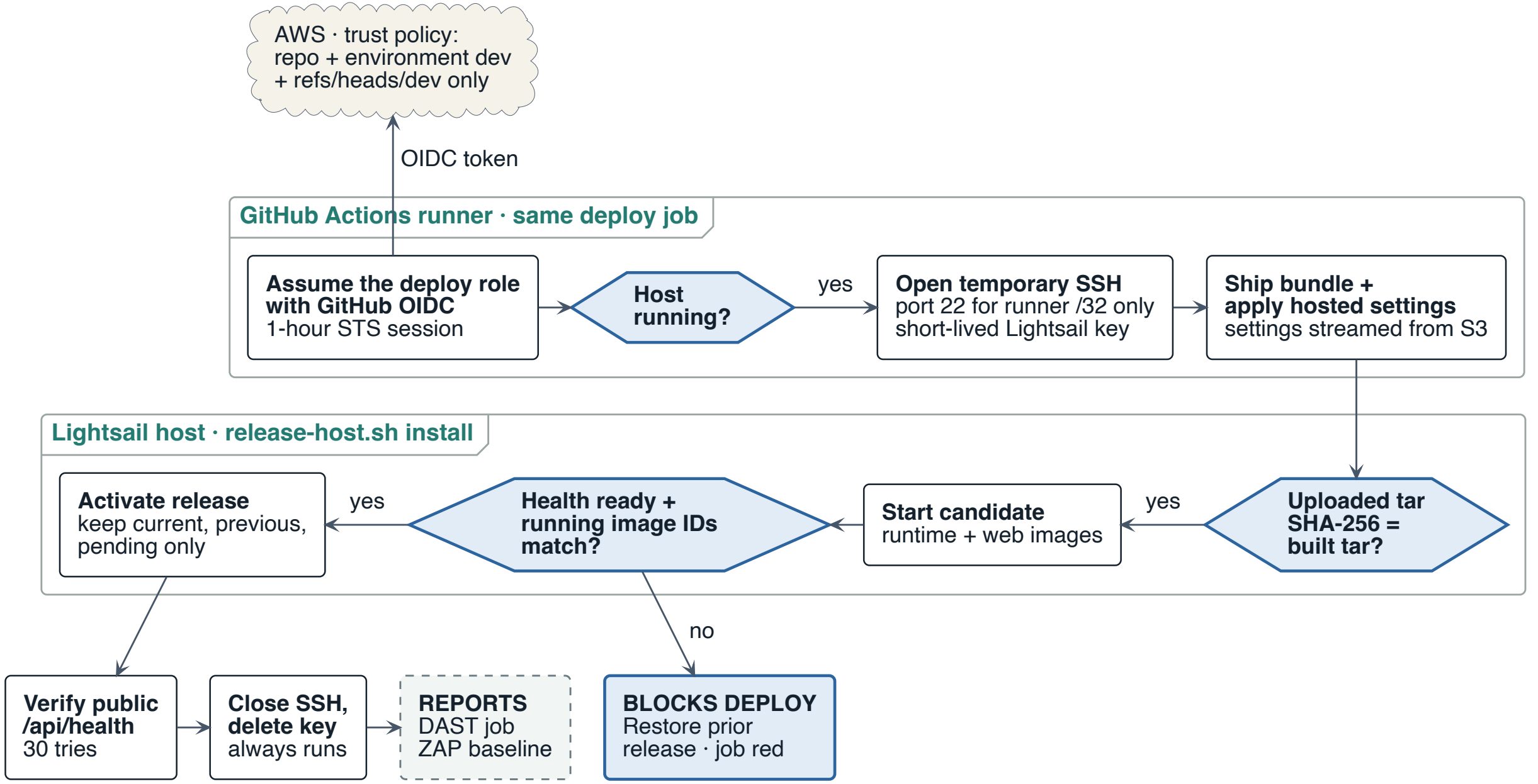
PR stage · security workflows run beside Quality and report their findings



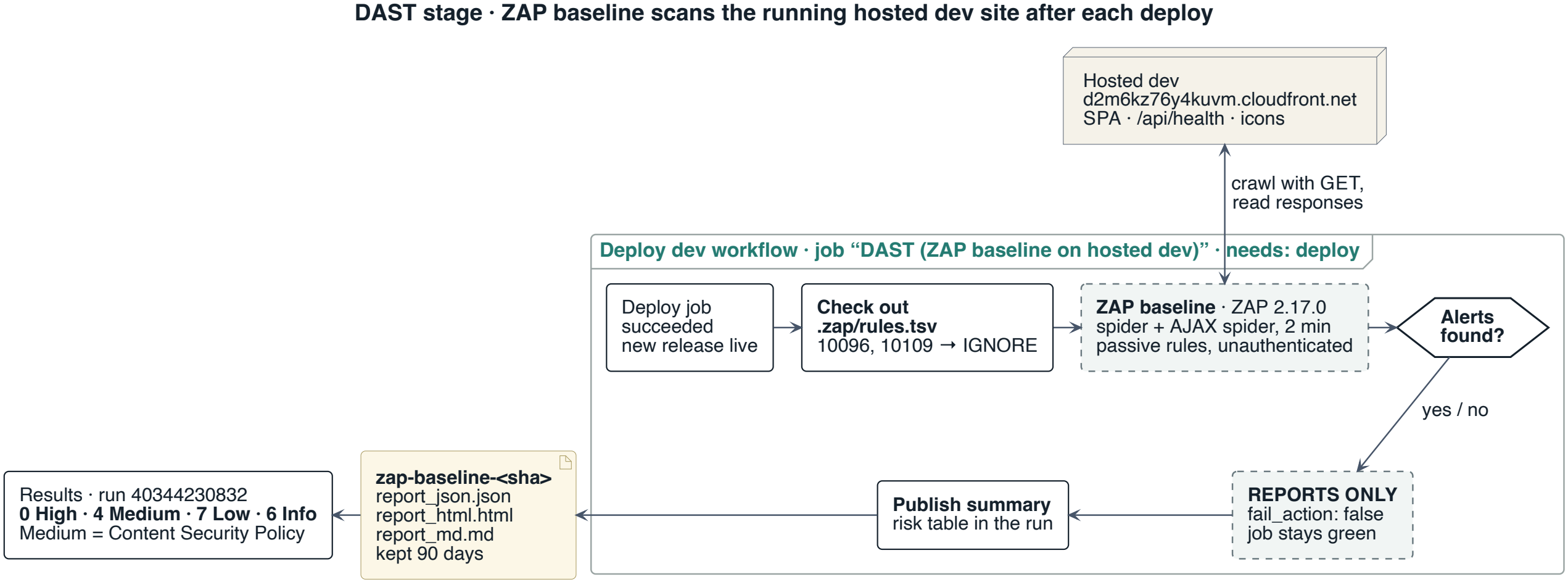
Deploy stage 1/2 · deploy-dev.yml builds, scans and signs the exact bundle before upload



Deploy stage 2/2 · keyless AWS access, upload, health-gated activation



ZAP scans the running hosted site after every deploy

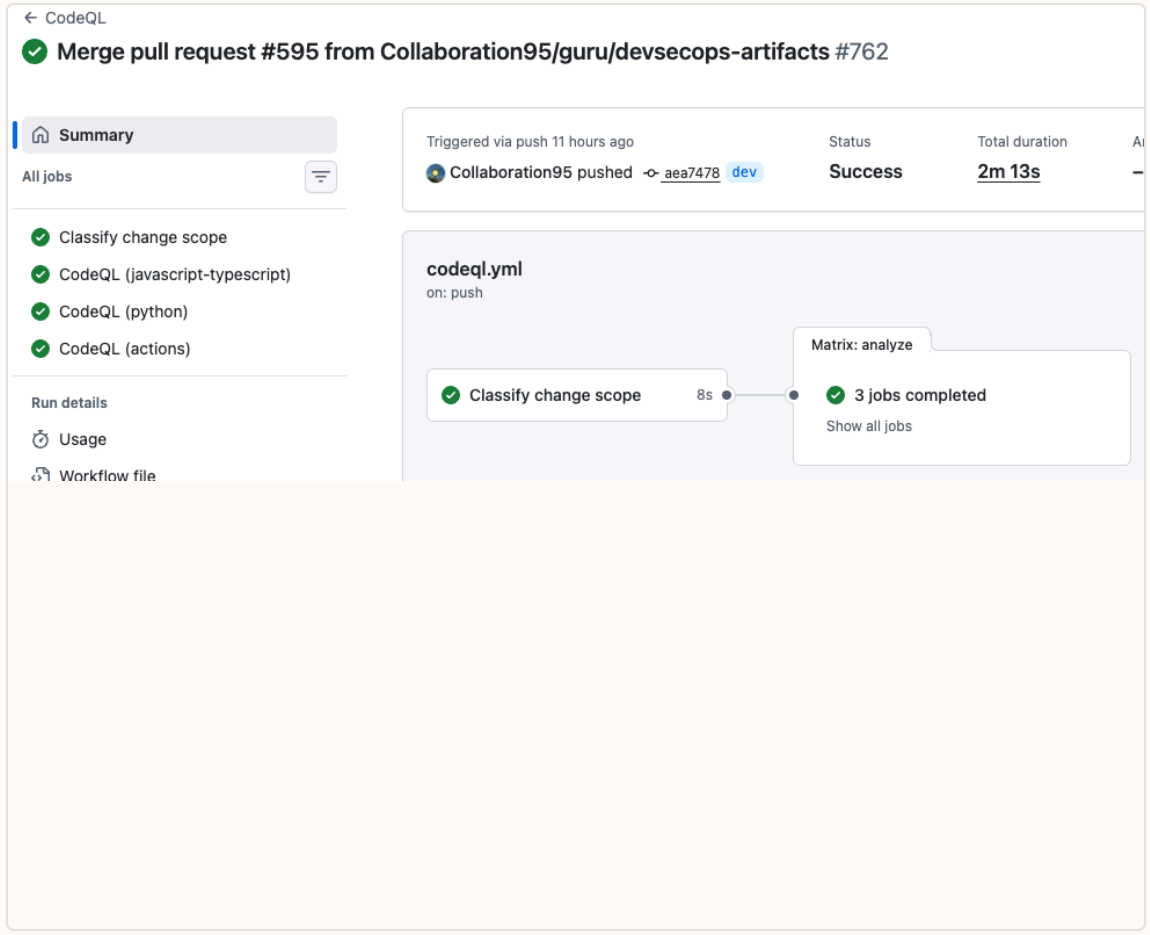


Nine kinds of check, each with a recorded result and a link

CHECK	TOOL	RUNS ON	FAILURE	RESULT · AEA7478	OPEN
SAST	CodeQL · JS/TS, Python, Actions	PR · push · weekly	REPORTS	0 open · alerts 54–56 triaged	run ↗
SCA	npm audit HIGH+ · Dependabot	PR · push	BLOCKS MERGE	zod GHSA blocked PRs → fixed	red run ↗
Secrets	Gitleaks · GitGuardian · push protection	push · PR	BLOCKS PUSH REPORTS	0 findings, full history	run ↗
Containers	Trivy · exact bundled images	Deploy dev	BLOCKS DEPLOY	0 High / 0 Critical	job ↗
IaC	Trivy config + exact exceptions	PR · push	REPORTS	8 High accepted · 7 Low	job ↗
SBOM	CycloneDX 1.6 per image	Deploy dev	IN MANIFEST	187 + 72 components	artifact ↗
Provenance	attest-build-provenance · Sigstore	Deploy dev	BLOCKS DEPLOY	gh attestation verify ✓	attestation ↗
DAST	OWASP ZAP baseline · hosted dev	after deploy	REPORTS	0 H · 4 M · 7 L · 6 Info	job ↗
Tests	node:test · Jest · PostgreSQL 17	PR · push	BLOCKS MERGE	2,782 passed · 89.6% / 85.5%	run ↗

SAST: CodeQL findings are triaged with a written reason

CODEQL RUN 40344231062 · THREE LANGUAGE ANALYSES



Tool CodeQL · `security-extended` queries · JavaScript/TypeScript, Python, GitHub Actions

Runs on every PR, push to dev / main, Mondays 03:23 UTC

Failure REPORTS alerts go to Security › Code scanning; 0 open

Example PR #592 load-test script: alerts 54–56 (file ↔ network data), dismissed “used in tests”: operator-run harness, never shipped in the app image

```
{
  "number": 56,
  "state": "dismissed",
  "rule": { "id": "js/http-to-file-access",
            "security_severity_level": "medium" },
  "location": { "path": "scripts/load/hosted.mjs",
                "start_line": 417 },
  "dismissed_reason": "used in tests"
}
```

Alert 56 ↗ Alert 54 ↗ Alert 55 ↗ CodeQL run ↗

SCA: a new zod advisory blocked merges until we fixed it

JOB LOG · PRODUCTION DEPENDENCY AUDIT · RUN 40140117765 · 24 OCT

```
$ npm audit --omit=dev --audit-level=high
zod  <4.6.6
Severity: high
Zod can exhaust memory while validating oversized constrained
collections - https://github.com/advisories/GHSA-mrhx-c7xc-
m3w5
node_modules/expo/node_modules/zod
3 high severity vulnerabilities
```

AFTER PR #591 · NPM-AUDIT.JSON · QUALITY 40344231052

```
"metadata": { "vulnerabilities": { "high": 0, "critical": 0,
  "total": 0 }, "dependencies": { "prod": 674, "total": 1119 }
}
```

Tool `npm audit --omit=dev --audit-level=high` in Quality · Dependabot alerts and security updates

Runs on every PR and push · inside the required check

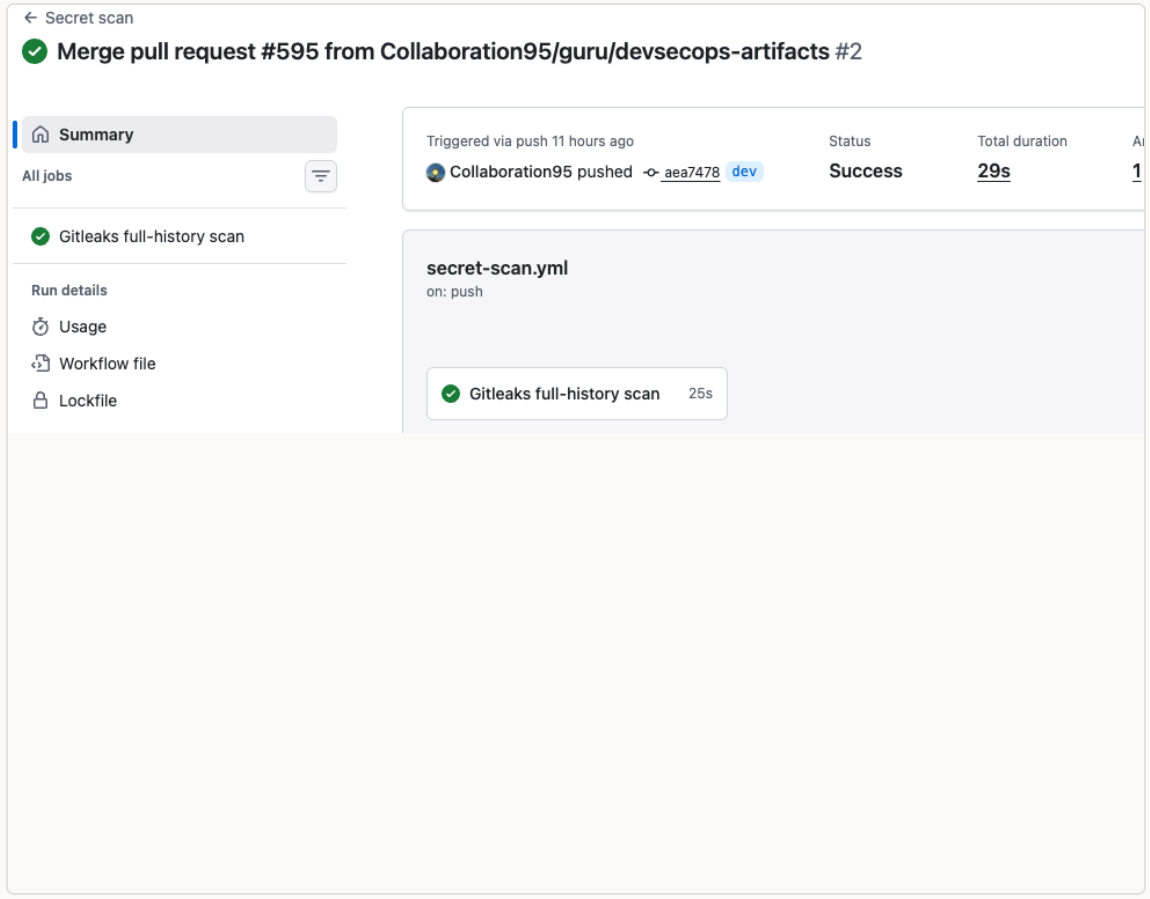
Failure BLOCKS MERGE and, via same-commit Quality, BLOCKS DEPLOY

Fix PR #591: scoped override `@expo/cli → zod 4.6.6`; no forced Expo major upgrade; audit back to 0

GHSA-mrhx-c7xc-m3w5 ↗ Failed audit ↗ PR #591 ↗ npm-audit.json ↗

Secrets are checked at push, on the PR and across history

SECRET SCAN 40344231125 · GITLEAKS FULL-HISTORY JOB + SARIF ARTIFACT



Push BLOCKS PUSH GitHub secret scanning + push protection, enabled · 0 alerts

PR REPORTS GitGuardian app check · “4 commits scanned”

History REPORTS Gitleaks v8.30.1 over full history · redacted SARIF · **0 findings**

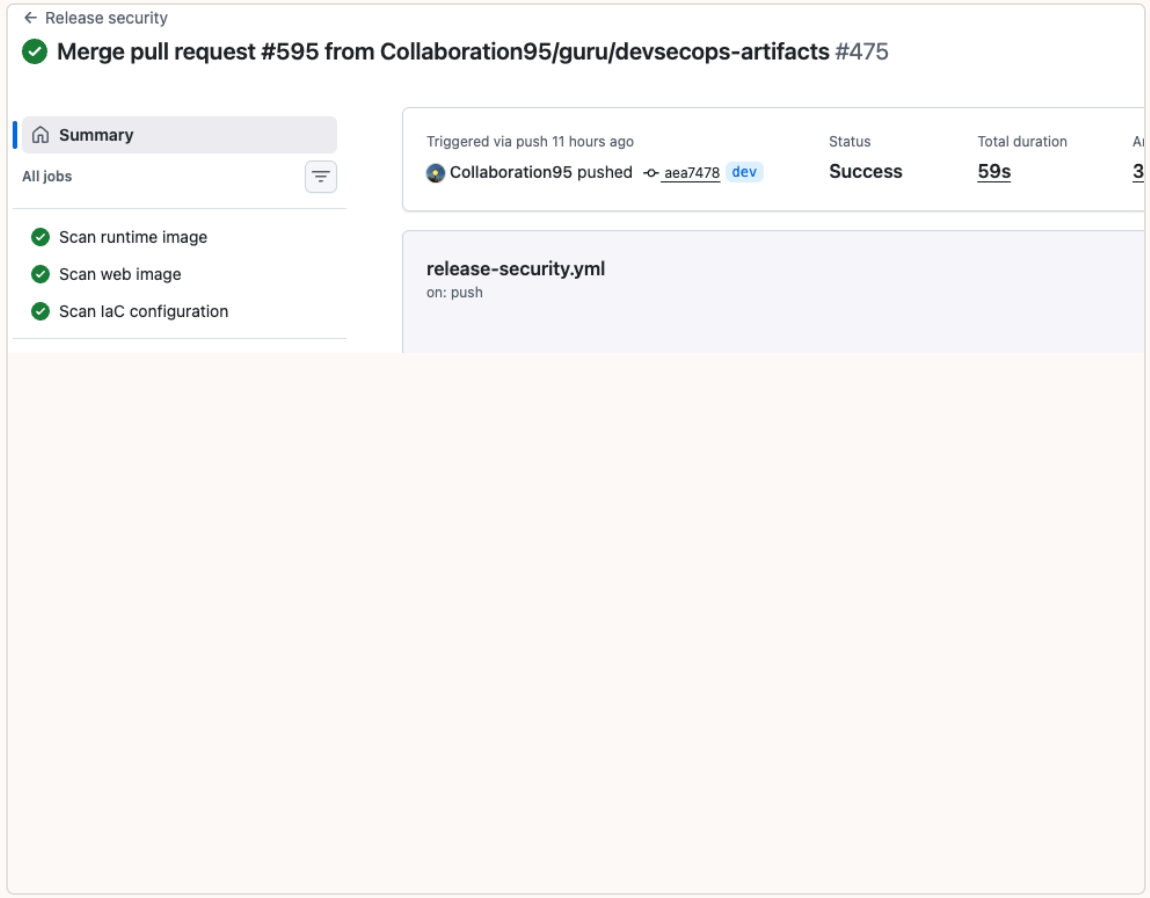
```
[extend]
useDefault = true

[[allowlists]]
condition = "AND"   # path AND value
targetRules = ["generic-api-key"]
paths = ['''^server/src/(schema|db)\.ts$''']
regexes = ['''^(contribution-deletion-v1|contribution-
ledger-v1|contribution-quota-v1)$''']
```

Secret scan run ↗ PR #595 checks ↗

Trivy blocks risky images; IaC risks need dated exceptions

RELEASE SECURITY 40344231046 · IMAGE + IAC SCANS, THREE ARTIFACTS



Images — Trivy v0.70.0 on runtime + web images · PR, push, tags · deploy repeats it on the **exact bundle**

BLOCKS DEPLOY

Bundle result — runtime 0 High / 0 Critical · 1 Medium (zlib CVE-2026-85091, fix 1.3.2-r1) · 2 Unknown (musl) · web 0

IaC — `trivy config .` on Terraform + Dockerfiles → 15 findings: 8 High, each matched to one exception · 7 Low

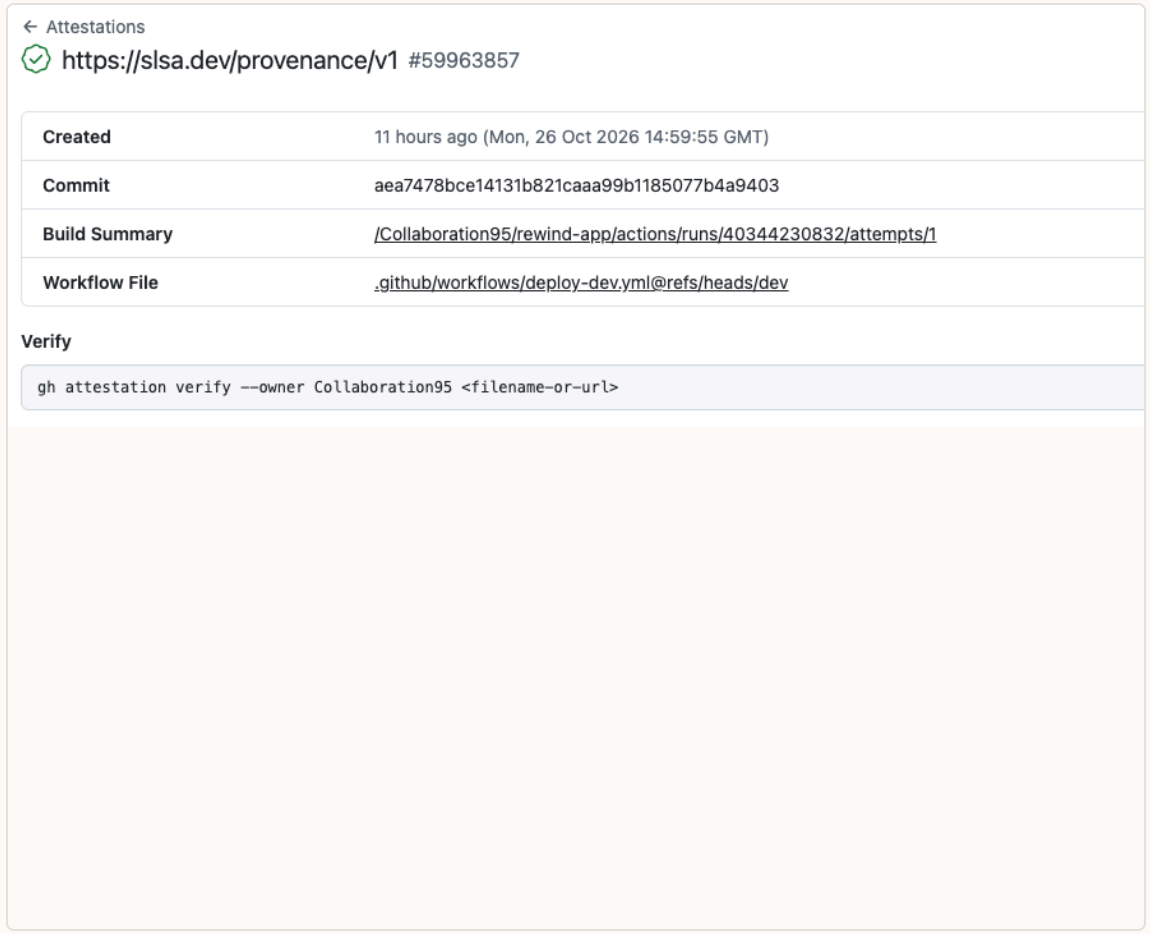
Rule — unmatched High or an expired exception fails the job · all 8 expire 31 Oct 2026

```
{ "id": "AWS-0011",
  "target": "infra/terraform/release/main.tf",
  "resource": "aws_cloudfront_distribution.release",
  "owner": "Guruprasath",
  "expires": "2026-10-31",
  "reason": "Accepted risk: ... without AWS WAF; a web
ACL
             adds monthly cost outside this academic
deployment." }
```

IaC job ↗ iac-full.json ↗ Bundle scan job ↗

SBOM and provenance bind shipped bytes to scans and workflow

ATTESTATION 59963857 · BUILD PROVENANCE FOR AEA7478



SBOM Trivy CycloneDX 1.6 per bundled image · runtime 187 · web 72 components

Manifest commit, run, Quality run, image IDs, digests, severity counts, SHA-256 of tar + SBOMs + reports

Provenance `actions/attest-build-provenance` · SLSA v1 · Sigstore, signed with the job's OIDC identity

```
// sbom-runtime.cdx.json · CycloneDX 1.6
{ "name": "ffmpeg", "version": "8.1.3-r0",
  "purl": "pkg:apk/alpine/ffmpeg@8.1.3-r0" }
// release-manifest.json
"security_gate": "pass",
"rewind-release.tar": "fef3c22a19a2…6e01"
```

```
$ gh attestation verify release-manifest.json \
    --repo Collaboration95/rewind-app
✓ Verification succeeded!   (exit 0)
```

Attestation ↗ SBOMs + manifest ↗ Bundle + Sigstore ↗

DAST: 0 High, 4 Medium, all from one Content Security Policy gap

ZAP REPORT · RUN 40344230832 · SUMMARY OF ALERTS

Generated on Mon, 26 Oct 2026 15:04:29

ZAP Version: 2.17.0

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	7
Informational	6
False Positives:	0

MEDIUM · CSP: WILDCARD DIRECTIVE · REQUEST AND EVIDENCE

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certai are used for everything from data theft to site defacement or distribution of malware. CSP provides should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts
URL	https://d2m6kz76y4kuvm.cloudfront.net
Node Name	https://d2m6kz76y4kuvm.cloudfront.net
Method	GET
Parameter	Content-Security-Policy
Attack	
Evidence	frame-ancestors 'none'
Other Info	The following directives either allow wildcard sources (or ancestors), are not defined, or are overly script-src, style-src, img-src, connect-src, frame-src, font-src, media-src, object-src, manifest-src,

Medium	CSP: Failure to Define Directive with No Fallback · Wildcard Directive · script-src unsafe-inline · style-src unsafe-inline
Low	COEP · COOP · CORP header missing · Permissions-Policy not set · Server version (nginx/1.31.6) · Dangerous JS functions (eval in bundle) · Timestamp disclosure
Info	CSP Report-Only header found · Suspicious comments (sw.js) · Modern web app · Non-storable · Cache-control · Storable content

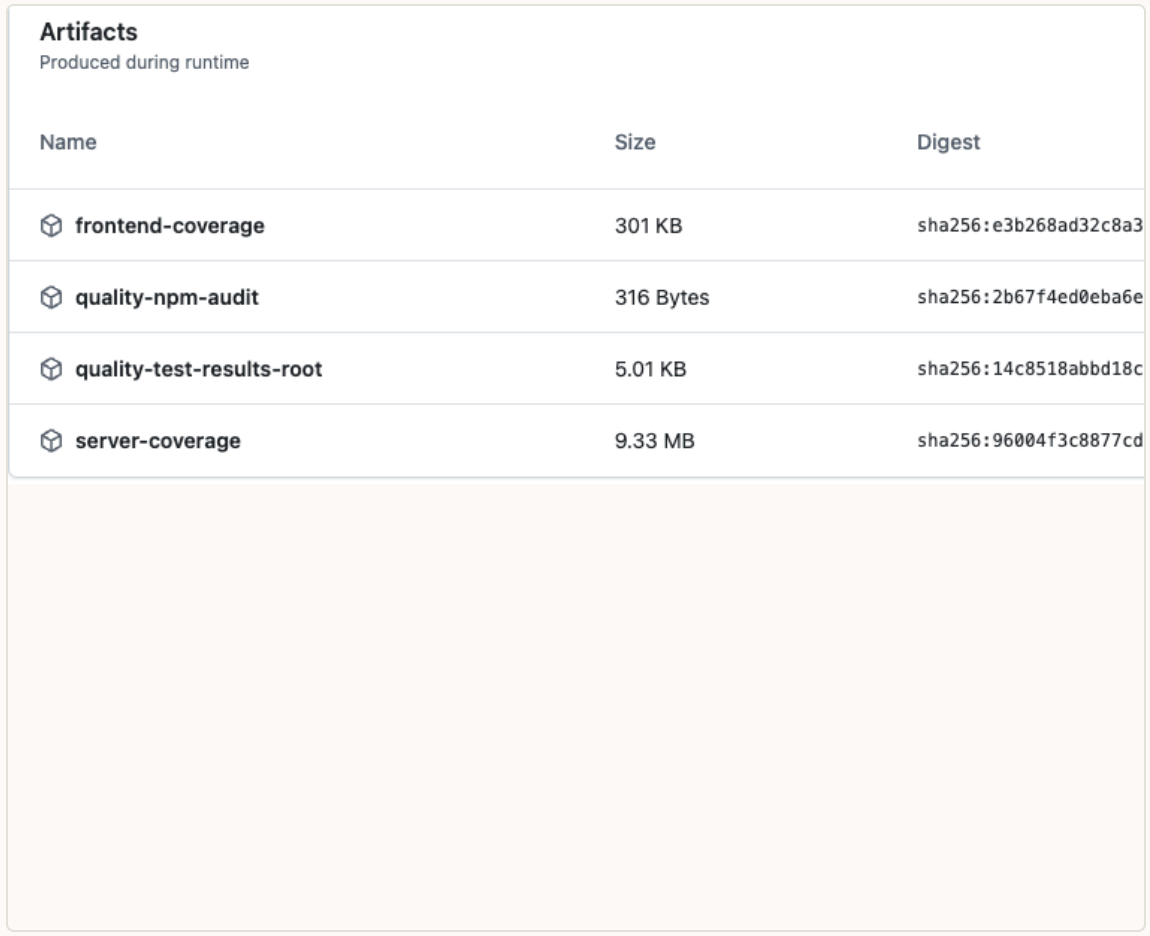
```
Alert    CSP: Failure to Define Directive with No Fallback
Risk     Medium (High confidence) · plugin 10055 · CWE-693
URL      GET https://d2m6kz76y4kuvm.cloudfront.net  (+
/robots.txt, /sitemap.xml)
Param    Content-Security-Policy
Evidence  frame-ancestors 'none'
Other    form-action is among the directives that do not
fall back to default-src
```

Why: the enforced header sets only `frame-ancestors`; the full policy ships as Report-Only. **Next:** enforce it.

ZAP HTML · 10055 ↗ Report-Only ↗ DAST job ↗ zap-baseline ↗

Tests and coverage gate the merge and are kept as artifacts

QUALITY RUN 40344231052 · RETAINED ARTIFACTS



LANE	RESULT · PR RUN 40343459119	KEPT
Root and IaC	123 passed · 1 skipped	JUnit XML
Server · SQLite	985 passed · 21 skipped	85.5% lines
Server · PostgreSQL 17	same suite, hosted engine	pass
Frontend · Jest	1,674 passed	89.64% statements · gate 70%
Static ×4 · fixtures	format, lint, architecture, typecheck · deploy fixtures	pass

Failure **BLOCKS MERGE** any red lane fails the required check

PR Quality run ↗ dev Quality run ↗

The pipeline caught problems that source-level tests could not

FINDING	IMPACT	FIX	EVIDENCE
A new advisory hit a locked dependency (zod, GHSA-mrhx-c7xc-m3w5)	Audit red; PRs #589, #590 blocked	Scoped override to zod 4.6.6 (#591)	run ↗
Alpine dropped the pinned `ffmpeg=8.1.2-r0`	Runtime image failed to build	Re-pin to 8.1.3-r0 (#591)	run ↗
Scanned image ≠ deployed image: deploy rebuilt it	Scan result did not describe shipped bytes	Scan the exact bundle; manifest + attestation (#595)	PR ↗
Gitleaks default rules: 27 false positives in history	Secret job would be red from day one	Allowlist exact path AND exact value	run ↗
Schema registry moved; packaging read the old path	Bundle verify failed before the host	Read declared version from schema.ts (#583)	run ↗
Cognito runtime dependencies missing from the image	Tests passed; built image could not sign in	Package them in the image (#511)	PR ↗

Verify what ships: the advisory database, the package index and the built image change without a code change.

Demo route: eight clicks from pull request to running site

#	OPEN	POINT AT	FILM
1	PR #595 › Checks ↗	Quality, CodeQL, Secret scan, Release security, GitGuardian	00:20
2	Quality run graph + artifacts ↗	classify → 9 lanes → gate · 4 artifacts	01:44
3	Code scanning alert 56 ↗	rule, line, “used in tests” + reason	04:08
4	Deploy dev run 40344230832 ↗	classify → deploy → DAST · 3 artifacts	05:02
5	Deploy job steps ↗	Quality wait → scan → attest → OIDC → install	05:18
6	Attestation 59963857 ↗	subjects: tar + manifest · workflow identity	07:18
7	ZAP HTML report ↗	summary table → CSP finding evidence	08:40
8	Hosted dev health ↗	HTTP 200 · PostgreSQL · schema ready	10:06

Terminal: `gh attestation verify --repo Collaboration95/rewind-app release-manifest.json` · fallback: recorded film (backup slide), “Film” = timestamp.

SYSTEM DEMONSTRATION

A private-group journey runs from prompt to film

01-02

Create and invite

Prompt · private membership

03-06

Contribute

Photo · video · chat · reminder

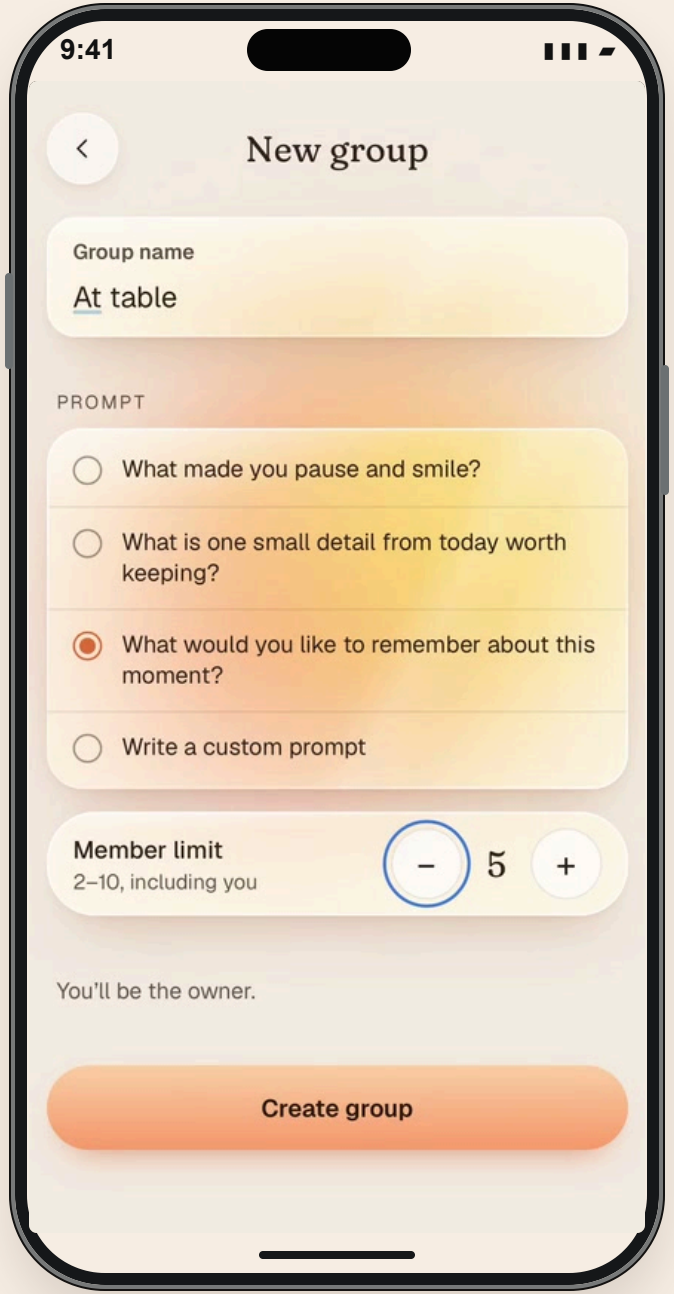
07-10

Reveal and retain

Ready · watch · save · access check

28-day product cycle · private groups · one feature per slide

A shared prompt gives the group a common starting point



01 / 10 · CREATE A GROUP

DO.

Name the group, set the prompt and choose its size.

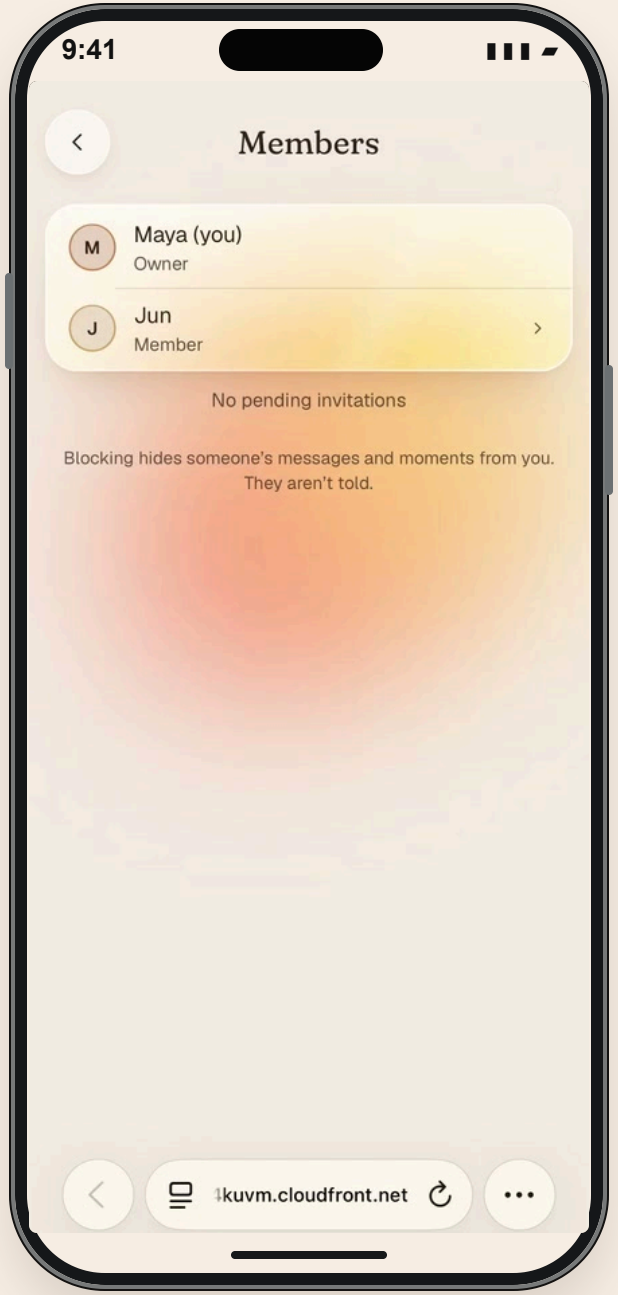
OBSERVE.

Home shows the new group; settings retain prompt and time zone.

RULE.

The owner manages group settings.

One accepted invitation creates one private membership



02 / 10 · INVITE AND JOIN

DO.

Create and share the code; the friend accepts.

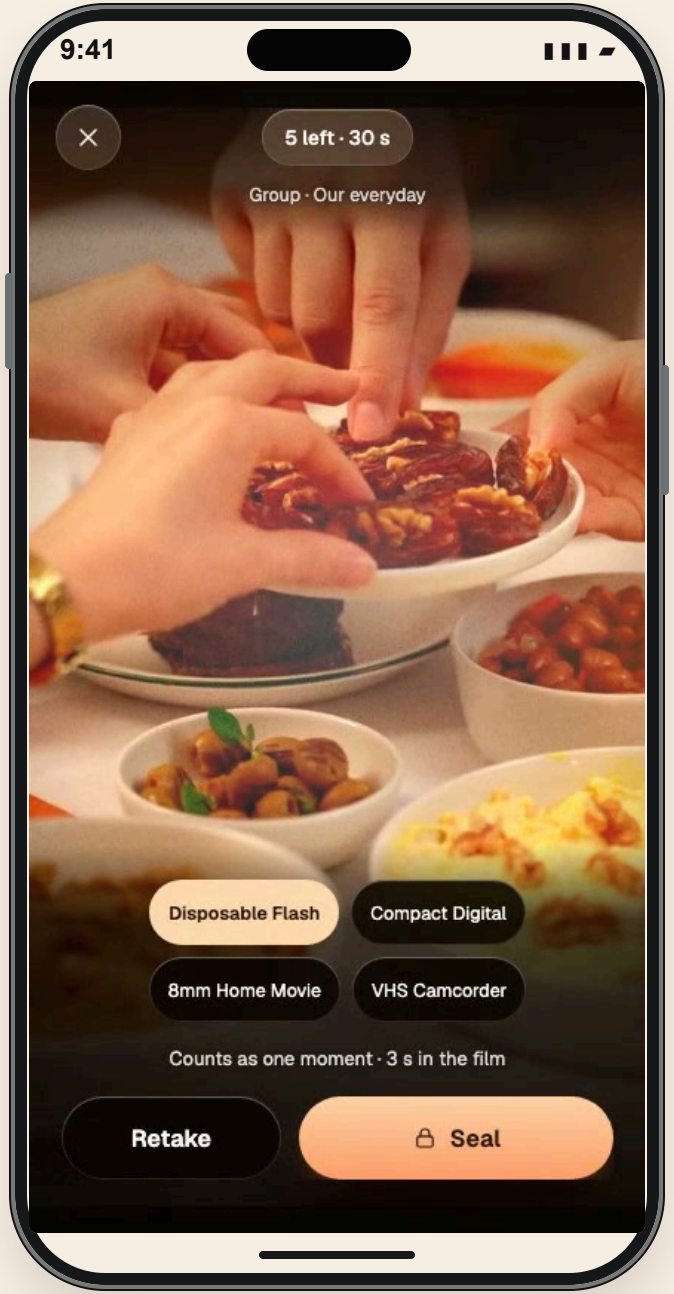
OBSERVE.

Both accounts see the same group and member list.

RULE.

Code works once and expires in 24 hours.

A submitted photo becomes a sealed moment



03 / 10 · SEAL A PHOTO

DO.

Take a photo, choose a look, review and submit.

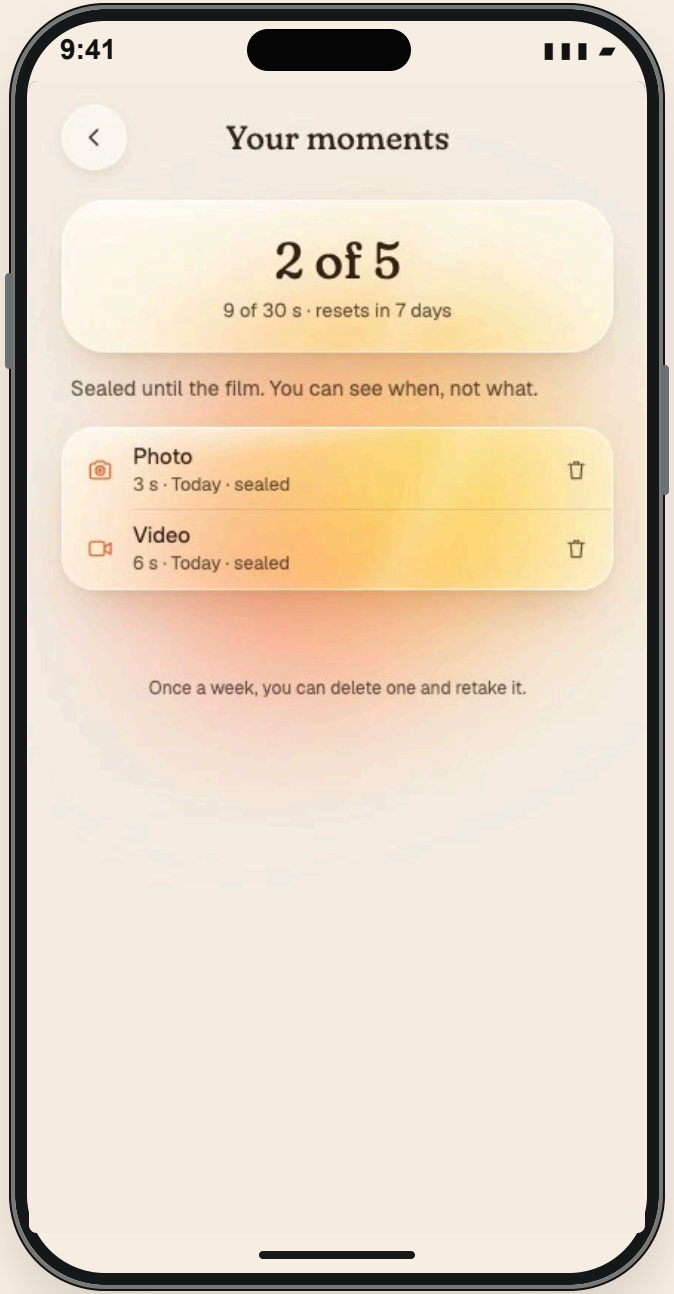
OBSERVE.

Your moments records a sealed entry.

RULE.

One photo uses one moment and three film seconds.

Video and photos share one enforced weekly allowance



04 / 10 · VIDEO AND ALLOWANCE

DO.

Record a video, review and submit.

OBSERVE.

The ledger updates moments and total seconds.

RULE.

5 moments / 30 seconds weekly; each video ≤15 seconds.

Stored messages and live updates keep the group connected

05 / 10 · GROUP CHAT

DO.

Send a message, reply and react from the other account.

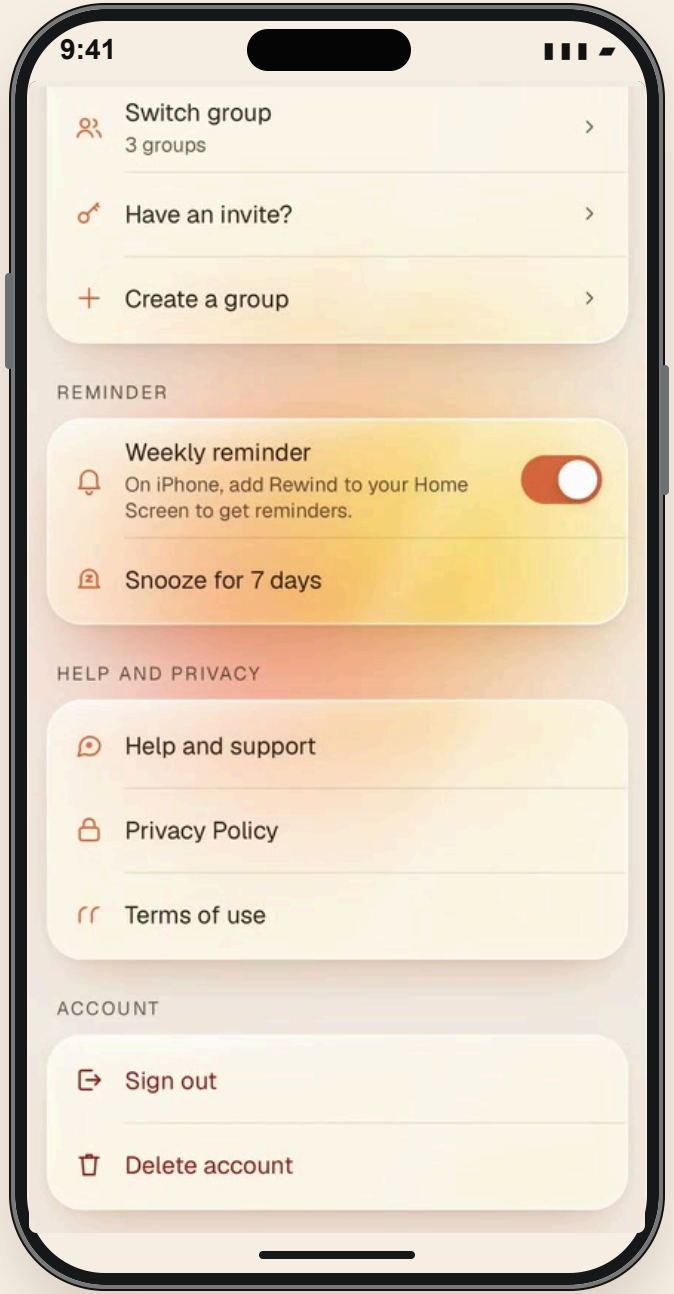
OBSERVE.

The second view updates without a refresh.

DESIGN.

Stored messages plus SSE delivery and reconnect.

Reminder permission leads to an explicit weekly choice



06 / 10 · WEEKLY REMINDER

DO.

Open settings and choose the weekly reminder.

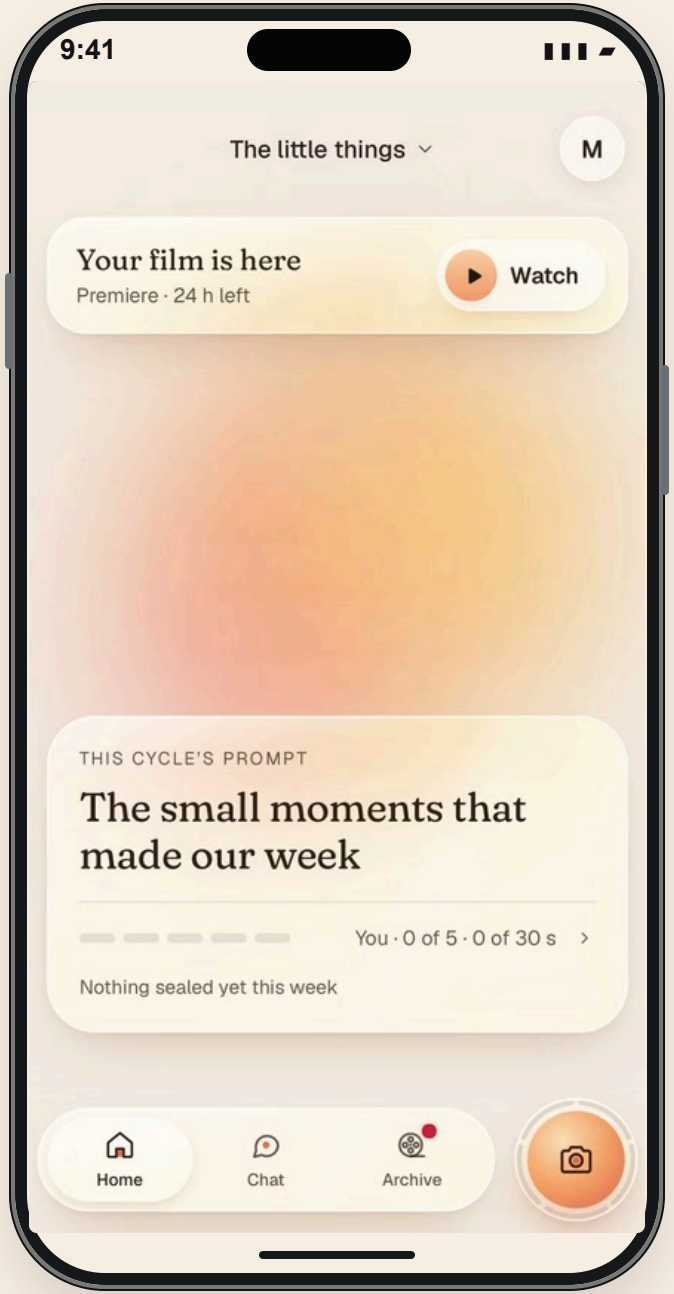
OBSERVE.

The switch and seven-day snooze keep the choice explicit.

RULE.

Sunday 19:00 in the group time zone; iPhone web push uses the Home Screen app.

The completed capsule is ready for its shared premiere



07 / 10 · FILM READY

OBSERVE.

A completed capsule exposes its premiere card.

DESIGN.

The scheduler closes the cycle, queues work and opens its successor.

RULE.

The product cycle is 28 days.

The reveal turns sealed contributions into one shared film

08 / 10 · WATCH THE FILM

DO.

Open the premiere and watch; skip between moments.

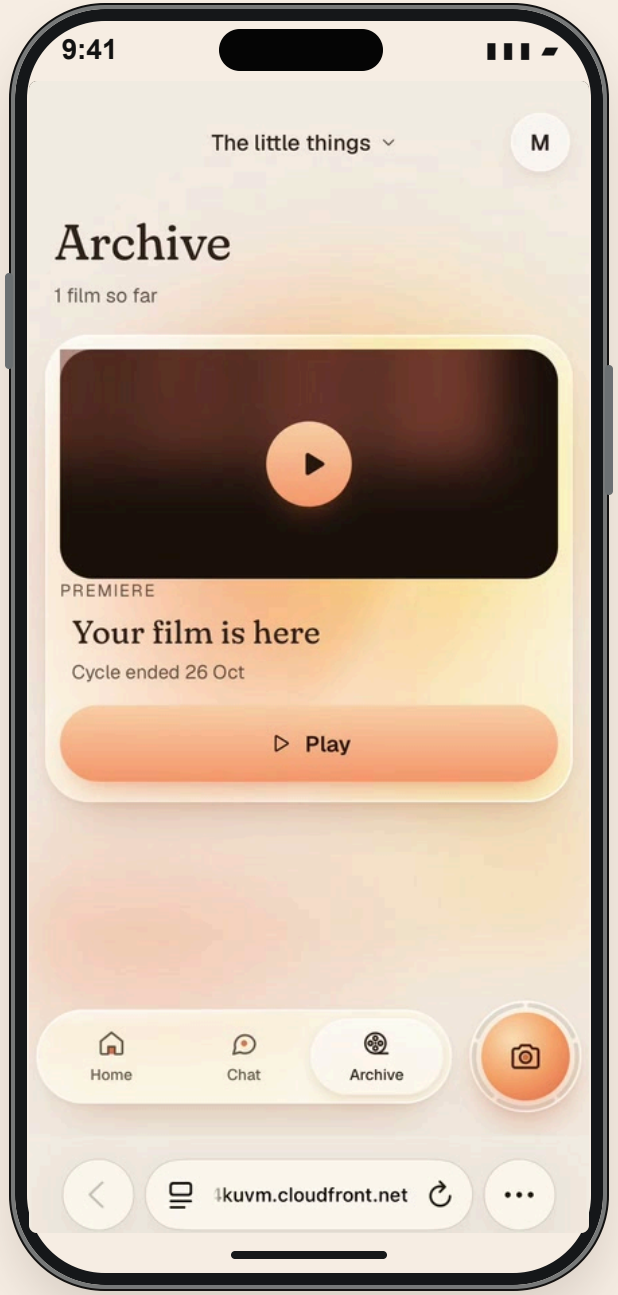
OBSERVE.

One film combines the group’s accepted inputs.

OUTPUT.

720 × 1280 · 30 fps · normalised audio.

Archive keeps the film available after its premiere



09 / 10 · ARCHIVE AND SAVE

DO.

Open Archive, select the film and save it.

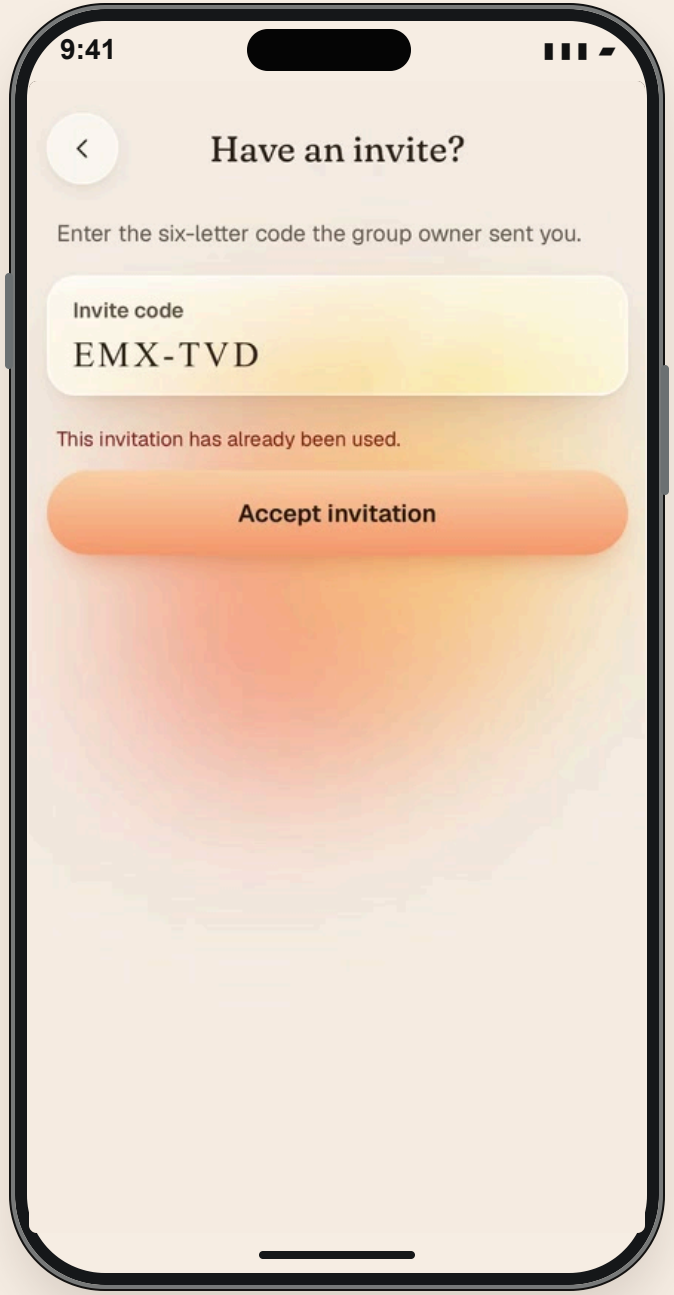
OBSERVE.

The MP4 download opens as a playable file.

CONTROL.

Members can save the film and their own moments.

A spent invitation gives an outsider no group access



10 / 10 · OUTSIDER DENIED

DO.

Reuse the spent invitation from an outsider account.

OBSERVE.

The invitation is rejected and the private group stays absent.

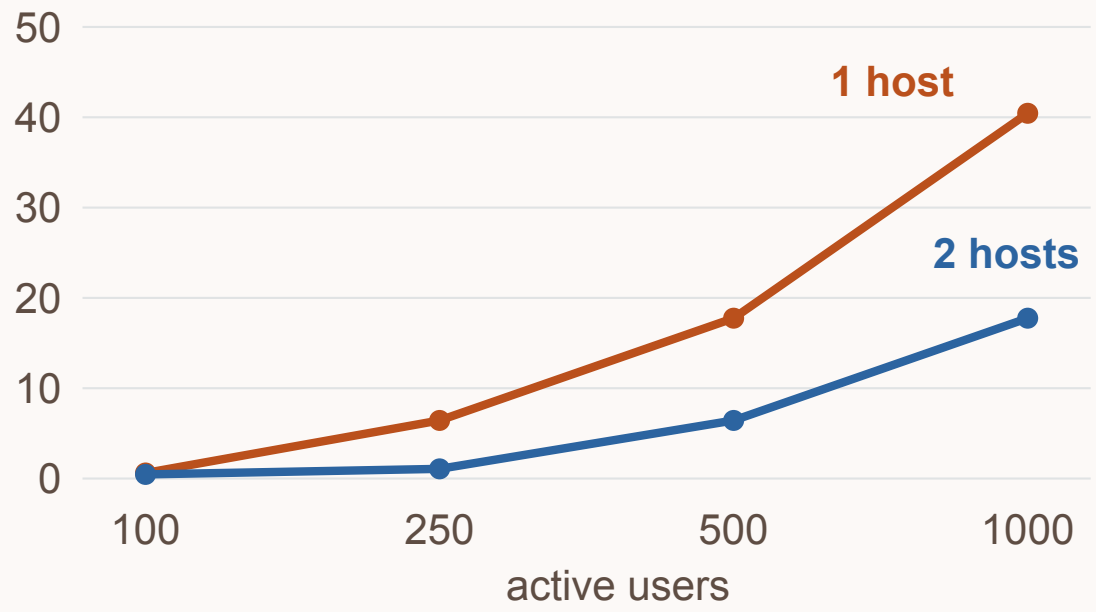
BOUNDARY.

Private group and media reads require their access checks.

SYSTEM DEMONSTRATION

The capacity model shows where to scale next

CAPACITY PROJECTION · MEAN RESPONSE IN SECONDS



Measured. 100 users: p95 1.34 s, 17.84 req/s, 0 errors.

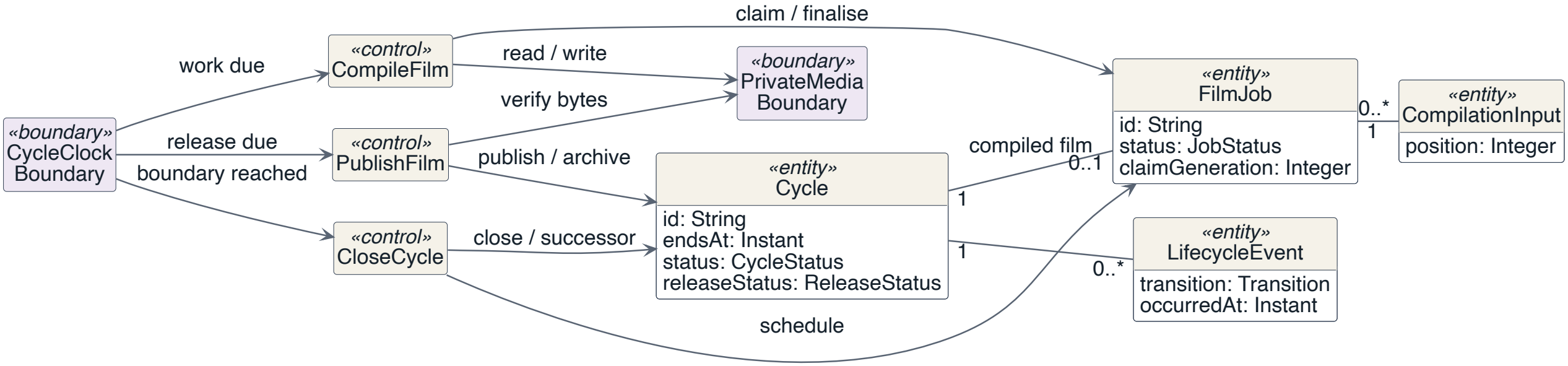
Ceiling. About 22 req/s on one API host; the knee is near 116 users.

Two hosts. At 250 users the mean drops from 6.4 s to 1.1 s.

Scale out. Separate media work, then asynchronous persistence with a connection pool.

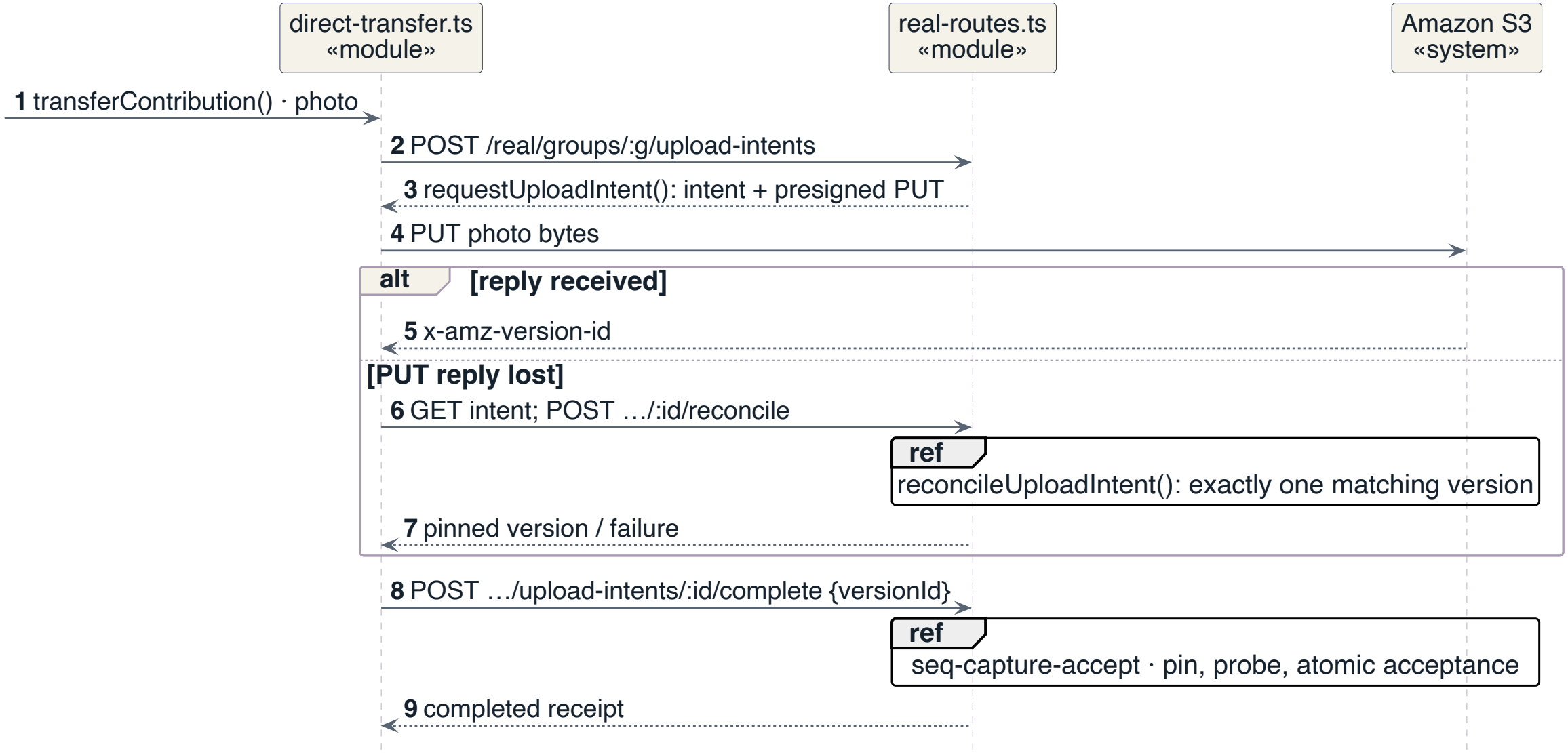
Maintain. The same pipeline checks every change.

Analysis classes · UC07-UC08 Close cycle and release film



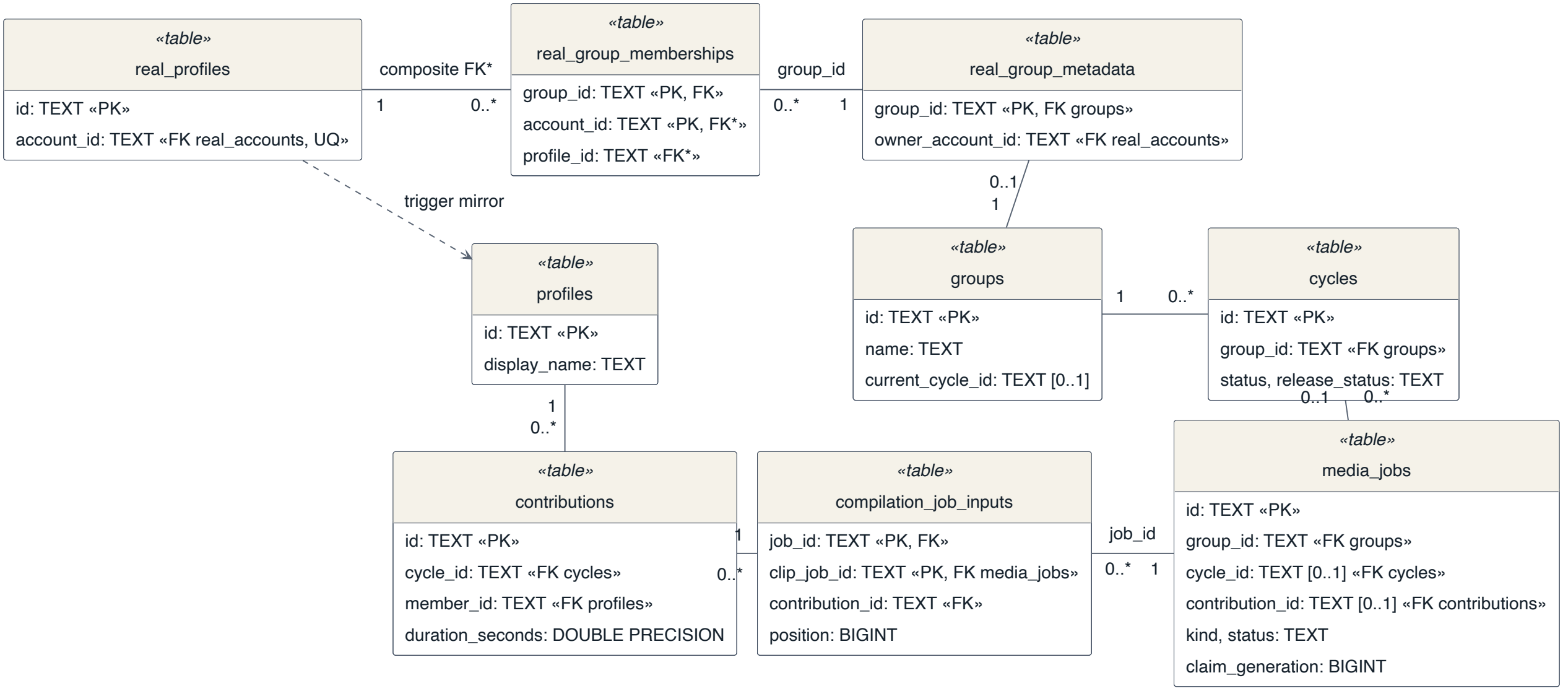
Conceptual BCE responsibilities; mapped to implemented elements in a2d-cycle.

Design sequence · UC05-UC06 Contribute a photo within allowance



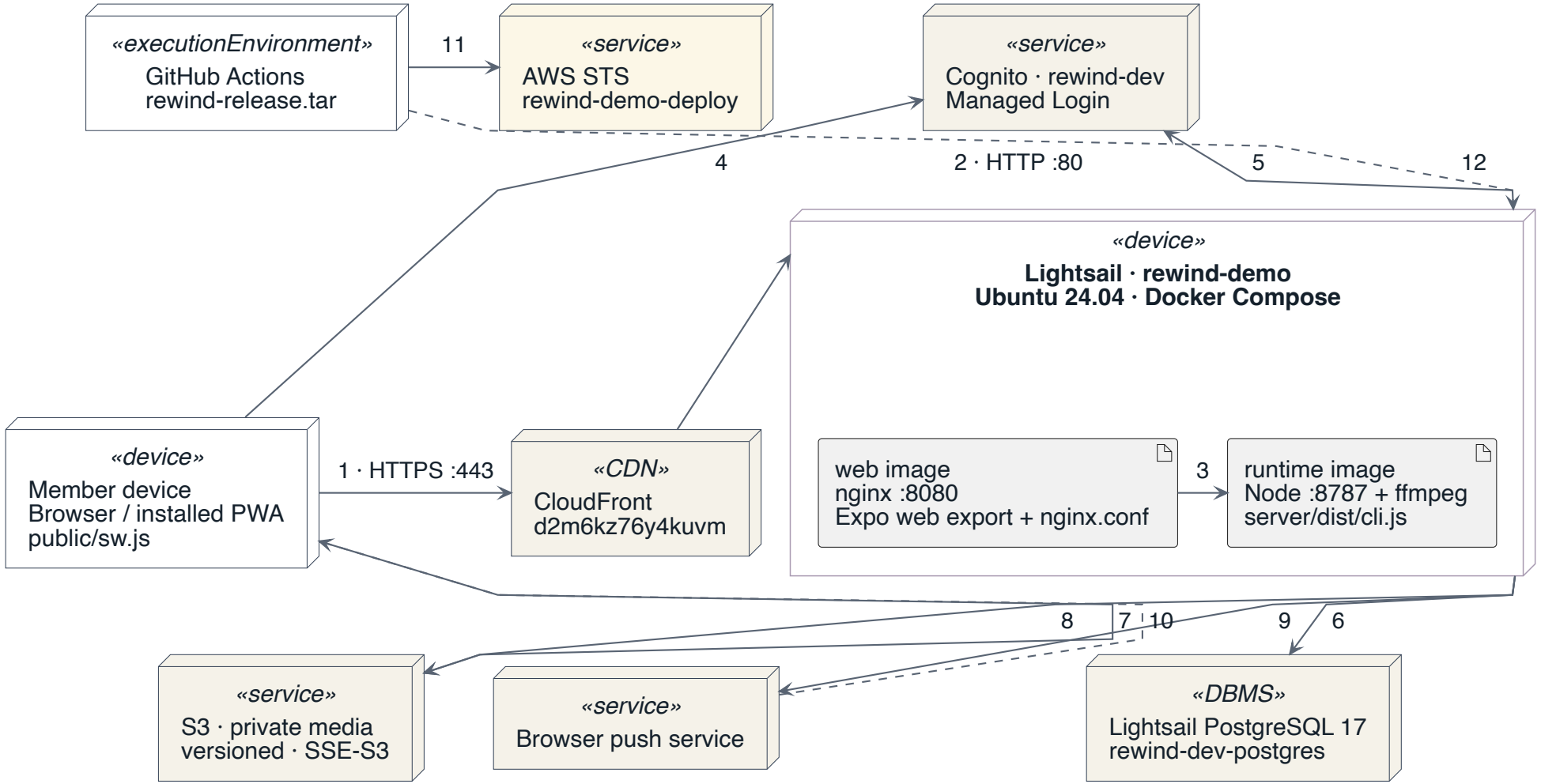
CameraCaptureScreen → GroupCaptureView callback → submitPhotoContribution() → runtime uploadClip() → transferContribution(). Processing: seq-capture-process.

Data class view · Real membership, capture and compilation



Selected columns. PK = primary key; FK = database foreign key; UQ = unique; [0..1] = nullable.
FK* = (account_id, profile_id) → real_profiles(account_id, id). real_accounts is the account identity table.
current_cycle_id is an application link. UNIQUE(job_id, contribution_id). Archive reads published cycles + film jobs.

Deployment view · Hosted dev



1 Browser → CloudFront: HTTPS :443. 2 CloudFront → nginx: HTTP :80 → :8080 + origin auth header.
3 nginx → Node: HTTP :8787 /api + SSE. 4 Browser → Cognito: HTTPS :443, authorization code + PKCE.
5 Node → Cognito: HTTPS :443 token exchange. 6 Node → PostgreSQL: TLS :5432.
7 Browser → S3: HTTPS :443 presigned PUT. 8 Node → S3: HTTPS :443 with IAM user credentials.
9 Node → push service: HTTPS :443 / VAPID. 10 Push service → PWA: push event.
11 Actions → STS: OIDC / HTTPS :443, 1 h dev role. 12 Actions → host: SCP / SSH :22, runner /32.
AWS ap-southeast-1. OIDC: dev branch + environment. Node owns the cycle, media and reminder loops.

Coverage and enforcement answer different questions

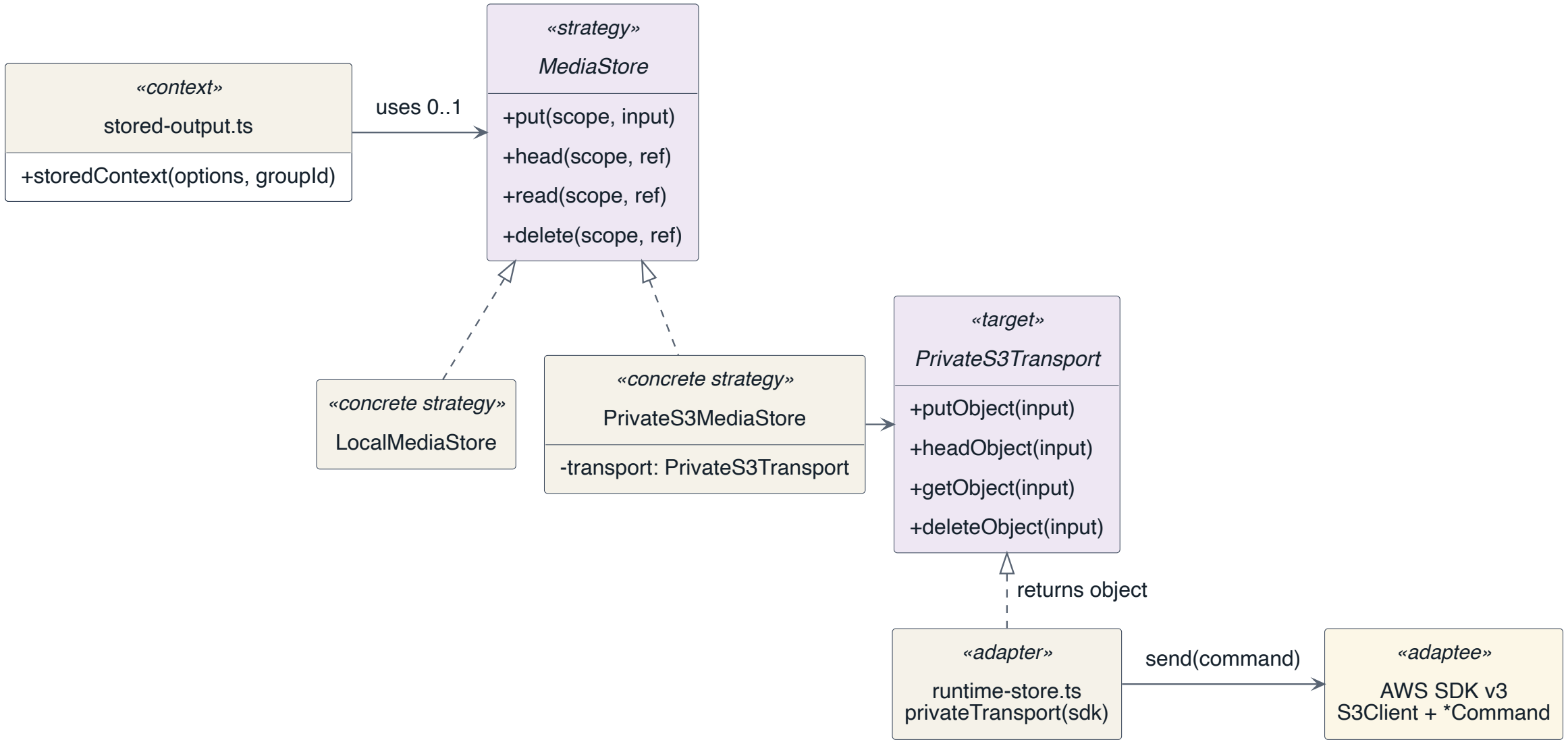
COVERAGE	MEASURED	POLICY
Client statements	89.6%	70% floor · blocks merge
Client branches	85.7%	Reported
Client functions	89.6%	Reported
Client lines	92.3%	Reported
Server lines	85.7%	Reported
Server branches	85.6%	Reported
Server functions	85.1%	Reported

Cases. 1,674 frontend; 1,006 server; 989 on PostgreSQL; 131 root; 41 browser, 6 accessibility.

Privacy. Route contracts and outsider tests exercise group, budget, chat and private media denials.

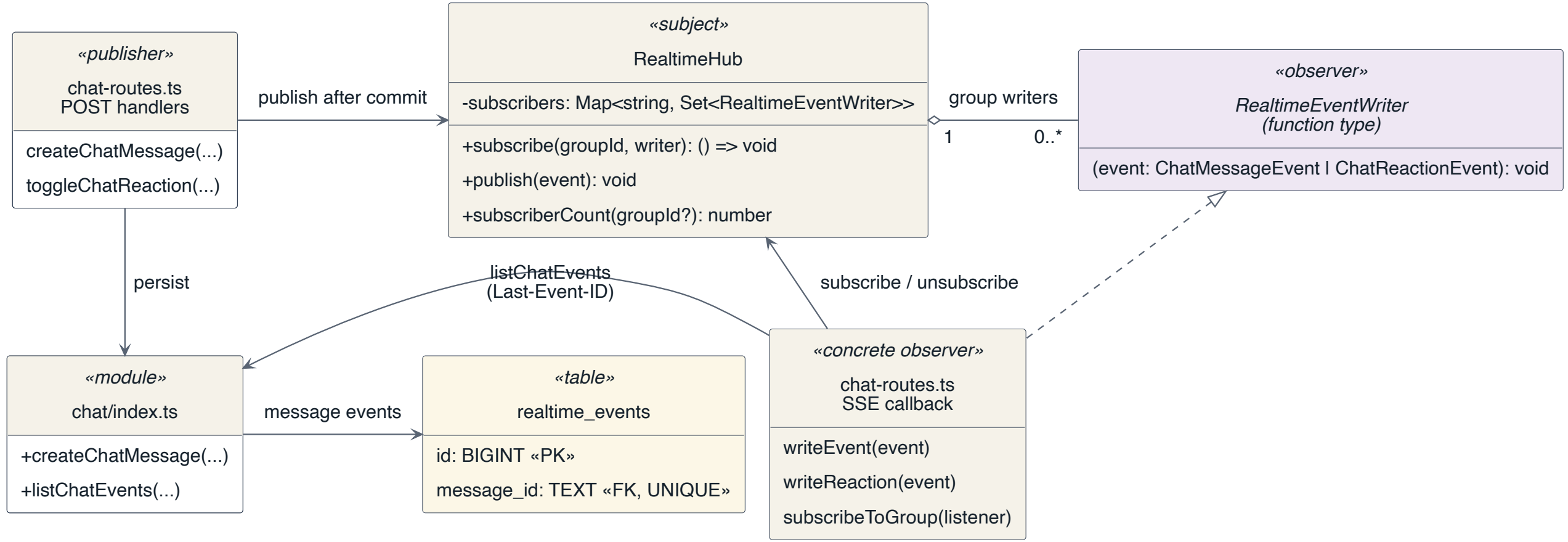
Performance. Local: 1,200 requests; 3 × 25-clip films in 4.9–8.1 seconds.

Design class view · Media storage



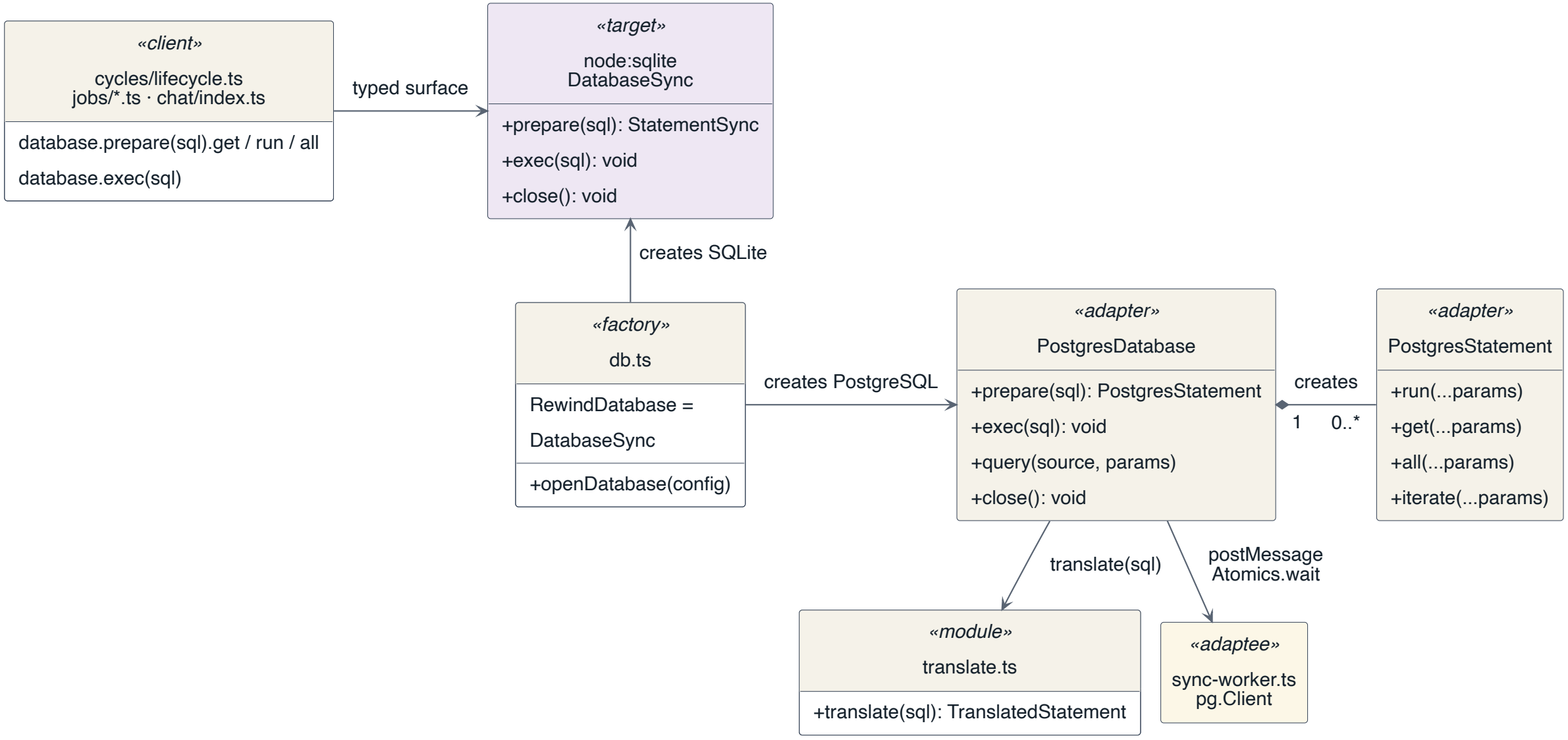
createMediaRuntime(config) selects LocalMediaStore or PrivateS3MediaStore. Hosted dev uses S3. Local disk mode sets config.media = null.

Design class view · Chat event delivery



Each HTTP runtime owns one RealtimeHub; writers are callbacks, not observer classes. Messages replay from realtime_events. Reactions do not move the replay cursor.

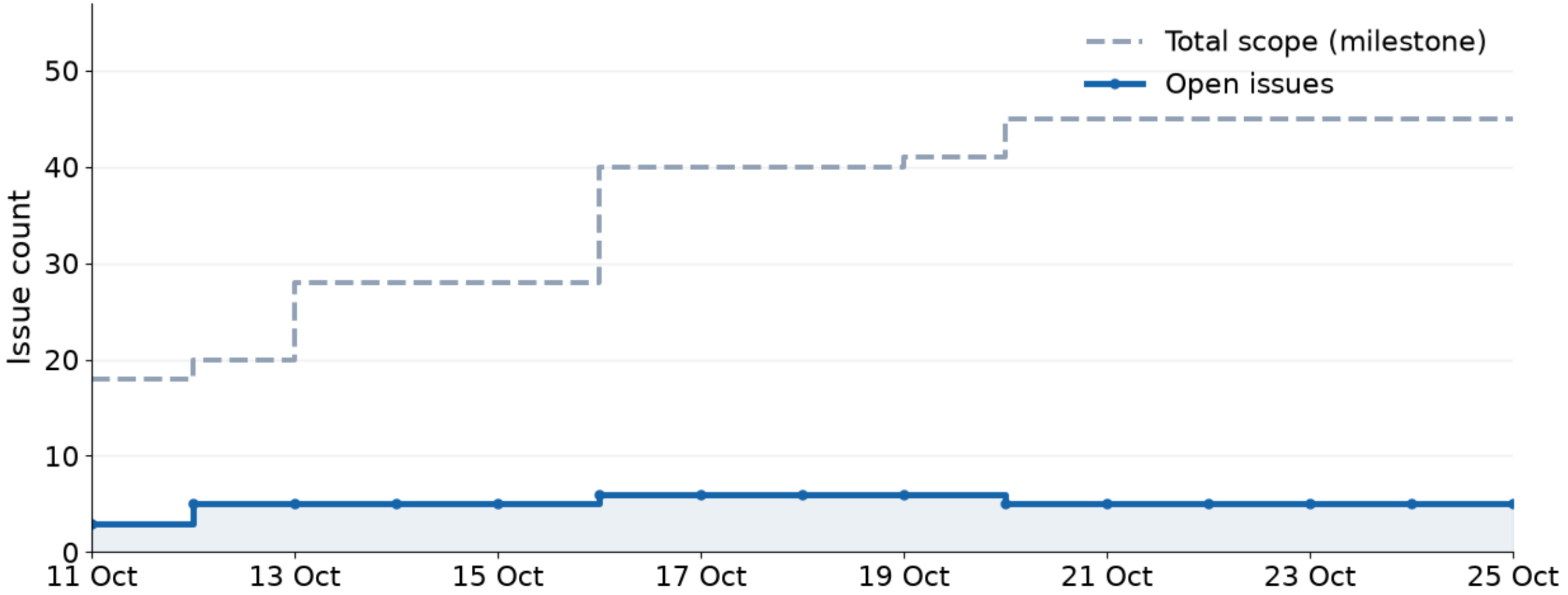
Design class view · PostgreSQL persistence adapter



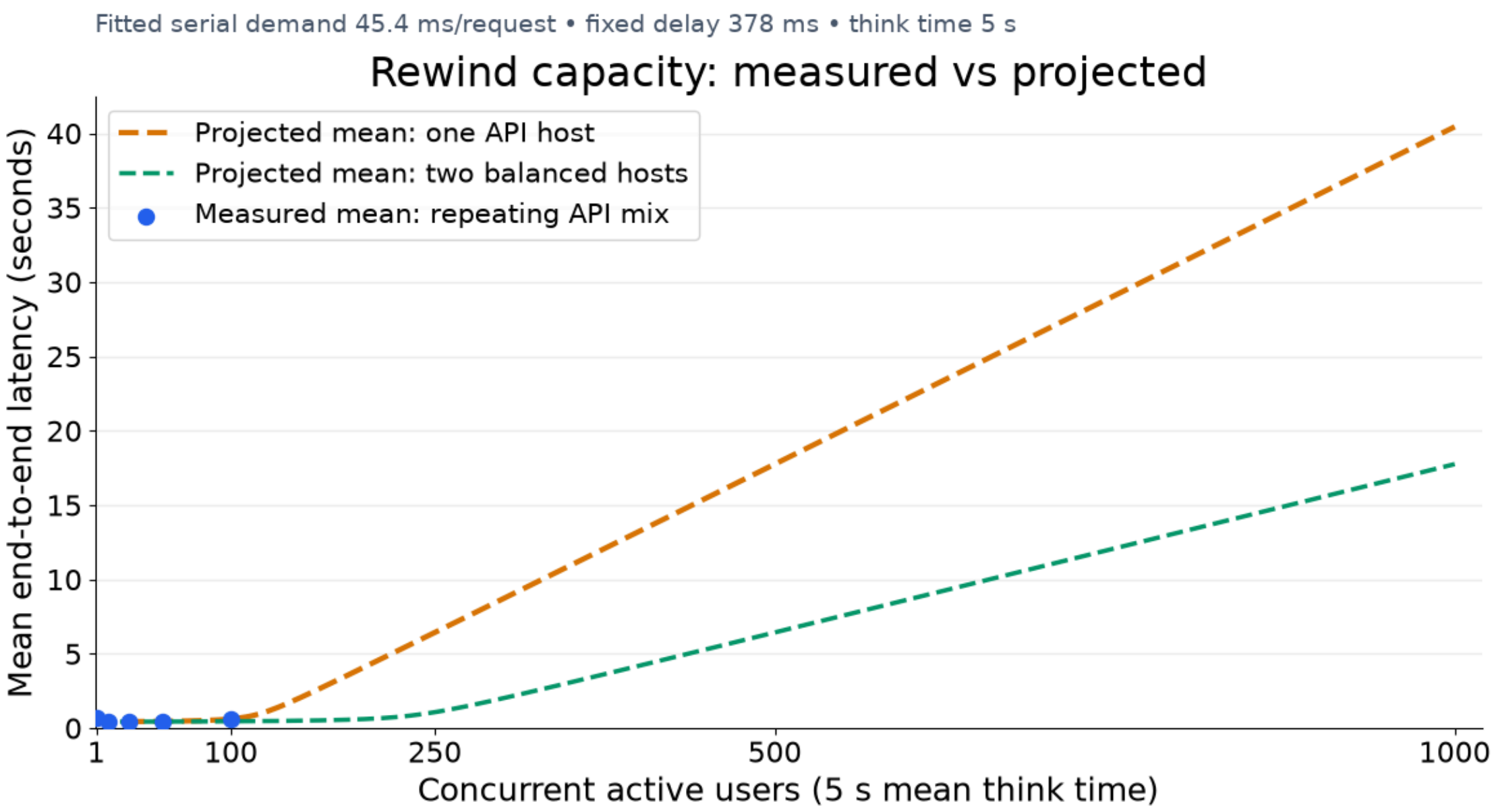
db.ts casts PostgresDatabase to RewindDatabase; the adapter has matching methods. Worker-thread pg.Client performs PostgreSQL I/O; callers keep synchronous operations.

Sprint 3 · issue burndown

11 Oct–24 Oct 2026 · opening 00:00 and daily closes · SGT



Opening scope/open: 18/3 | Closing scope/open: 45/5


Fitted serial demand 45.4 ms/request • fixed delay 378 ms • think time 5 s
Rewind capacity: measured vs projected
Projected mean: one API host
Projected mean: two balanced hosts
Measured mean: repeating API mix
Mean end-to-end latency (seconds)
0
5
10
15
20
25
30
35
40
1
100
250
500
1000
Concurrent active users (5 s mean think time)

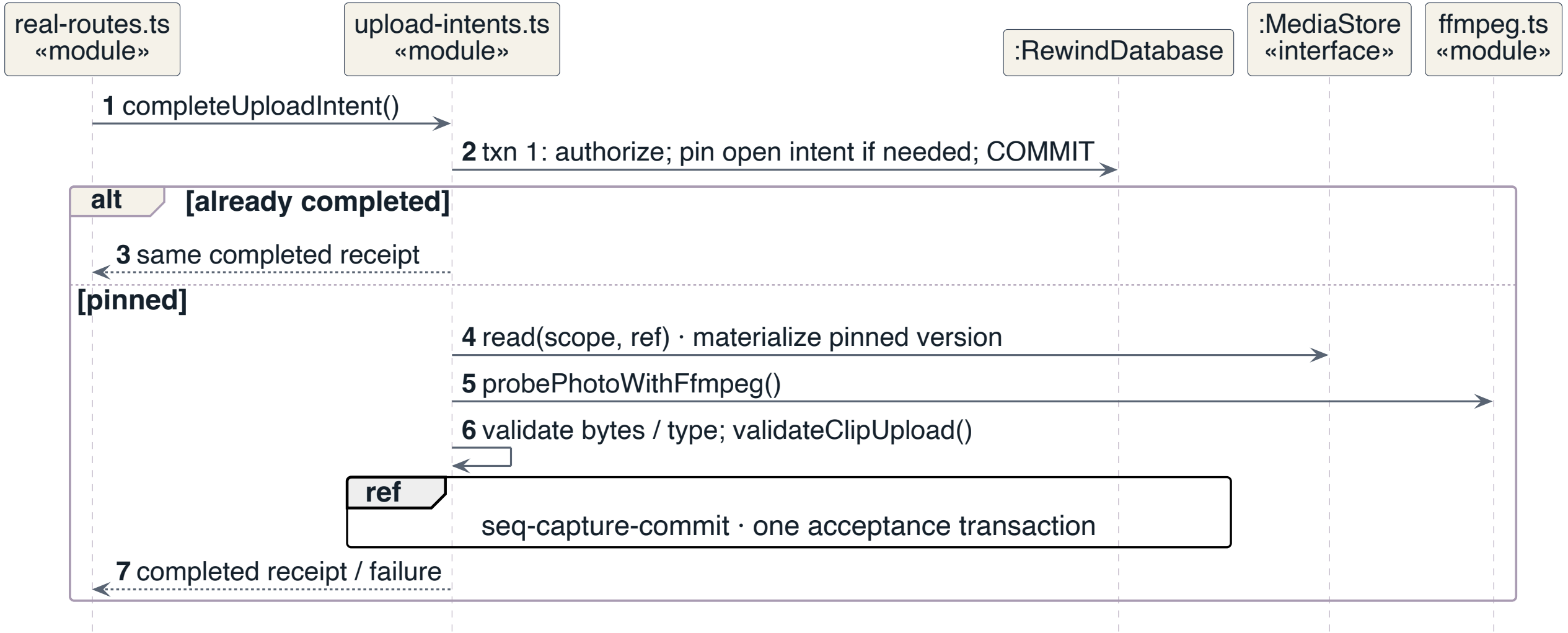
Retained artifacts make the deployment independently inspectable

FILE / OUTPUT	QUESTION IT ANSWERS
quality-test-results-root · server/frontend coverage	Which behaviours and coverage were exercised?
npm-audit.json · gitleaks.sarif · iac-full.json	Which dependency, secret and configuration findings were reported?
sbom-runtime.cdx.json · sbom-web.cdx.json	Which components are inside the image pair?
trivy-runtime.json · trivy-web.json	Which findings belong to those exact images?
release-manifest.json · rewind-release.tar	Which commit, bytes and report hashes travelled together?
Signed provenance · gh attestation verify	Which workflow produced the retained subjects?
ZAP report_html.html · report_json.json	Which running-page findings were observed?

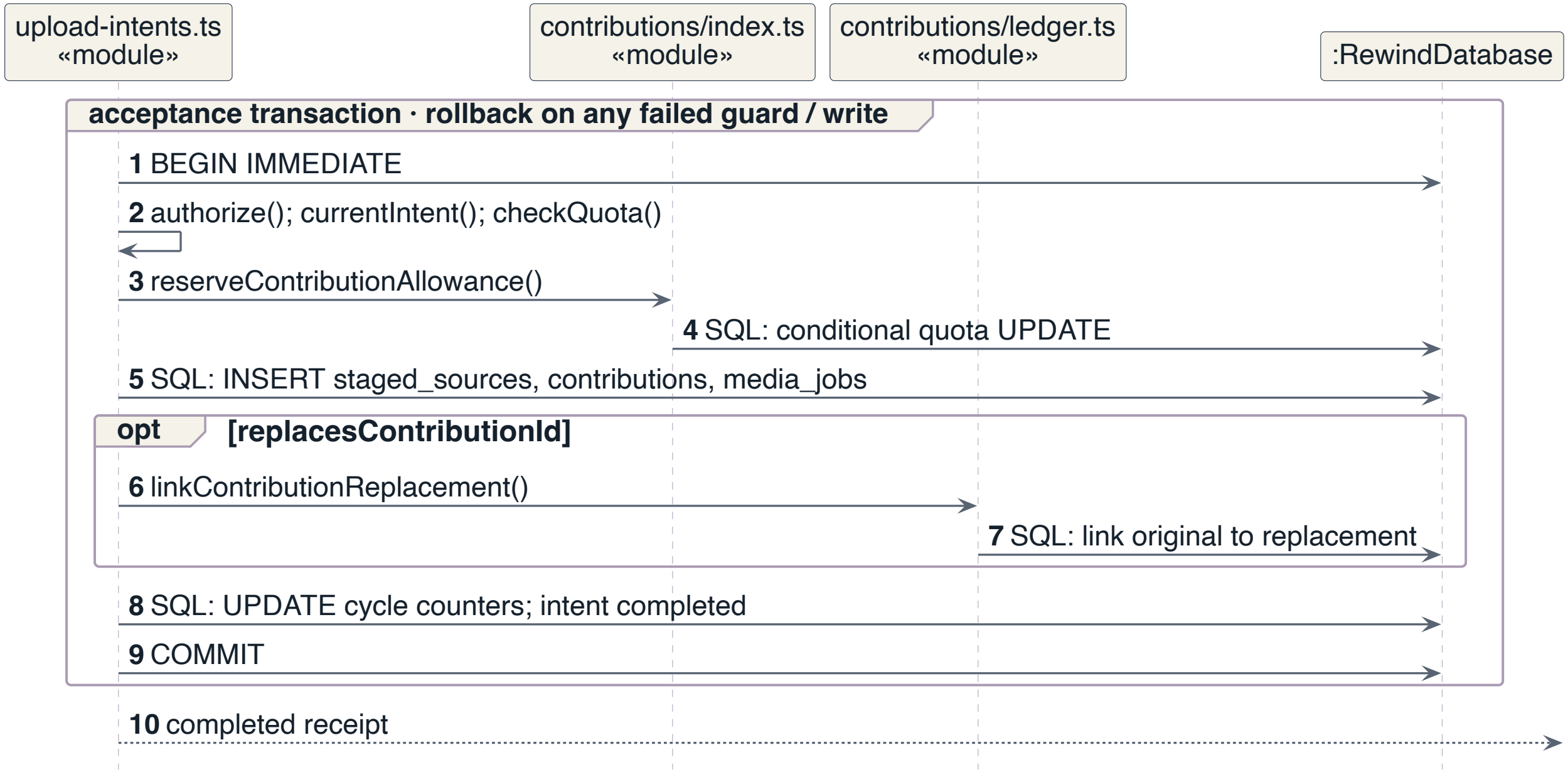
```
gh attestation verify --repo Collaboration95/rewind-app release-manifest.json
```

IaC JSON · 15 findings Signed manifest JSON ZAP JSON

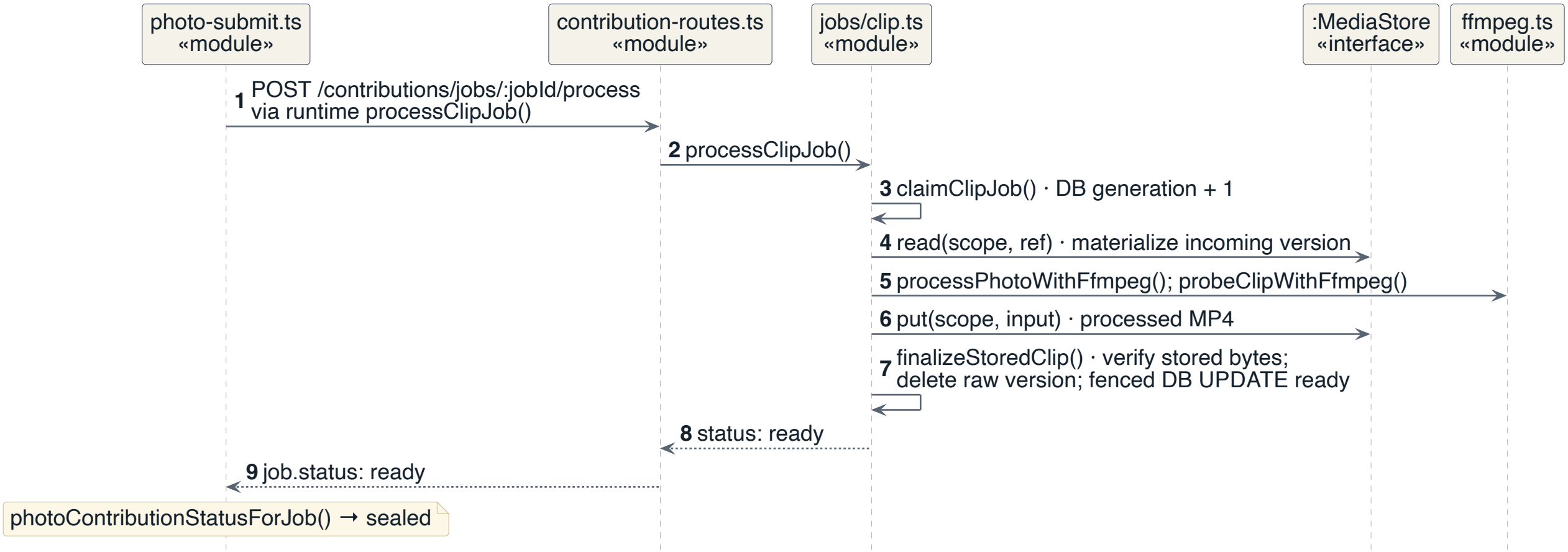
Design sequence · UC05-UC06 Pin and validate the photo



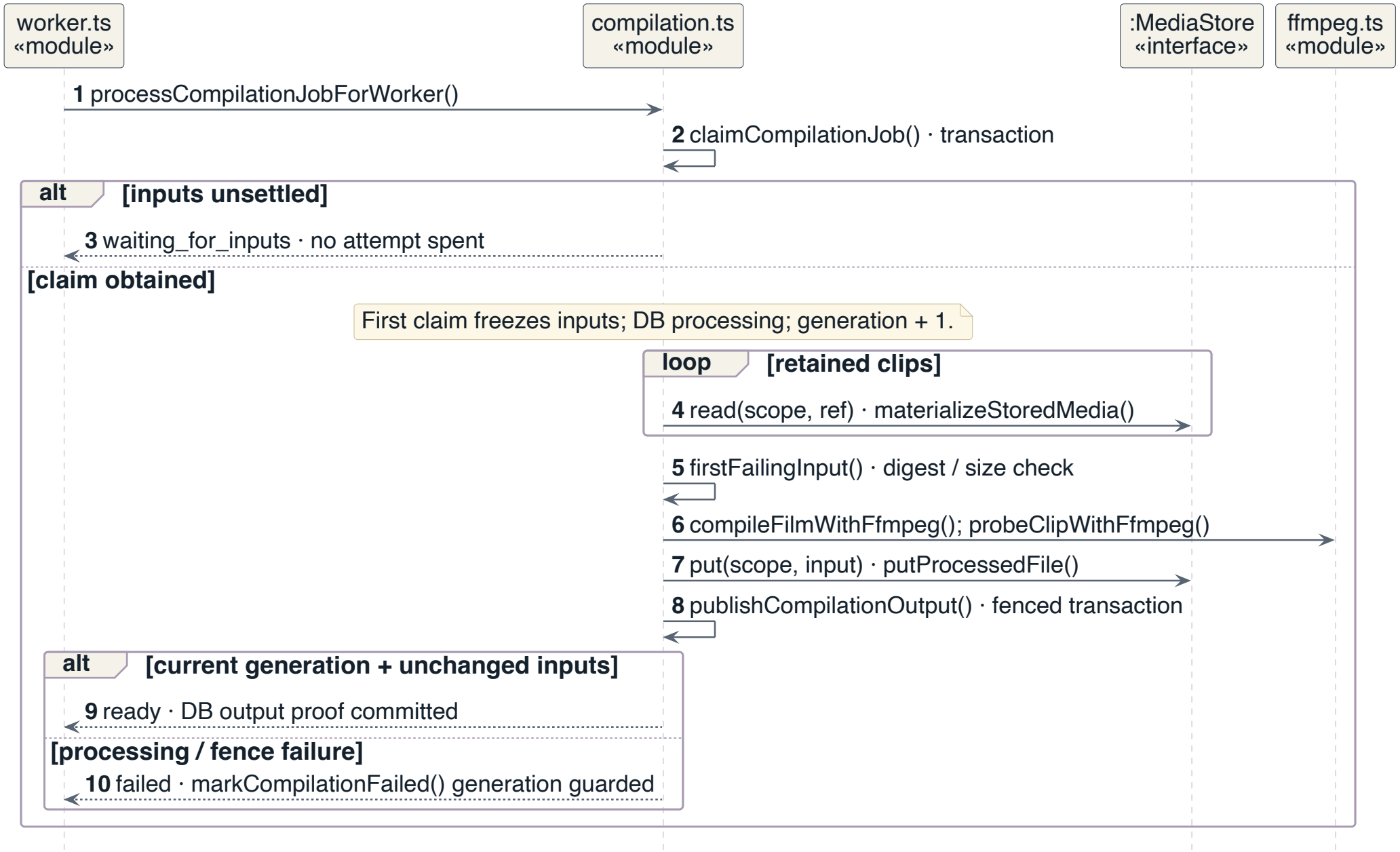
Design sequence · UC06 Commit the allowance and contribution



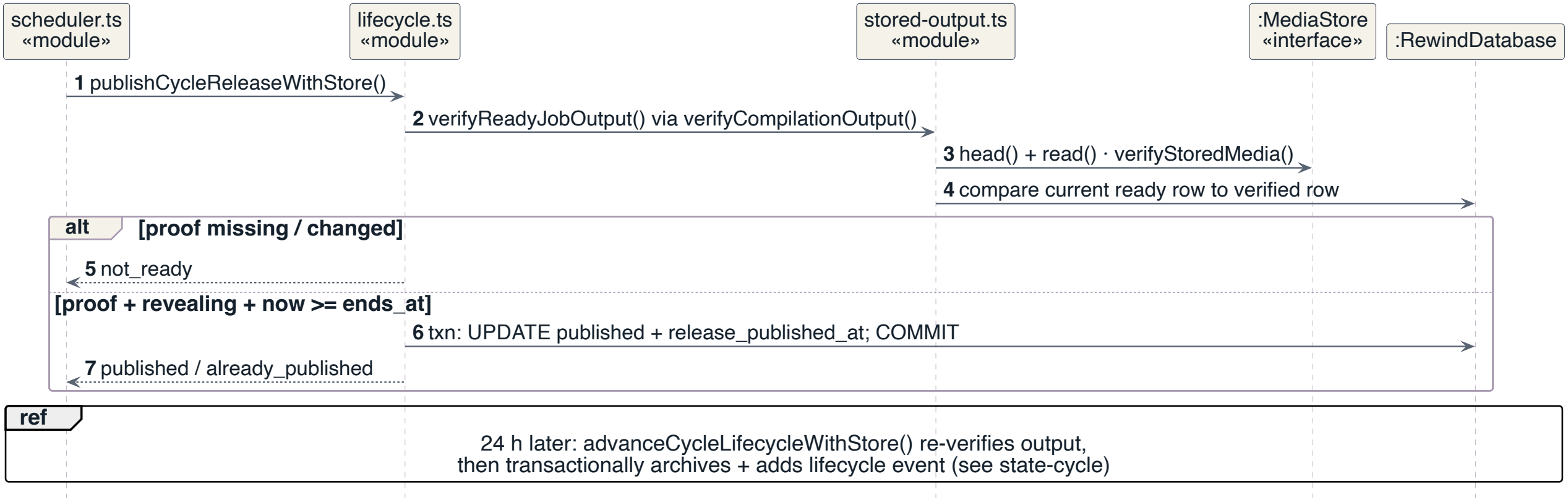
Design sequence · UC05 Process the accepted photo



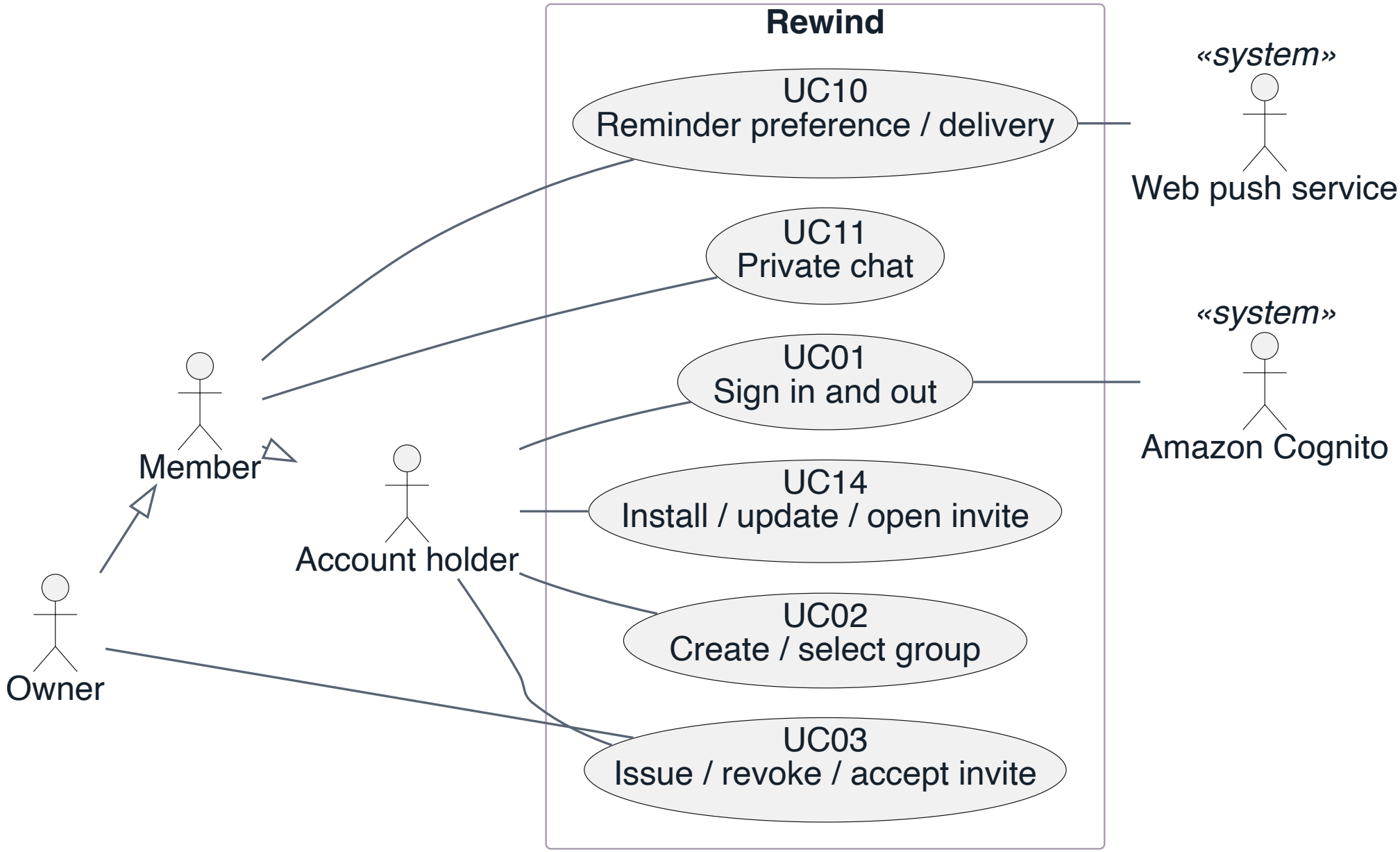
Design sequence · UC08 Compile the cycle film



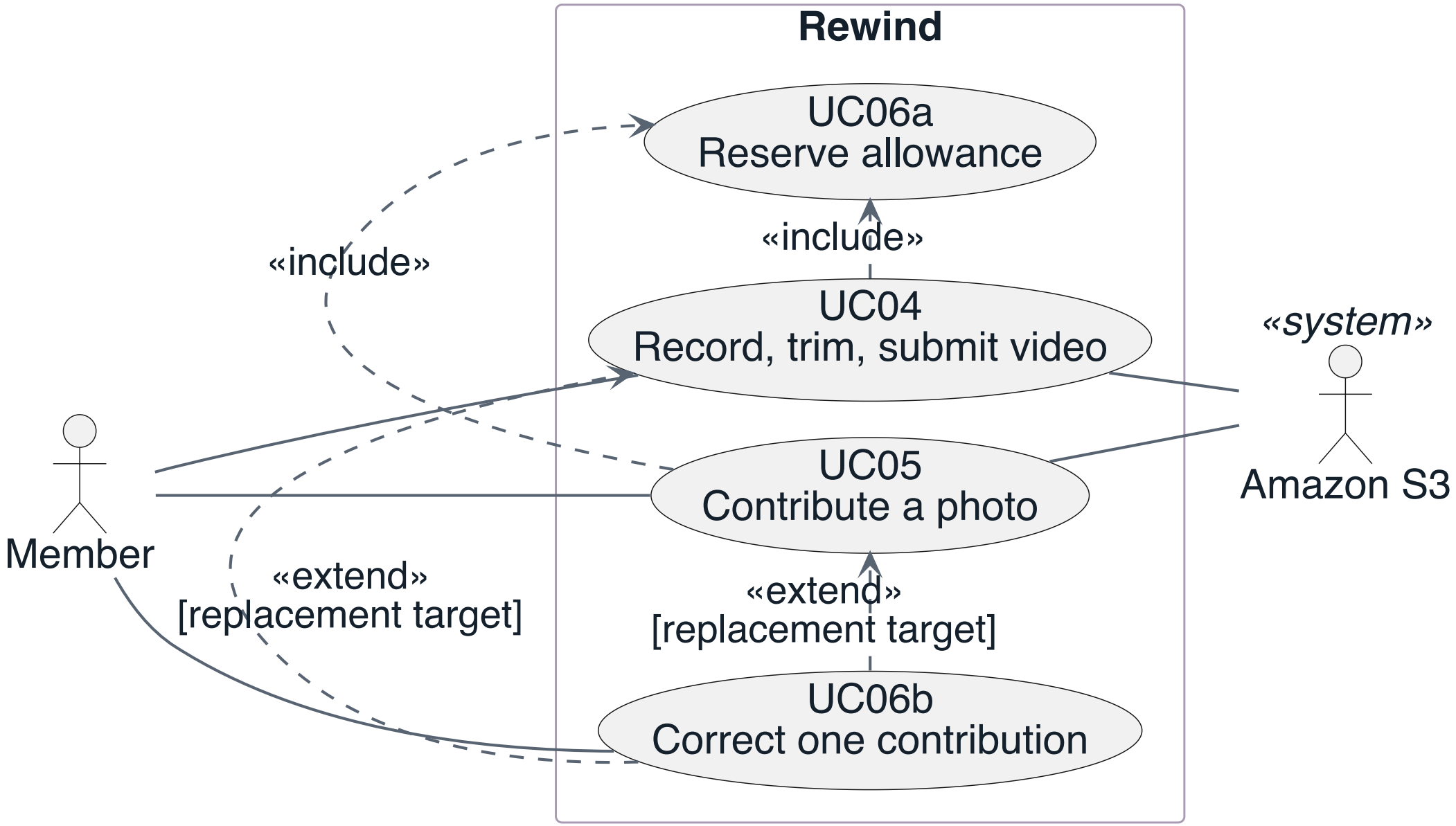
Design sequence · UC08 Publish and archive the film



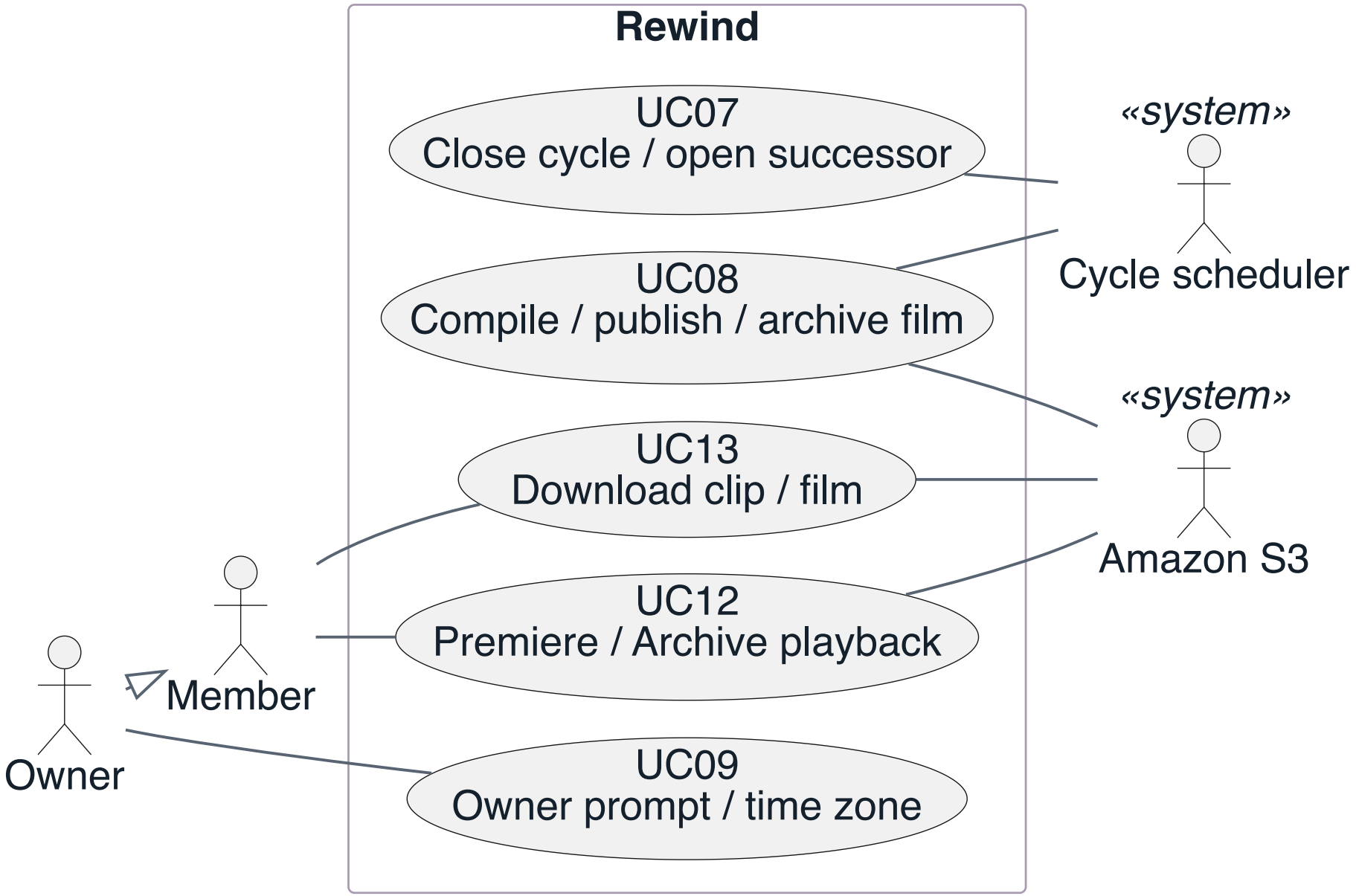
Use case model · UC01-UC03, UC10-UC11, UC14 Participate in a group



Use case model · UC04-UC06 Contribute within allowance

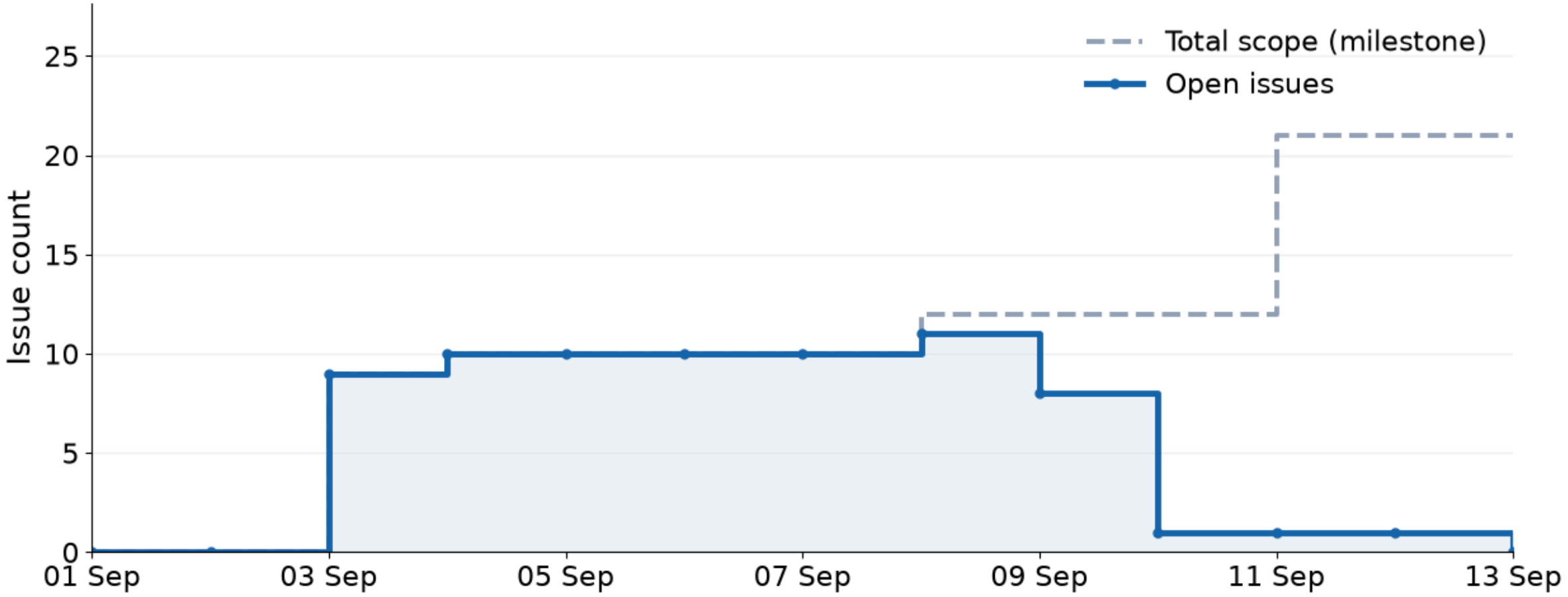


Use case model · UC07-UC09, UC12-UC13 Release and revisit the film



Sprint 0 · issue burndown

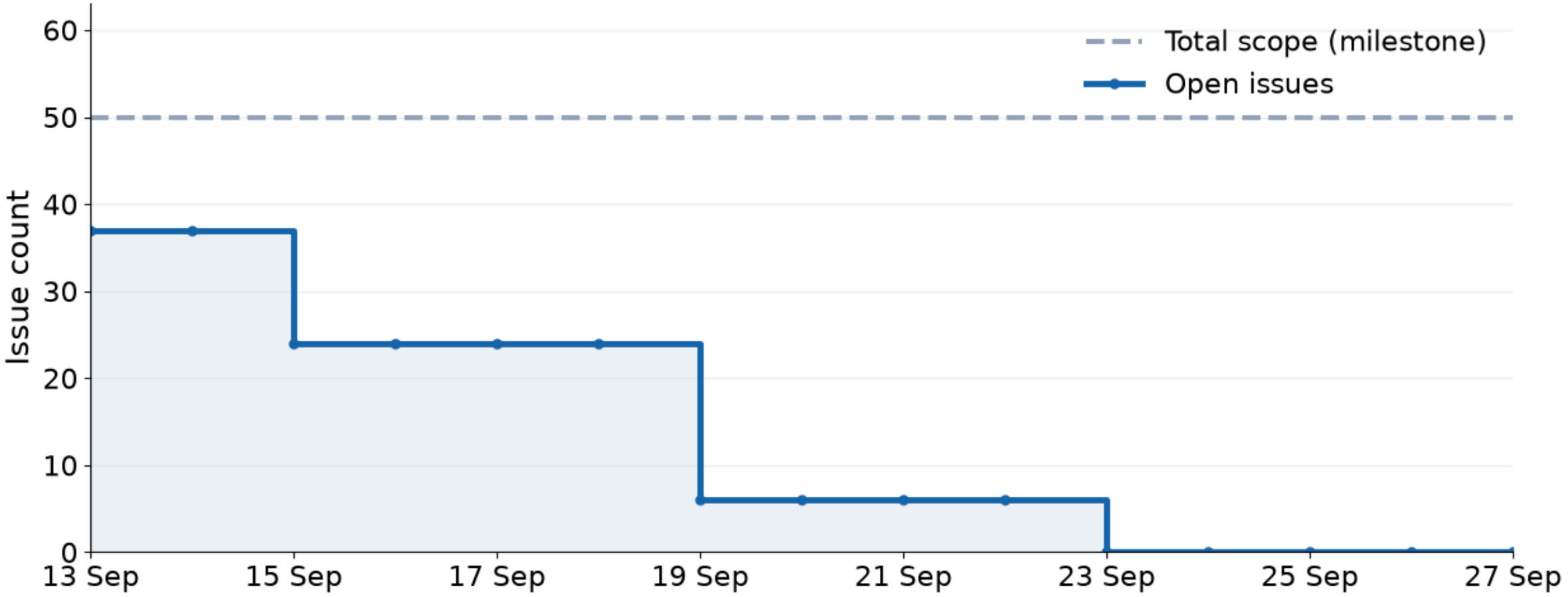
01 Sep–12 Sep 2026 · opening 00:00 and daily closes · SGT



Opening scope/open: 0/0 | Closing scope/open: 21/0

Sprint 1 · issue burndown

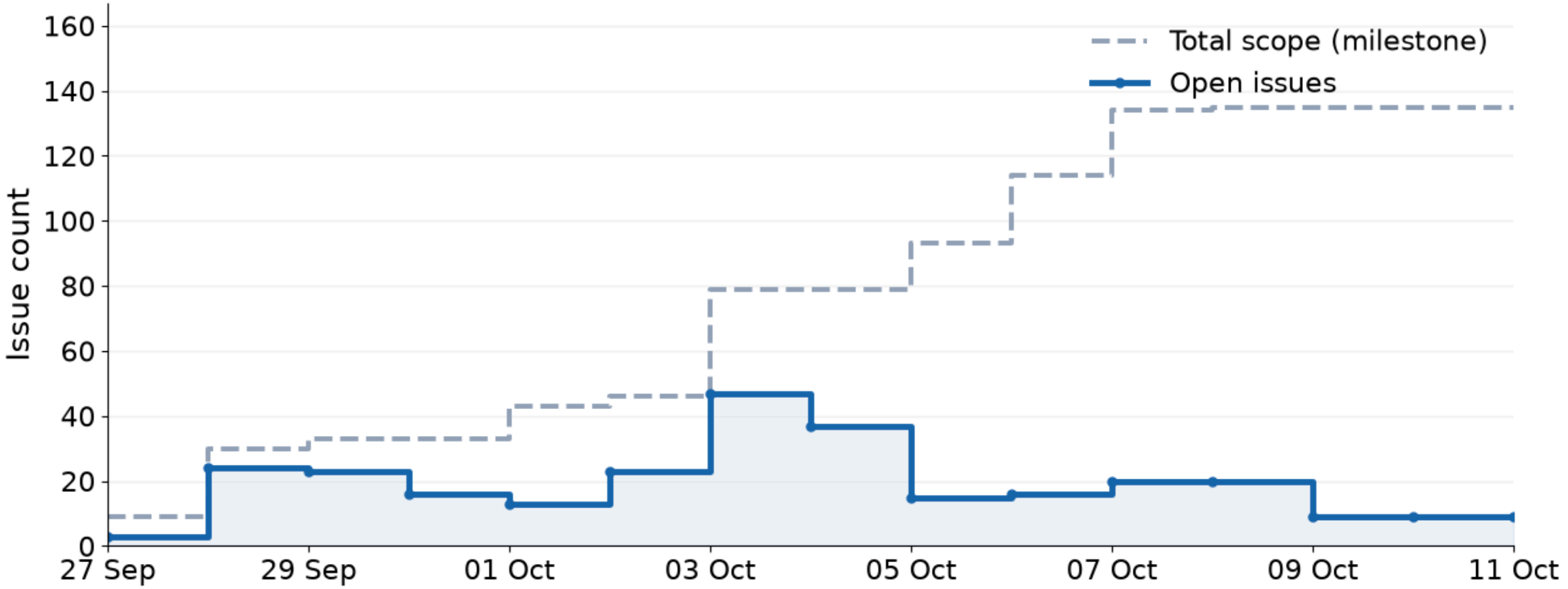
13 Sep–26 Sep 2026 · opening 00:00 and daily closes · SGT



Opening scope/open: 50/37 | Closing scope/open: 50/0

Sprint 2 · issue burndown

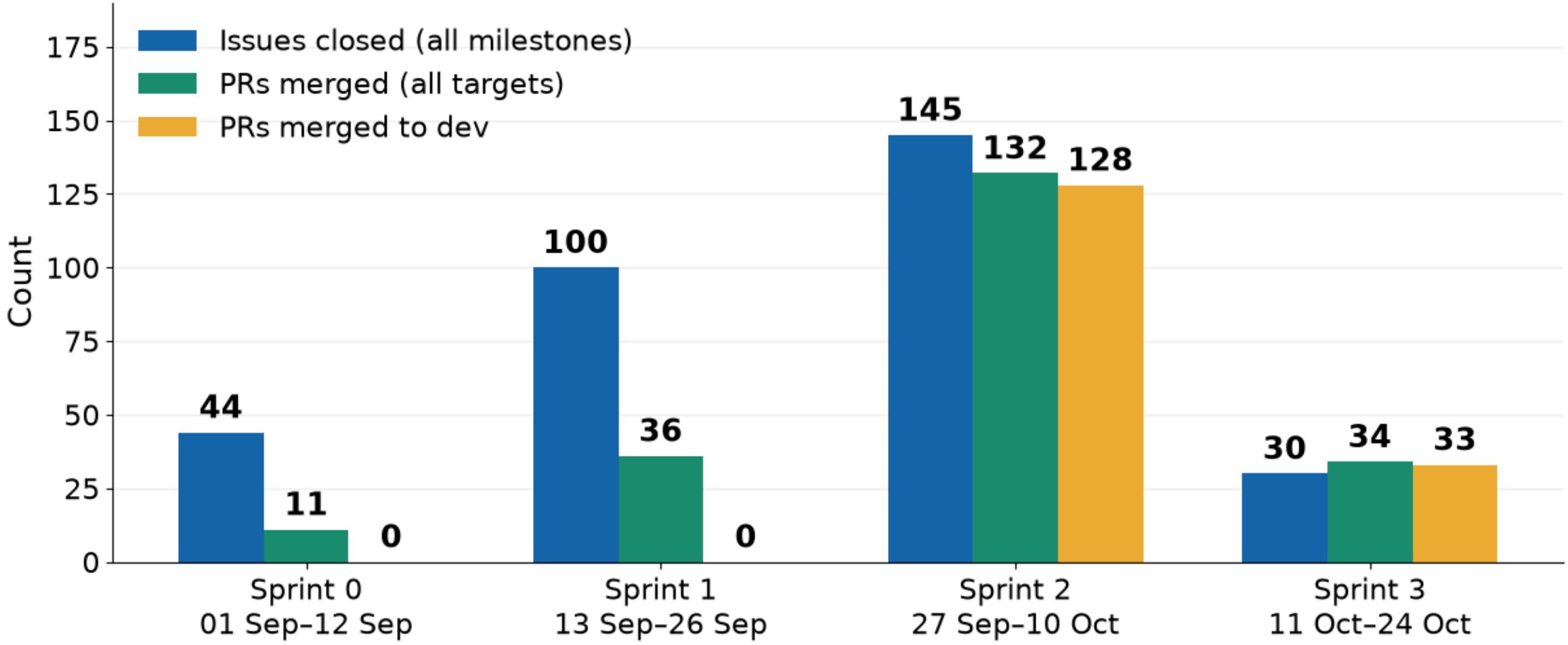
27 Sep–10 Oct 2026 · opening 00:00 and daily closes · SGT



Opening scope/open: 9/3 | Closing scope/open: 135/9

Delivery throughput by sprint

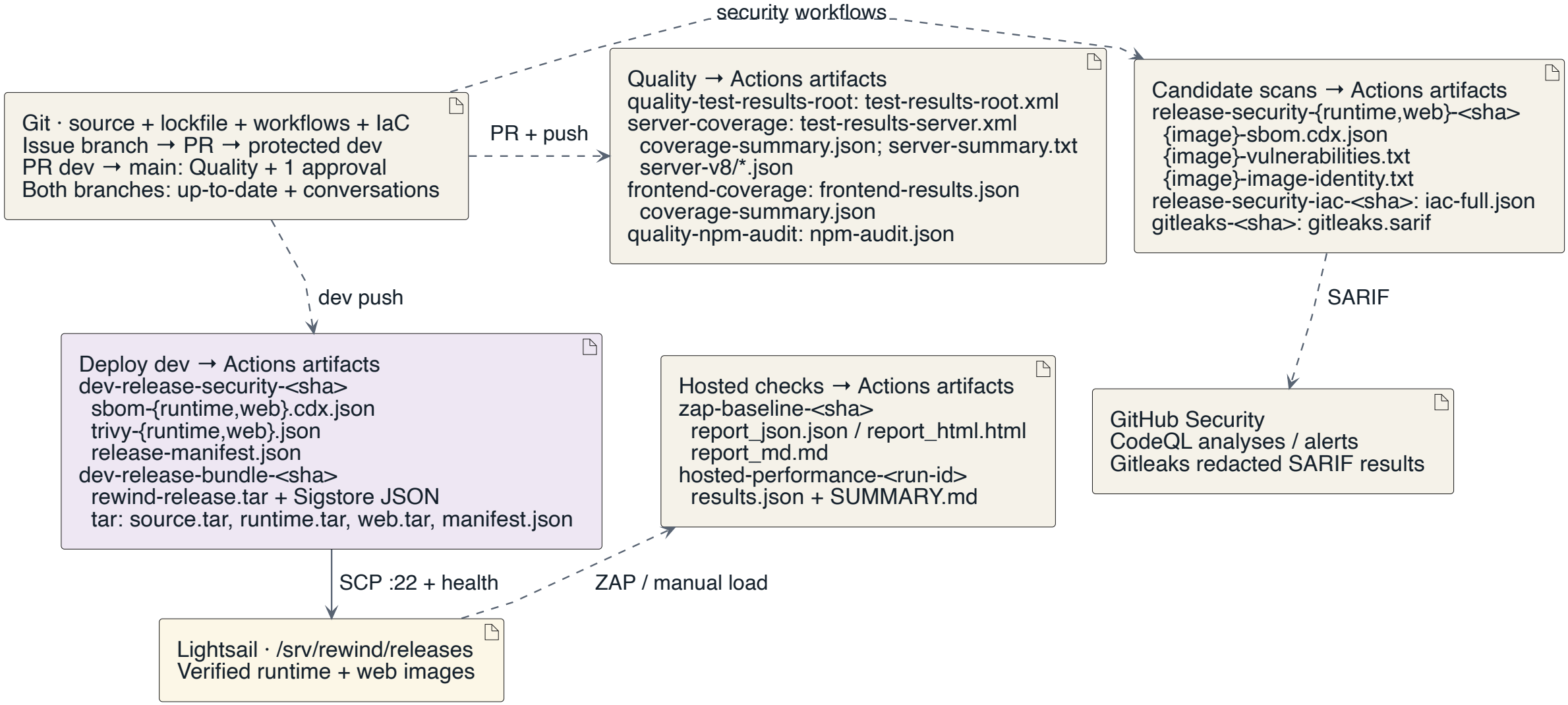
Calendar windows in SGT · issue closures and merged PRs



Backlog stories connect sprint goals to delivered use cases

ARTIFACT	RECORD / TRACE
Product backlog	329 issues · 319 closed · 10 open; mvp delivery path has 7 open
User story · UC05	As a member, seal a photo as a three-second segment. S2 #313 → S3 #545 / #574
Sprint plans	S0 foundation → S1 integrated journey → S2 real accounts → S3 stability
Sprint Review	Each sprint reviews its increment against the selected scope
Retrospective	S1 integration gaps → S2 real adapters; S2 stale state → S3 interaction tests

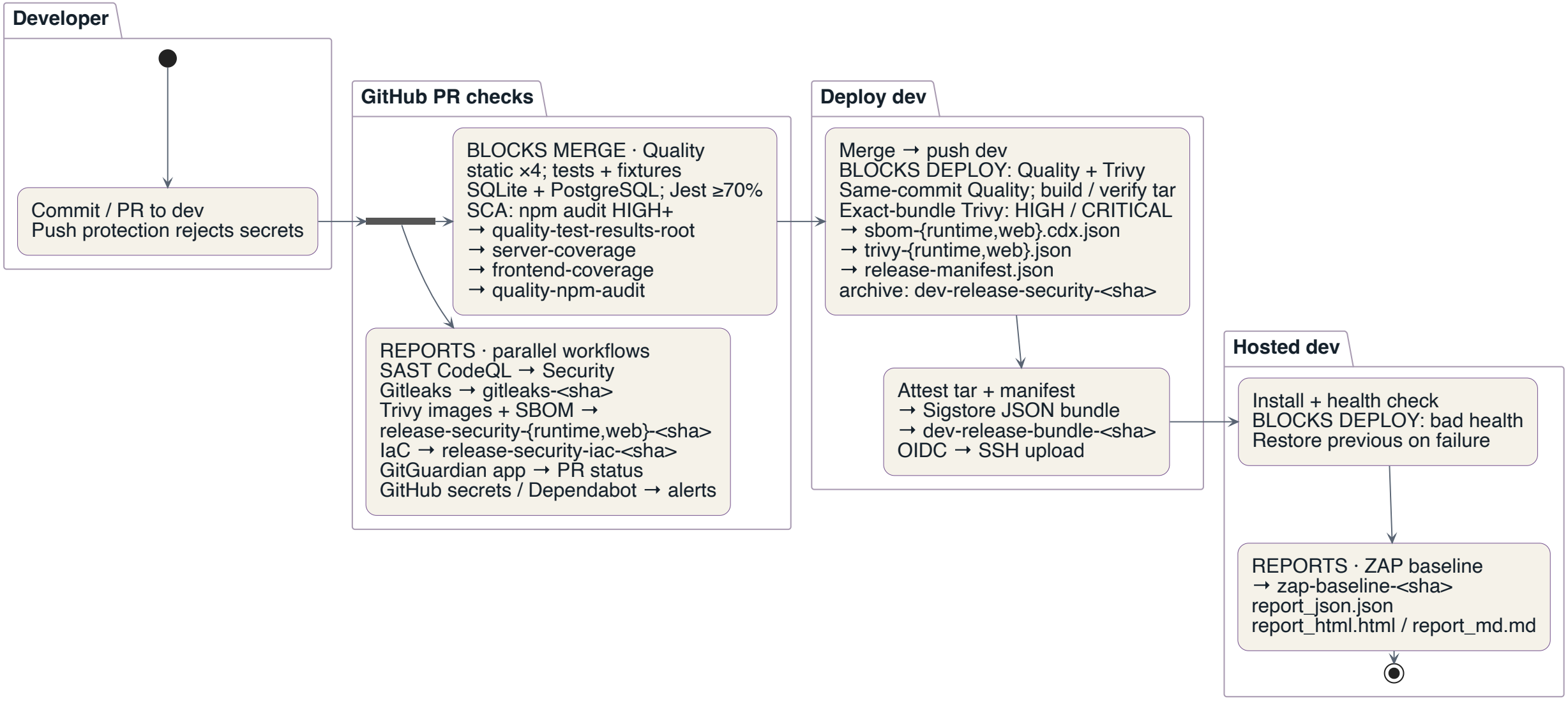
Artifact view · Source, evidence and deployable bundle



Actions retention: 30 d; server/frontend coverage and hosted performance: 14 d. CodeQL results live in Security. Manifest binds commit + Quality run + image IDs + SHA-256(tar, SBOMs, Trivy). Attestation signs tar + manifest. <sha> = commit; {runtime,web} = both images. Main browser checks join Quality; hosted dev is the deployment target.

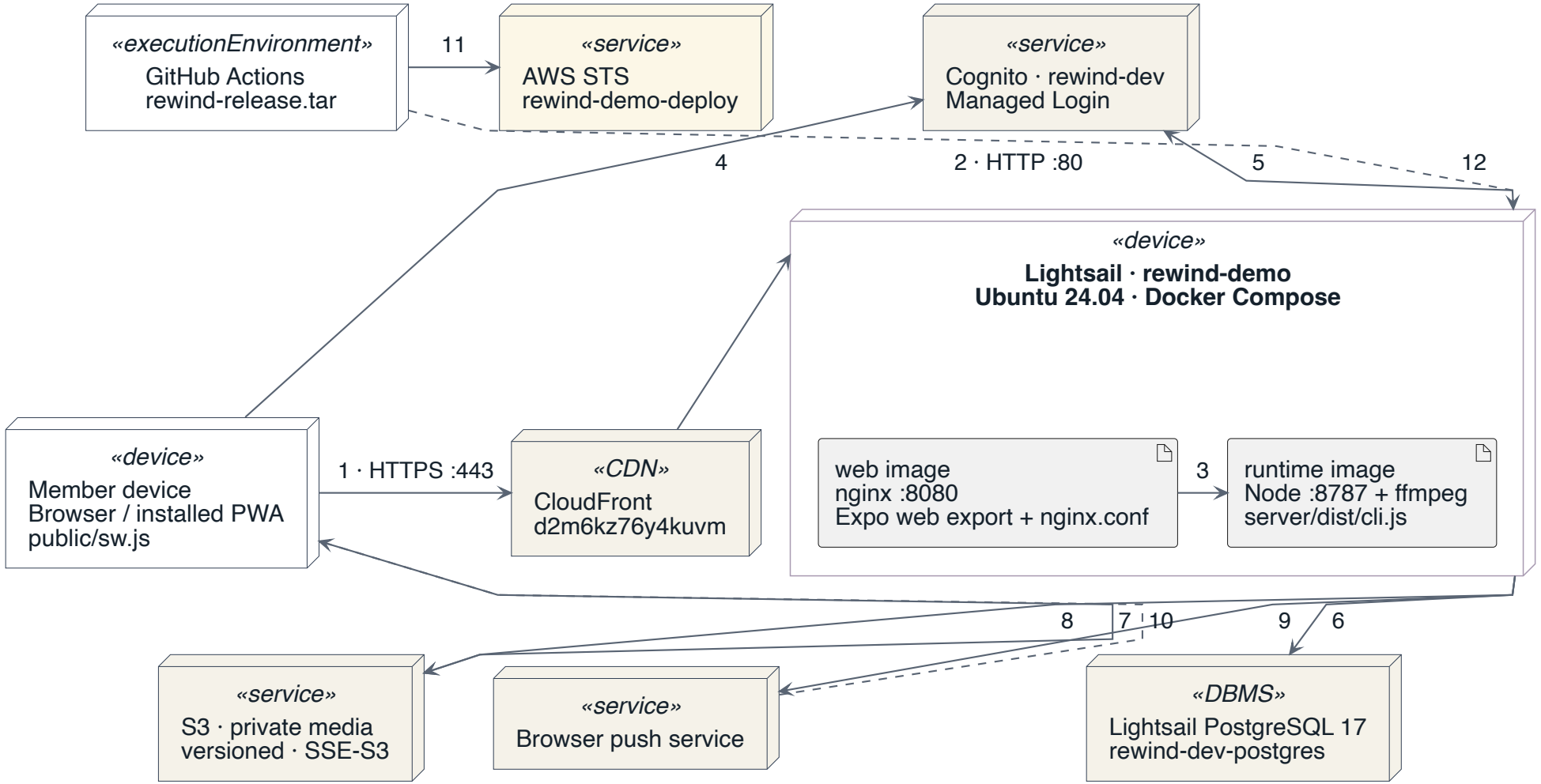
Pipeline decisions separate merge gates from host activation

Activity view · DevSecOps checks and hosted delivery



BLOCKS MERGE = required Quality. BLOCKS DEPLOY = stops upload / activation. REPORTS = outside both gates.
PR + push: Quality, CodeQL, Gitleaks; CodeQL also weekly. Candidate scans: path-filtered PR, dev/main push, v*, manual.
Deploy: dev push / manual; docs-only skips host work and app checks. Main adds browser checks to Quality.
Manual performance REPORTS → hosted-performance-<run-id>: results.json + SUMMARY.md. Independent scans can fail their jobs.

Deployment view · Hosted dev



1 Browser → CloudFront: HTTPS :443. 2 CloudFront → nginx: HTTP :80 → :8080 + origin auth header.
3 nginx → Node: HTTP :8787 /api + SSE. 4 Browser → Cognito: HTTPS :443, authorization code + PKCE.
5 Node → Cognito: HTTPS :443 token exchange. 6 Node → PostgreSQL: TLS :5432.
7 Browser → S3: HTTPS :443 presigned PUT. 8 Node → S3: HTTPS :443 with IAM user credentials.
9 Node → push service: HTTPS :443 / VAPID. 10 Push service → PWA: push event.
11 Actions → STS: OIDC / HTTPS :443, 1 h dev role. 12 Actions → host: SCP / SSH :22, runner /32.
AWS ap-southeast-1. OIDC: dev branch + environment. Node owns the cycle, media and reminder loops.

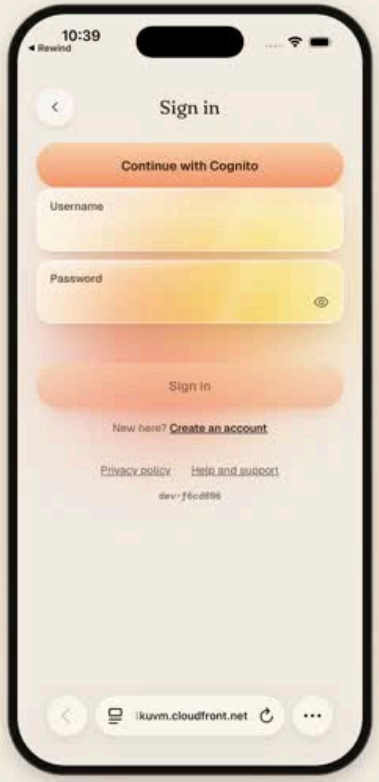
Packaging and runtime boundaries exposed useful defects

FINDING	CONSEQUENCE	REPAIR / LEARNING
New advisory in a locked dependency tree	3 High zod findings blocked Quality	Override update + clean audit
Alpine removed a pinned FFmpeg package	Image build failed before scan	Update to available 8.1.3-r0 pin
Schema registry moved during refactoring	Bundle verifier read the old location	Read the declared schema version
Service worker retained SSE forwarding	Group switching exhausted streams	Browser-owned SSE + cancellation checks
Retry UI preserved the failed state	“Try again” returned without capture	Behavioural test + viewfinder reset

Test the adapter, the built image and the whole interaction.

Installation keeps the app one tap away

01 Install to Home Screen



Do. Safari → Share → Add to Home Screen → open.

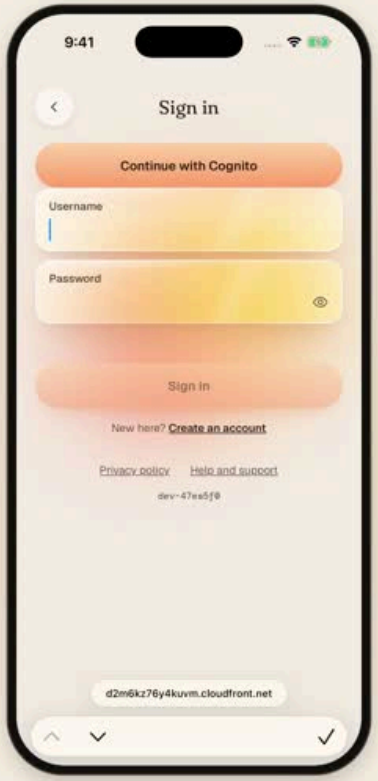
Observe. The installed app opens in its own Home Screen window.

Why. This is the iPhone delivery surface.

P / click · play or pause

Sign-in returns the member to the private-group journey

02 Sign in



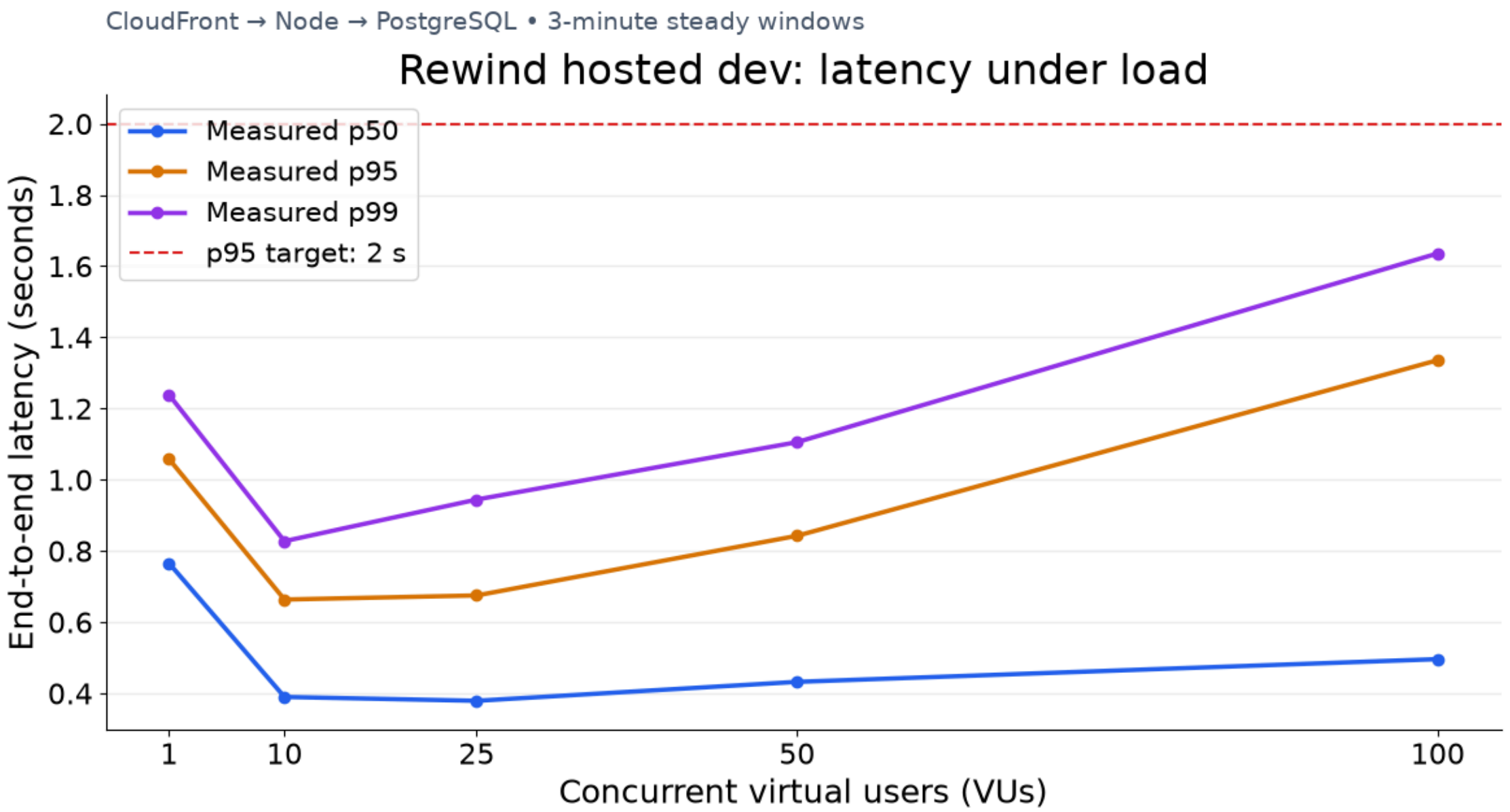
Do. Sign in as Maya and open her group space.

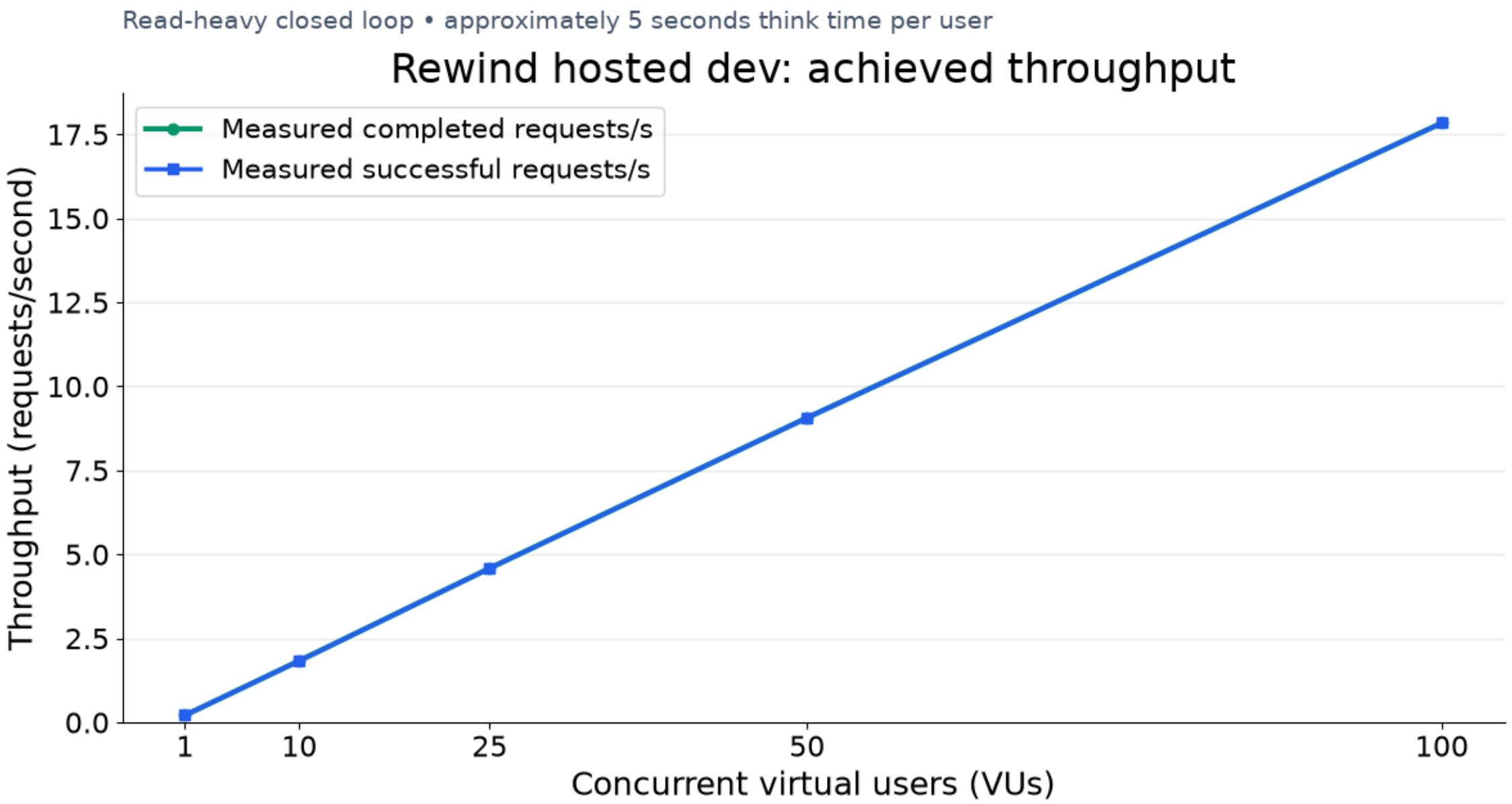
Observe. The authenticated account returns to Rewind.

Design. Web identity supports Cognito code + PKCE with server-side exchange.

P / click · play or pause

Every steady load stage stays below the latency target




Read-heavy closed loop • approximately 5 seconds think time per user
Rewind hosted dev: achieved throughput
Measured completed requests/s
Measured successful requests/s
Throughput (requests/second)
0.0
2.5
5.0
7.5
10.0
12.5
15.0
17.5
1
10
25
50
100
Concurrent virtual users (VUs)

Source → Quality → hosted dev

SWE5006 · TEAM 14 · DEVSECOPS

Every change passes through explicit decisions

Rewind CI/CD · source, security, artifacts and hosted dev

DECISION 1 — QUALITY GATE

Pull request

Focused change → protected dev

DECISION 2 — QUALITY GATE

Parallel verification

Tests · coverage · dependency audit

DECISION 3 — TRIAGE

Security findings

CodeQL · secrets · images · IaC

DECISION 4 — UPLOAD GATE

Verified release bundle

Trivy · SBOM · manifest · provenance

DECISION 5 — HOSTED DEV

Deploy and inspect

OIDC → host health → ZAP baseline

DECISION 6 — REVIEW GATE

Promotion

Protected main → approving review

dev · Quality · signed artifacts · hosted dev /api/health · promotion PR #586

Rewind · CI/CD · hosted dev

Branch protection: dev automates the gate; main adds a human review

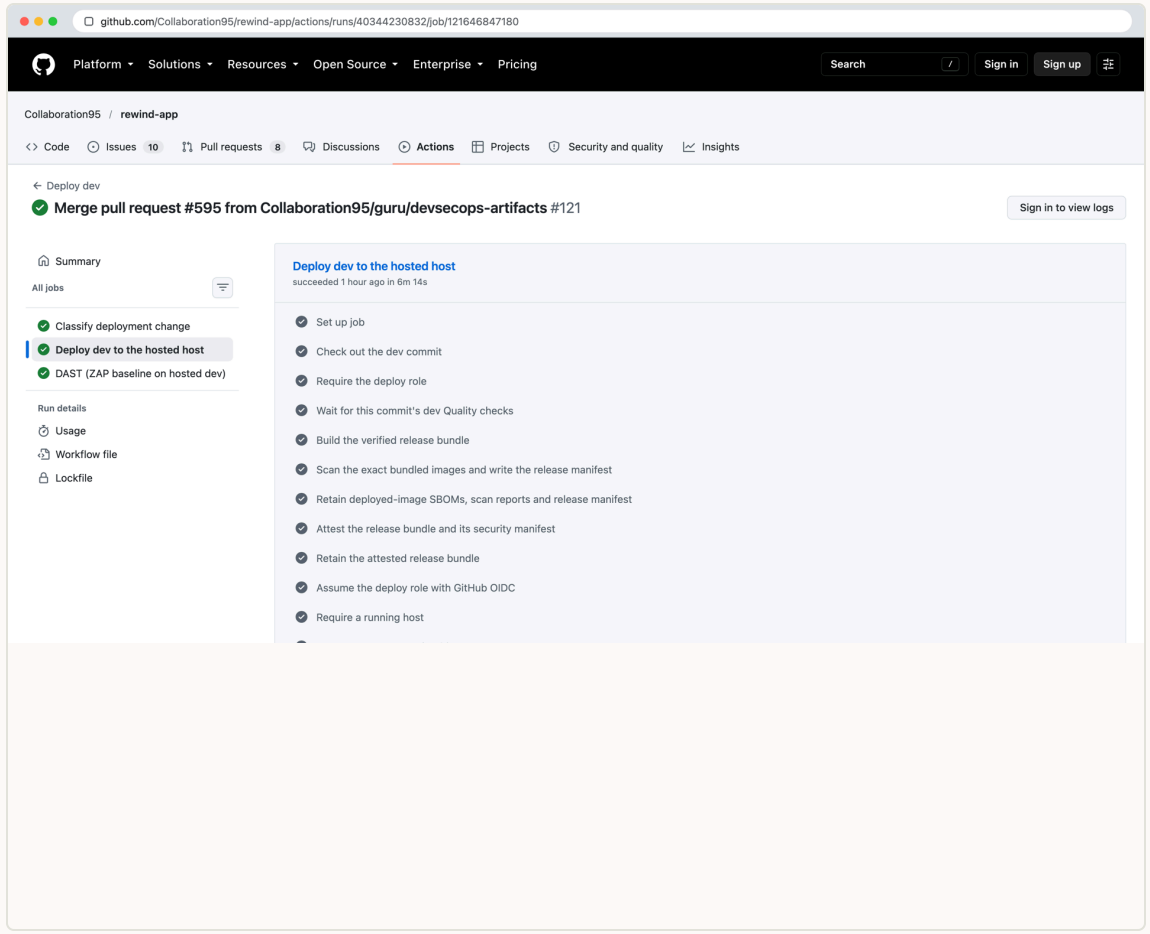
RULE	DEV	MAIN
Required status check	Format, lint, typecheck, and test	same
Branch up to date (strict)	yes	yes
Approving reviews	0	1 · last push must be approved
Conversation resolution	required	required
Applies to administrators	yes	yes
Force-push / deletion	blocked	blocked
Extra Quality lane	—	web export, PWA, accessibility

Repository security: secret scanning and push protection on · Dependabot security updates on · all actions pinned to commit SHAs · default token read-only.

Branch settings ↗ Promotion PR #586 ↗

Deploy job steps in GitHub, in the order of the stage diagrams

DEPLOY DEV 40344230832 · JOB STEPS



SAME RUN · THREE RETAINED ARTIFACTS